В.В. Горгорова, А.В. Чернов

ИНФОРМАЦИОННАЯ БЕЗОПАСНОСТЬ

Учебное пособие

УДК 691.391

Информационная безопасность, Учебное пособие – Ростов н/Д: Рост. гос. строит. ун-т, 2011. – с.

В учебном пособии в систематизированном виде изложены основные сведения, необходимые для начального знакомства с проблемами информационной безопасности и включающие в себя обзор нормативно-правовой базы в области защиты информации, защиты операционных систем и сетей, описание криптографических методов защиты информации. Подробно описаны и разобраны на примерах отдельные виды симметричных и ассиметричных шифров. Приведены лабораторные и практические работы, дополняющие курс «Информационная безопасность», индивидуальные задания для самостоятельной работы.

Для студентов, преподавателей, а так же широкого круга читателей интересующихся вопросами информационной безопасности.

Соответствует государственным образовательным стандартам по специальностям Экономика и управление, Прикладная информатика.

УДК 691.391

Составители:
к. т. н., доц. В.В. Горгорова
д.т.н., проф. А.В.Чернов

Рецензент:
д.т.н.,
проф. каф. Информатики ФГБОУ ВПО РГУПС М.А. Бутакова

Редактор Н.Е. Гладких
Темплан 2011 г., поз.

Подписано в печать Формат $60 \times 84/16$. Бумага писчая. Ризограф.
Уч.-изд.л. 1,7 Тираж 100 экз. Заказ

Редакционно-издательский центр
Ростовского государственного строительного университета
344022, Ростов-на-Дону, ул. Социалистическая, 162.

© Ростовский государственный
строительный университет, 2011

Оглавление

Глава 1. Нормативно-правовые аспекты защиты информации 5
1.1. Российское организационное и нормативно-правовое обеспечение информационной безопасности 5
1.2. Международные нормативно-правовые акты обеспечения ИБ 15
1.3. Правовая база лицензирования и сертификации в области защиты информации 19
1.4. Преступления в сфере компьютерной информации и вопросы защиты авторских прав 27
Глава 2. Безопасность вычислительных систем и сетей 40
2.1. Задача обеспечения информационной безопасности в современных условиях. Информация как объект защиты 40
2.2. Источники угроз и способы нарушения информационной безопасности 42
2.3. Аспекты практической компьютерной безопасности. Средства анализа защищенности систем и сетей 47
2.4. Защита компьютеров и сетей. Антивирусное программное обеспечение 50
Глава 3. Криптографические методы защиты информации 57
3.1 Основные понятия криптографии 57
3.2 Разновидности шифров 60
3.2.1 Шифры замены 60
3.2.2 Шифры перестановки 64
3.2.3.Шифры гаммирования. 66
3.3 Системы шифрования с закрытым и открытым ключом 68
3.3.1 RSA-криптосистема с открытым ключом 71
3.4 Электронная цифровая подпись 74
3.4.1 Механизм формирования электронной цифровой подписи 74
3.4.2 Хеш-функция 78
3.4.3 Сертификация открытых ключей 81
Глава 4. Лабораторный практикум 82
4.1 Лабораторная работа № 1 82
4.2 Лабораторная работа № 2 85
4.3 Лабораторная работа № 3 89
4.4 Лабораторная работа № 4 95
4.5 Лабораторная работа № 5 101
4.6 Лабораторная работа № 6 104
4.7 Лабораторная работа № 7 106
4.8 Лабораторная работа № 8 109
4.9 Лабораторная работа № 9. 116
4.10 Лабораторная работа № 10. 116
4.11 Лабораторная работа № 11. 118

ЛИТЕРАТУРА: 120
Приложение 122

Глава 1. Нормативно-правовые аспекты защиты информации

Информационная безопасность Российской Федерации – это защищенность ее национальных интересов в информационной сфере, определяющихся совокупностью сбалансированных интересов личности, общества и государства.

В Доктрине информационной безопасности Российской Федерации отмечено: «Интересы личности в информационной сфере заключаются в реализации конституционных прав человека и гражданина на доступ к информации, на использование информации в интересах осуществления не запрещенной законом деятельности, физического, духовного и интеллектуального развития, а также в защите информации, обеспечивающей личную безопасность.

Интересы общества в информационной сфере заключаются в обеспечении интересов личности в этой сфере, упрочении демократии, создании правового социального государства, достижении и поддержании общественного согласия, в духовном обновлении России.

Интересы государства в информационной сфере заключаются в создании условий для гармоничного развития российской информационной инфраструктуры, реализации конституционных прав и свобод человека и гражданина в области получения информации и пользования ею в целях обеспечения незыблемости конституционного строя, суверенитета и территориальной целостности России, политической, экономической и социальной стабильности, в безусловном обеспечении законности и правопорядка, развитии равноправного и взаимовыгодного международного сотрудничества.» [1]

Изложение основ информационной безопасности (ИБ) невозможно без рассмотрения соответствующей нормативно-правовой базы. В ознакомительном курсе по ИБ сложно произвести полный анализ данной области права. Основная задача этой главы состоит в том, чтобы, дать краткий обзор правовых актов, регулирующих вопросы, связанные с ИБ.

1.1. Российское организационное и нормативно-правовое обеспечение информационной безопасности

Современные информационные технологии вошли почти во все сферы общественных отношений. Это привело к необходимости создания правовых норм, регулирующих данную область. Такие нормы необходимы так, как информация имеет специфические свойства, благодаря которым она принципиально отличается от других объектов права. Например, хищение информации не всегда связано с кражей носителя информации. Информацию можно с помощью удаленного доступа по сетям связи просто скопировать, находясь за тысячи километров от объекта доступа, при этом после похищения информация останется в распоряжении владельца в неизменном виде.

---

[1] Доктрина информационной безопасности Российской Федерации. Утверждена Президентом РФ 09.09.2000. Совм. Изд. Ред. «Российская газета» и Международная Академия Информатизации. – М.: Межд. Изд. «Информациология», 2000. (интернет ресурс http://www.rg.ru/oficial/doc/min_and_vedom/mim_bezop/doctr.shtm http://www.infoguard.ru/legislation?ID=1&show_id=4)

Особенность информационных правоотношений состоит в том, что развитие технических средств, предоставляющих качественно новые возможности формирования и использования информационных ресурсов, происходит быстрее, чем создается необходимая правовая база, регламентирующая использование этих возможностей.

В настоящее время законодательные меры по защите процессов переработки информации заключаются в исполнении существующих в стране или введении новых законов, положений, постановлений и инструкций, регулирующих юридическую ответственность как должностных, так и частных лиц.

Цель законодательных мер — предупреждение и сдерживание потенциальных нарушителей.

Политика национальной безопасности и информационная политика страны должны проводиться по единым принципам. Основным документом, в котором развивается концепция национальной безопасности РФ применительно к информационной сфере, является Доктрина информационной безопасности Российской Федерации, утвержденная Президентом РФ 09.09.2000г.

Доктрина информационной безопасности Российской Федерации представляет собой совокупность официальных взглядов на цели, задачи, принципы и основные направления обеспечения информационной безопасности РФ.

Доктрина служит основой для формирования государственной политики в области обеспечения информационной безопасности РФ; подготовки предложений по совершенствованию правового, методического, научно-технического и организационного обеспечения информационной безопасности РФ; разработки целевых программ обеспечения информационной безопасности РФ.

В Доктрине информационной безопасности Российской Федерации раскрыто содержание следующих принципов, закрепленных в Федеральном законе от 27.07.2006 № 149-ФЗ «**Об информации, информационных технологиях и о защите информации**» взамен утратившего силу Федерального закона **«Об информации, информатизации и защите информации»** от 20.02.1995 № 24-ФЗ:

- законность (соблюдение Конституции РФ, законодательства Российской Федерации и норм международного права при осуществлении деятельности по обеспечению национальной безопасности);
- соблюдение баланса жизненно важных интересов личности общества и государства (единство, взаимосвязь и сбалансированность всех видов безопасности, гибкое изменение их приоритетности в зависимости от ситуации);
- недопустимость ограничения прав и свобод граждан, за исключением случаев, прямо предусмотренных законом (уважение прав и свобод человека);
- взаимная ответственность личности, общества и государства по обеспечению безопасности; интеграция с международными системами безопасности;

- приоритет политических и экономических мер обеспечения национальной безопасности с опорой на военный потенциал России; сочетание централизованного управления силами и средствами обеспечения безопасности с передачей в соответствии с федеративным устройством России части полномочий в этой области органам государственной власти субъектов Российской Федерации и органам местного самоуправления.

Государственная информационная политика должна опираться на следующие базовые принципы:

- открытость политики (все важнейшие мероприятия информационной политики открыто обсуждаются обществом, государство учитывает общественное мнение);
- равенство интересов участников (политика в равной степени учитывает интересы всех участников информационной деятельности независимо от их положения в обществе, формы собственности и государственной принадлежности);
- системность (реализация процессов обеспечения ИБ через государственную систему);
- приоритет отечественного производителя (при равных условиях приоритет отдается конкурентоспособному отечественному производителю информационно-коммуникационных средств, продуктов и услуг);
- социальная ориентация (основные мероприятия информационной политики должны быть направлены на обеспечение социальных интересов граждан России);
- государственная поддержка (мероприятия информационной политики, направленные на информационное развитие социальной сферы финансируются преимущественно государством);
- приоритет права — законность (развитие и применение правовых и экономических методов имеет приоритет перед любыми формами административных решений проблем информационной сферы);
- сочетание централизованного управления силами и средствами обеспечения безопасности с передачей в соответствии с федеральным устройством России части полномочий в этой области органам государственной власти субъектов Российской Федерации и органам местного самоуправления;
- интеграция с международными системами обеспечения ИБ.

К основным задачам в сфере обеспечения ИБ РФ относятся:

- формирование и реализация единой государственной политики по обеспечению защиты национальных интересов от угроз в сфере реализации конституционных прав и свобод граждан на информационную деятельность;
- совершенствование законодательства РФ в сфере обеспечения ИБ;

- определение полномочий органов государственной власти РФ, субъектов Российской Федерации и органов местного самоуправления в сфере обеспечения ИБ;
- координация деятельности органов государственной власти по обеспечению ИБ;
- создание условий для успешного развития негосударственного компонента в сфере обеспечения ИБ, осуществления эффективного гражданского контроля над деятельностью органов государственной власти;
- совершенствование и защита отечественной информационной инфраструктуры, ускорение развития новых информационных технологий и их широкое распространение, унификация средств поиска, сбора, хранения, обработки и анализа информации с учетом вхождения России в глобальную информационную инфраструктуру;
- развитие стандартизации информационных систем на базе общепризнанных международных стандартов и их внедрение для всех видов информационных систем;
- развитие отечественной индустрии телекоммуникационных и информационных средств, их приоритетное по сравнению с зарубежными аналогами распространение на внутреннем рынке;
- защита государственных информационных ресурсов, прежде всего в федеральных органах государственной власти, на предприятиях оборонного комплекса;
- духовное возрождение России; обеспечение сохранности и защиты культурного и исторического наследия (в том числе музейных, архивных, библиотечных фондов, основных историко-культурных объектов);
- сохранение традиционных духовных ценностей при важнейшей роли Русской православной церкви и церквей других конфессий;
- пропаганда средствами массовой информации элементов национальных культур народов России, духовно-нравственных, исторических традиций, норм общественной жизни и передового опыта подобной пропагандистской деятельности;
- повышение роли русского языка как государственного языка и языка межгосударственного общения народов России и государств - членов СНГ;
- создание оптимальных социально-экономических условий для осуществления важнейших видов творческой деятельности и функционирования учреждений культуры;
- противодействие угрозе развязывания противоборства в информационной среде;
- организация международного сотрудничества по обеспечению ИБ при интеграции России в мировое информационное пространство.

Для реализации указанных задач государственной системой обеспечения информационной безопасности необходимо осуществлять следующие функции:

- оценка состояния ИБ в стране, определение приоритетов по интересам в информационной сфере и установление их баланса в конкретных условиях;
- выявление и учет источников внутренних и внешних угроз, проведение их мониторинга и классификации;
- определение основных направлений предотвращения угроз или минимизации ущерба от их реализации;
- организация исследований в сфере обеспечения ИБ;
- разработка и принятие законов и иных нормативно-правовых актов;
- разработка федеральных целевых и ведомственных программ обеспечения ИБ, координация работ по их реализации;
- организация единой системы лицензирования, сертификации, экспертизы и контроля в этой сфере;
- страхование информационных рисков;
- подготовка специалистов по обеспечению ИБ, в том числе из числа работников правоохранительных и судебных органов;
- информирование общественности о реальной ситуации в сфере обеспечения ИБ и работе государственных органов в этой сфере;
- изучение практики обеспечения ИБ, обобщение и пропаганда передового опыта такой работы в регионах;
- правовая защита прав и интересов граждан, интересов общества и государства в сфере ИБ;
- организация обучения способам и методам самозащиты физических лиц от основных угроз в информационной сфере;
- содействие разработке и принятию норм международного права в сфере обеспечения ИБ;
- установление стандартов и нормативов в сфере обеспечения ИБ.

Эффективность установления стандартов и нормативов в сфере обеспечения ИБ определяет сроки и возможности организации системы обеспечения ИБ РФ, поэтому рассмотрим это подробнее.

В Российской Федерации действуют 13 государственных стандартов по защите информации: ГОСТ 28147-89, ГОСТ Р34.10 - 2001, ГОСТ Р 34.11-94, ГОСТ Р 50739-95, ГОСТ Р ИСО/МЭК 15408-1-2002, ГОСТ Р ИСО/МЭК 15408-2-2002, ГОСТ Р ИСО/МЭК 15408-3-2002, ГОСТ Р 50922-2006, ГОСТ Р 51188-98, ГОСТ Р 51275-99, ГОСТ Р ИСО 7498-1-99, ГОСТ Р ИСО 7498-2-99, ГОСТ Р 53898-2010. По классификатору стандартов эти государственные стандарты относятся к различным группам и не являются функционально полными ни по одному из направлений защиты процессов переработки информации. Наряду с этим, есть семейства родственных стандартов, которые имеют отношение к области защиты процессов переработки информации:

- системы тревожной сигнализации, комплектуемые извещателями различного принципа действия, — 12 государственных стандартов;

- информационные технологии (сертификация систем телекоммуникации, программных и аппаратных средств, аттестационное тестирование взаимосвязи открытых систем, аттестация баз данных и т.д.) — около 200 государственных стандартов;
- системы качества (в том числе стандарты серии 9000, введенные в действие на территории Российской Федерации) — больше 100 государственных стандартов.

Одним из аналогов перечисленных стандартов является руководящий документ Гостехкомиссии России **«Автоматизированные системы. Защита от несанкционированного доступа к информации. Классификация автоматизированных систем и требований по защите информации»**.[2]

Комплексный характер защиты процессов переработки информации достигается благодаря использованию унифицированного алгоритмического обеспечения для средств криптографической защиты в соответствии с российскими государственными стандартами:

- ГОСТ 28147—89 «Системы обработки информации. Защита криптографическая. Алгоритм криптографического преобразования»;[3]
- ГОСТ Р 34.10—2001 «Информационная технология. Криптографическая защита информации. Процессы формирования и проверки электронной цифровой подписи»[4];
- ГОСТ Р 34.11—94 «Информационная технология. Криптографическая защита информации. Функция хэширования»[5];
- ГОСТ Р 50739—95 «Средства вычислительной техники. Защита от несанкционированного доступа к информации. Общие технические требования»[6].

Объективно государственные организации могут ограничиться криптографической защитой только своей информации (прежде всего, государственной и служебной тайн). Остальные требования по защите информации должны быть подчинены единым понятным правилам и исполнимым запретам. Это должны быть законы, следуя которым субъект сможет сам защитить свою информацию доступными ему средствами. Введение единообразного подхода к использованию средств криптозащиты оставляет монополисту явную возможность для использования дубликатов.

В ст. 2 ФЗ «**Об информации, информационных технологиях и о защите информации**» информация определяется как «сведения (сообщения, данные)

---

[2] Гостехкомиссия России. Руководящий документ. «Автоматизированные системы. Защита от несанкционированного доступа к информации. Классификация автоматизированных систем и требований по защите информации». – М.: Воениздат,1992.

[3] ГОСТ 28147—89 «Системы обработки информации. Защита криптографическая. Алгоритм криптографического преобразования». – М., 1989.

[4] ГОСТ Р 34.10—2001 «Информационная технология. Криптографическая защита информации. Процессы формирования и проверки электронной цифровой подписи». – М., 2001.

[5] ГОСТ Р 34.11—94 «Информационная технология. Криптографическая защита информации. Функция хэширования» – М., 1994.

[6] ГОСТ Р 50739—95 «Средства вычислительной техники. Защита от несанкционированного доступа к информации. Общие технические требования». – М., 1995.

независимо от формы их представления». Документированная информация (документ) определяется как «зафиксированная на материальном носителе путем документирования информация с реквизитами, позволяющими определить такую информацию или в установленных законодательством Российской Федерации случаях ее материальный носитель».

Отметим, что в Федеральном законе от 29 декабря 1994 года № 77-ФЗ «**Об обязательном экземпляре документов**» документ определяется как «материальный объект с зафиксированной на нем информацией в виде текста, звукозаписи или изображения, предназначенный для передачи во времени и пространстве в целях хранения и общественного использования». В последнем определении нет требования наличия реквизитов, позволяющих идентифицировать информацию, но конкретизируется вид информации (текст, звукозапись или изображение) и постулируется утверждение о «предназначении для общественного использования».

Согласно ст. 5.3, для подтверждения юридической силы документов допускается использование электронной цифровой подписи (ЭЦП). Реализация механизма ЭЦП рассматривается в гл. 3.

В настоящее время ЭЦП используется в финансовой сфере, однако правовые вопросы, связанные с ее применением, не полностью урегулированы. В Федеральном законе от 10 января 2002 года № 1-ФЗ «**Об электронной цифровой подписи**» определены условия, при соблюдении которых электронная цифровая подпись признается равнозначной собственноручной подписи на бумажном носителе. В этом законе прописаны условия использования ЭЦП, особенности её использования в сферах государственного управления и в корпоративной информационной системе. Благодаря ЭЦП многие российские компании осуществляют свою торгово-закупочную деятельность в Интернете, через «Системы электронной торговли», обмениваясь с контрагентами необходимыми документами в электронном виде, подписанными ЭЦП. Это значительно упрощает и ускоряет проведение конкурсных торговых процедур.

Документированная информация с ограниченным доступом (информация, доступ к которой ограничен в соответствии с законодательством РФ) подразделяется на информацию, отнесенную к государственной тайне, и конфиденциальную информацию (к последней можно отнести информацию, представляющую коммерческую, служебную, личную и другие тайны).

Отнесение сведений к государственной тайне, их рассекречивание и защита регулируются законом РФ «**О государственной тайне**» от 21 июля 1993 года № 5485-1. Государственная тайна в этом законе определяется как «защищаемые государством сведения в области его военной, внешнеполитической, экономической, разведывательной, контрразведывательной и оперативно-розыскной деятельности, распространение которых может нанести ущерб безопасности Российской Федерации».

Правовую основу деятельности в области связи на территории РФ устанавливает закон «**О связи**» (Федеральный закон от 07.07.2003 № 126-ФЗ). Согласно ст. 29-43 этого закона, деятельность физических и юридических лиц,

связанная с предоставлением услуг в области связи, подлежит лицензированию, а средства связи, используемые в сетях связи, подлежат сертификации.

Данным законом на предприятия, предоставляющие услуги в области связи, возлагаются определенные обязанности по взаимодействию с правоохранительными органами. В ст. 64.1 сказано: «Операторы связи обязаны предоставлять уполномоченным государственным органам, осуществляющим оперативно-розыскную деятельность или обеспечение безопасности Российской Федерации, информацию о пользователях услугами связи и об оказанных им услугах связи, а также иную информацию, необходимую для выполнения возложенных на эти органы задач, в случаях, установленных федеральными законами.»

Правовые вопросы проведения оперативно-розыскных мероприятий, регулируются Федеральным законом от 12 августа 1995 года № 144 - ФЗ «**Об оперативно-розыскной деятельности**». В ст. 6 этого закона приведен перечень оперативно-розыскных мероприятий, в число которых входят:

«9. Контроль почтовых отправлений, телеграфных и иных сообщений.

10. Прослушивание телефонных переговоров.

11. Снятие информации с технических каналов связи».

В ст. 8 этого закона определяются условия, при которых допустимо проведение оперативно розыскных мероприятий, ограничивающих конституционные права граждан на тайну переписки, телефонных переговоров, почтовых, телеграфных и иных сообщений. Такие мероприятия могут проводиться только на основании судебного решения «и при наличии информации:

1. О признаках подготавливаемого, совершаемого или совершенного противоправного деяния, по которому производство предварительного следствия обязательно.
2. О лицах, подготавливающих, совершающих или совершивших противоправное деяние, по которому производство предварительного следствия обязательно.
3. О событиях или действиях (бездействии), создающих угрозу государственной, военной, экономической или экологической безопасности Российской Федерации».

В исключительных случаях, которые не терпят отлагательства, эти мероприятия могут проводиться на основании мотивированного постановления одного из руководителей органа, осуществляющего оперативно-розыскную деятельность, с обязательным уведомлением суда, либо судьи, в течение 24 часов. Если в течение 18 часов с момента начала проведения оперативно-розыскного мероприятия судебное решение не получено, то проведение этого мероприятия должно быть прекращено.

С 2005 года после того как Российская Федерация ратифицировала Конвенцию Совета Европы «**О защите физических лиц при автоматизированной обработке персональных данных**», в России создаются условия для защиты прав граждан в этой сфере. В Федеральном законе от 27 июля 2006 г. № 152-ФЗ «**О персональных данных**» были регламентированы принципы обработки персональных данных:

1. законность целей и способов обработки персональных данных и добросовестность;
2. соответствие целей обработки персональных данных целям, заранее определенным и заявленным при сборе персональных данных, а также полномочиям оператора;
3. соответствие объема и характера обрабатываемых персональных данных, способов обработки персональных данных целям обработки персональных данных;
4. достоверность персональных данных, их достаточность для целей обработки, недопустимости обработки персональных данных, избыточных по отношению к целям, заявленным при сборе персональных данных;
5. недопустимость объединения созданных для несовместимых между собой целей баз данных информационных систем персональных данных.

Положения закона дополнительно уточняют постановления правительства № 781 от 17 ноября 2007 и № 687 от 15 сентября 2008, а также «Приказ трёх» (совместный приказ ФСТЭК (федеральная служба по техническому и экспертному контролю), ФСБ (федеральная служба безопасности), Мининформсвязи) N 55/86/20 от 13 февраля 2008 года.

Выдержки из некоторых нормативно-правовых актов, касающиеся защиты персональных данных:

- В пункте 1 статьи 19 Федерального закона «**О персональных данных**» говорится: «*Оператор при обработке персональных данных обязан принимать необходимые организационные и технические меры, в том числе использовать шифровальные (криптографические) средства, для защиты персональных данных от неправомерного или случайного доступа к ним, уничтожения, изменения, блокирования, копирования, распространения персональных данных, а также от иных неправомерных действий*».
- В пункте 2 Постановления правительства № 781 говорится: «*Безопасность персональных данных при их обработке в информационных системах обеспечивается с помощью системы защиты персональных данных, включающей организационные меры и средства защиты информации (в том числе шифровальные (криптографические) средства, средства предотвращения несанкционированного доступа, утечки информации по техническим каналам, программно-технических воздействий на технические средства обработки персональных данных)…*».

Нормативно-правовыми актами устанавливается необходимость защиты персональных данных на протяжении всего жизненного цикла: с момента создания до архивирования или утилизации. В частности говорится о необходимости защиты персональных данных от утечек по техническим каналам, несанкционированного доступа и с помощью шифрования. Следует заметить, что во многих информационных сетях персональные данные хранятся и используются совместно с другой конфиденциальной информацией. За несоблюдение закона

152-ФЗ предусматривается как административная, так и уголовная ответственность. Более того, в ряде случаев за нарушения закона «О персональных данных» у оператора персональных данных может быть отозвана лицензия на осуществление деятельности. Использование DLP-решений (Data Loss Prevention), основная задача которых обнаружить и заблокировать запрещенную передачу конфиденциальных данных, позволит привести систему управления информационной безопасностью организации в соответствие с законом 152-ФЗ «О персональных данных» и защитить персональные данные от утечек и несанкционированного доступа.

В декабре 2009 был принят Закон 363-ФЗ «**О внесении изменений в статьи 19 и 25 Федерального закона «О персональных данных»**». Практика реализации законодательства о персональных данных показала, что оно нуждается в существенной доработке. На это направлены усилия Министерства связи и массовых коммуникаций, Роскомнадзора, других заинтересованных министерств и ведомств. С одной стороны, необходимо обеспечить надежную защиту персональных данных граждан, с другой – уменьшить материальные затраты операторов персональных данных. Так как есть ряд организаций, где финансирование минимально – это школы, библиотеки, медицинские учреждения.

Еще одна проблема связана с увеличением количества разного рода ресурсов, информационных баз, в которых содержатся персональные данные граждан. Высок риск их недобросовестного и противоправного использования. Возникает задача – обеспечить надежную защиту информации о гражданах, размещенную в информационно-коммуникационных системах.

Наряду с этим существует большое число отраслевых стандартов для финансовых институтов, касающихся защиты информации от внутренних угроз и управления операционными рисками:

- **Стандарт Банка России СТО БР ИББС-1.0-2008**. Стандарт для российских банков, исполнение положений которого пока носит рекомендательный характер. В стандарте в частности затронута необходимость защиты от действий инсайдеров, в том числе необходимость контроля использования Интернета и корпоративной почты, а также ведения архива электронной почты.
- **Кодекс корпоративного поведения ФСФР (Федеральная служба по финансовым рынкам)**. Свод правил и рекомендации ФСФР России для компаний - участников рынков ценных бумаг России. Основная цель Кодекса — обеспечение равенства прав акционеров и защита их интересов, а одна из важнейших глав кодекса — контроль финансово-хозяйственной деятельностью общества. В Кодексе корпоративного поведения регламентируется создание прозрачной системы менеджмента и построение системы управления операционными рисками, а также необходимость создания условия для независимой оценки любой финансово-хозяйственной операции.

Архивирование информации (data retain) является распространенным требованием многих стандартов и законов, касающихся информационной безопасности. Сохранение переписки сотрудников, отправленных через Интернет данных, записанных на периферийные устройства файлов и копий, распечатанных

на принтерах документов, является важной задачей как с точки зрения внутреннего контроля и управления операционными рисками, так и как самостоятельная задача. Очевидно, что часто для различных целей требуется провести ретроспективный анализ использованной и перемещенной за пределы корпоративной сети информации.

Некоторые распространенные отраслевые стандарты и законы, в которых регламентируется архивирование данных:

- **Федеральный закон 125-ФЗ «Об архивном деле в Российской Федерации»** от 22.10 2004г**.** Этот закон регулирует отношения в сфере организации хранения, комплектования, учета и использования документов Архивного фонда Российской Федерации и других архивных документов независимо от их форм собственности.
- **Стандарт Банка России СТО БР ИББС-1.0-2008**.

В настоящее время становится очевидным, что меры по защите персональных данных не могут оставаться в границах одного государства и при этом быть эффективными. Поэтому нужна готовность к самому широкому взаимодействию с иностранными партнерами, в первую очередь по вопросам трансграничной передачи персональных данных. Совместная работа специалистов из разных стран – самый верный путь решения многих проблем в области защиты персональных данных.

1.2. Международные нормативно-правовые акты обеспечения ИБ

В международной практике обеспечения ИБ основными направлениями являются:

- нормирование компьютерной безопасности по критериям оценки защищенности надежных систем и информационных технологий;
- стандартизация процессов создания безопасных информационных систем.

В 1983 г. Агентством компьютерной безопасности Министерства обороны США был опубликован отчет, названный TCSEC (Критерии оценки защищенности надежных систем), или как назвали этот отчет по цвету обложки - «Оранжевая книга». В этом отчете были определены четыре уровня безопасности для оценки защиты данных с грифом в многопользовательских компьютерных системах: A1 — гарантированная защита; B1, B2, B3 — полное удовлетворение доступом; C7, C2 — избирательное управление доступом; D — минимальная безопасность. По мере перехода от уровня A к уровню D к надежности систем предъявляются более жесткие требования.

Национальный центр компьютерной безопасности МО США для оценки компьютерных систем Министерства обороны США выпустил инструкции NCSC-TG-005 и NCSC-TG -011, известные по цвету обложки как «Красная книга».

Агентство информационной безопасности ФРГ подготовило Green Book - «Зеленую книгу», в которой в комплексе рассмотрены требования к доступности, целостности и конфиденциальности информации, как в государственном,

так и в частном секторе. В 1990 г. «Зеленая книга» была одобрена ФРГ, Великобританией, Францией и Нидерландами и направлена в ЕС, где на ее основе были подготовлены ITSEC (Information Technology Security Evaluation Criteria, Критерии оценки защищенности информационных технологий), или «Белая книга» - европейский стандарт, определяющий критерии, требования и процедуры создания безопасных ИС, имеющий две схемы оценки: по эффективности (от E1 до E6) и функциональности (доступность, целостность системы, целостность данных, конфиденциальность информации и передачу данных).

В «Белой книге» названы основные компоненты безопасности по критериям ITSEC:

- информационная безопасность;
- безопасность системы;
- безопасность продукта;
- угроза безопасности;
- набор функций безопасности;
- гарантированность безопасности;
- общая оценка безопасности;
- классы безопасности.

При проверке эффективности анализируется соответствие между задачами безопасности по конфиденциальности, целостности, доступности информации и реализованным набором функций безопасности — их функциональной полнотой и согласованностью, простотой использования, а также возможными последствиями использования злоумышленниками слабых мест защиты. В понятие «эффективность» включается, и способность механизмов защиты противостоять прямым атакам. По ITSEC декларируется три степени мощности (базовая, средняя и высокая). При проверке корректности анализируется правильность и надежность реализации функций безопасности. По ITSEC декларируется семь уровней корректности — от E0 до E6.

Общая оценка безопасности системы по ITSEC состоит из двух компонент: оценки уровня гарантированной эффективности механизмов или средств безопасности и уровня их гарантированной корректности. Безопасность системы в целом оценивается отдельно для систем и продуктов. Защищенность их не может быть выше мощности самого слабого из критически важных средств защиты.

В «Европейских критериях» устанавливается 10 классов безопасности: F-C1, F-C2, F -B1, F -B2, F -B3, F -1N, F -AV, F -DI, F – DC, F - DX. Первые пять классов аналогичны классам C1, C2,B1, B2, B3 американских критериев TCSEC. Класс F -1N предназначен для систем с высокими потребностями к обеспечению целостности, что типично для СУБД, и различает следующие виды доступа: чтение, запись, добавление, удаление, создание, переименование и выделение объектов. Класс F - AV предназначен для систем с высокими требованиями к обеспечению их работоспособности за счет противодействия угрозам отказа в обслуживании (существенно для систем управления технологическими

процессами). Класс F -DI ориентирован на системы с повышенными требованиями к целостности данных, которые передаются по каналам связи. Класс F – DC характеризуется повышенными требованиями к конфиденциальности информации, а класс F - DX предназначен для систем с повышенными требованиями одновременно по классам F - DI и F - DX.

Канада разработала «Критерии безопасности компьютерных продуктов» (CTCPEC – Canadian Trusted Computer Product Evaluation Criteria). США разработали «Федеральные критерии безопасности информационных технологий» (Federal Criteria for Information Technology Security). Объединение этих критерии в новый набор критериев оценки защищенности привело к созданию «Общих критериев оценки безопасности информационных технологий» (Common Criteria for Information Technology Security Evaluation). Общие критерии адресованы трем группам специалистов (пользователям, разработчикам и экспертам по классификации КС) и представляют собой новый межгосударственный уровень в стандартизации безопасности информационных технологий.

В международном праве существует большое число законов, отраслевых стандартов для финансовых институтов, телекоммуникационных компаний, учреждений здравоохранения и обязательных и рекомендательных документов, затрагивающих защиту информации от внутренних угроз и управление операционными рисками:

- **PCI DSS**. Обязательный стандарт для операторов данных платежных карт систем VISA, MasterCard, American Express, JCB, Discover. Во-первых, в стандарте регламентируется необходимость шифрования носителей информации, содержащих данные платежных карт, и надежной защиты ключей шифрования. Также в PCI DSS определена необходимость генерации стойкого ключа и разделение криптографического ключа между несколькими лицами. Во-вторых, согласно стандарту операторы платежных карт должны защищать информацию от утечек по различным каналам, жестко регламентировав использование внешних устройств и перемещение конфиденциальных данных. В-третьих, в PCI DSS определена необходимость использования двухфакторной аутентификации для доступа к данным.
- **Basel II**. Довольно давно и успешно применяющийся в Евросоюзе, Северной Америке и Японии нормативный акт, регламентирующий банковскую деятельность. В частности в стандарте описана необходимость ведения архива конфиденциальной информации и создания системы управления операционными рисками.
- **SOX**. Sarbanes-Oxley Act of 2002 является обязательным для всех публичных компаний, акции которых котируются на фондовых биржах США. За несоблюдение закона топ - менеджеры компании несут персональную финансовую (штраф до 25 млн. долларов) и уголовную ответственность (до 20 лет лишения свободы). Секция 404 закона регламентирует необходимость внедрения системы внутреннего контроля для предотвращения и защиты информационных активов компании от утечек и несанкционированного использования.

- **SEC Rule 17a-4 и NASD 3010/3110**. Своды правил для компаний, акции которых котируются на биржах США. В правилах регламентируется создание архива электронной корреспонденции и переписки через службы мгновенных сообщений. Требования NASD 3010/3110 еще более жесткие — требуется архивировать не только корреспонденцию участников системы, но и все транзакции брокеров, трейдеров и лиц, действующих от их имени.
- **Combined code on corporate governance**. Кодекс корпоративного управления Великобритании пока не является обязательным для всех организаций, однако уже давно де-факто является стандартом для корпораций, чьи акции представлены на Лондонской фондовой бирже. Combined code регламентирует создание и поддержку системы внутреннего контроля и необходимость как минимум один раз в год проводить независимый аудит такой системы. Также в Кодексе говорится о необходимости постоянного мониторинга самой системы внутреннего контроля, а в случае возникновения какого-либо инцидента ИБ, высшее руководство компании должно быть немедленно информировано.
- **HIPAA**. Американский закон HIPAA затрагивает учреждения здравоохранения, страховые компании и посредников, хранящих, обрабатывающих и передающих конфиденциальные данные. Закон конкретизируют правила HIPAA, The Security Rule, в которых в частности регламентируется необходимость создания системы внутреннего контроля, написания правил использования рабочих компьютеров и внешних устройств и организации системы контроля доступа к информации.
- **GBLA & FACTA**. Защита непубличной информации клиентов финансовых корпораций регламентируется законами Gramm-Leach-Bliley Act of 1999 и Fair and Accurate Credit Transactions Act of 2003. Стандарт «Interagency Guidelines Establishing Information Security Standards» вносит дополнительные уточнения в приведенные законы и требует от финансовых институтов США защищать непубличные данные граждан в процессе хранения, использования, пересылки и утилизации от всех прогнозируемых рисков информационной безопасности, а также обеспечить надежный контроль доступа к этой информации.

Вопрос защиты персональных данных в международном праве решается уже довольно давно, первым законом стала европейская Конвенция «Convention for the Protection of Individuals with regard to Automatic Processing of Personal Data» («О защите личности в связи с автоматической обработкой персональных данных»), принятая 28 января 1981 года. На текущий момент подавляющее большинство развитых стран уже имеют соответствующие законы. Приведем некоторые законы о персональных данных других стан:

- Privacy Act of 1988, Австралия, 1988.
- EU Data Protection Directive (Directive 95/46/EC), Евросоюз, 1995.
- Data Protection Act, Великобритания, 1998.
- ORGANIC LAW on the Protection of Personal Data, Испания, 1999.
- Personal Information Protection and Electronic Data Act, Канада, 2000.

- Federal Data Protection Act of 2001, Германия, 2001.
- EU Internet Privacy Law of 2002 (Directive 2002/58/EC), Евросоюз, 2002.
- Data Protection Code of 2003, Италия, 2003.
- Personal Information Protection Law, Япония, 2003.

Если организация работает на международных рынках, при построении системы защиты информации необходимо учитывать требования этих законов и привести системы внутреннего контроля в полное соответствие приведенным законам для защиты персональных данных от случайных и преднамеренных утечек.

1.3. Правовая база лицензирования и сертификации в области защиты информации

Под ***лицензированием*** понимают юридически оформленный процесс получения некоторым субъектом права на осуществление определенного вида деятельности. В качестве субъекта может выступать физическое лицо, организация, предприятие, а также другие юридические лица.

Правовым документом в области лицензирования является Федеральный закон от 8 августа 2001г. РФ № 128-ФЗ «**О лицензировании отдельных видов деятельности**» и внесенными изменениями. В соответствии с данным законом Правительством РФ принято Постановление от 26 января 2006 №45 «**Об организации лицензирования отдельных видов деятельности**», в котором представлен «Перечень федеральных органов исполнительной власти, осуществляющих лицензирование». Согласно данному перечню компетенция федеральных органов исполнительной власти по ведению лицензионной деятельности в области защиты информации определяется следующим образом:

- ФСТЭК России.
    - Деятельность по технической защите конфиденциальной информации.
- ФСТЭК России. ФСБ России.
    - Деятельность по разработке и (или) производству средств защиты конфиденциальной информации
- ФСБ России.
    - Разработка, производство, реализация и приобретение в целях продажи специальных технических средств, предназначенных для негласного получения информации, индивидуальными предпринимателями и юридическими лицами, осуществляющими предпринимательскую деятельность.
    - Деятельность по выявлению электронных устройств, предназначенных для негласного получения информации, в помещениях и технических средствах (за исключением случая, если указанная деятельность осуществляется для обеспечения собственных нужд юридического лица или индивидуального предпринимателя).
    - Деятельность по распространению шифровальных (криптографических) средств.

  - Деятельность по техническому обслуживанию (криптографических) средств. Предоставление услуг в области шифрования информации.
  - Разработка, производство шифровальных (криптографических) средств, защищенных с использованием шифровальных (криптографических) средств информационных систем, телекоммуникационных систем.
- Федеральная служба по надзору в сфере связи, информационных технологий и массовых коммуникаций.
  - Деятельность по изготовлению аудиовизуальных произведений, программ для электронных вычислительных машин, баз данных и фонограмм на любых видах носителей (за исключением случаев, если указанная деятельность самостоятельно осуществляется лицами, обладающими правами на использование указанных объектов авторских прав и смежных прав в силу федерального закона или договора).

Сертификацией называют процесс установления соответствия некоторого товара, либо предоставляемых услуг, заданным требованиям. Сертификация производится третьей стороной, независимой от потребителя и производителя, в соответствии с юридически утвержденной процедурой.

Законом РФ от 7 февраля 1992 №2300-1 «**О защите прав потребителей**» в России введена обязательная сертификация ряда товаров (работ, услуг).

Одновременно с этим законом введена в действие система сертификации Госстандарта России, которая устанавливает порядок работ по обязательной сертификации. В приказе Госстандарта РФ от 30 декабря 1993 г. № 239 «Об утверждении «Порядка проведения Госстандартом России государственного контроля и надзора за соблюдением обязательных требований государственных стандартов, правил обязательной сертификации и за сертифицированной продукцией (работами, услугами)»» (с изменениями и дополнениями) определены права, обязанности и ответственность участников процесса сертификации.

Необходимость сертификации средств защиты, применяемых при обработке информации, составляющей государственную тайну, закреплена в Законе РФ «О государственной тайне». Согласно ст. 28 этого закона, организация сертификации средств защиты информации возлагается на ФСТЭК, ФСБ и Министерство обороны в пределах их компетенции. Координация работ по организации сертификации средств защиты информации возлагается на Межведомственную комиссию по защите государственной тайны.

Сертификация средств защиты информации, использующих шифрование, проводится в соответствии с Постановлением Правительства РФ от 26 июня 1995 г. № 608 «**О сертификации средств защиты информации**» (с изменениями от 23 апреля 1996 г., 29 марта 1999 г., 17 декабря 2004 г., 21 апреля 2010 г.). Согласно этому постановлению средства защиты информации, составляющей государственную тайну, подлежат обязательной сертификации в рамках конкретных систем сертификации. Положение о системе сертификации и перечень средств защиты информации, подлежащих сертификации в каждой системе, согласовываются с Межведомственной комиссией по защите государствен-

ной тайны. В этом документе устанавливаются правила сертификации по требованиям безопасности информации шифровальных средств и закрытых систем, и комплексов телекоммуникаций органов государственной власти, организаций, предприятий, банков и иных учреждений, расположенных на территории РФ, независимо от их ведомственной принадлежности и форм собственности.

Свои системы сертификации средств защиты информации имеют также СВР (служба внешней разведки), Министерство обороны и ФСБ России.

Одним из обязательных условий сертификации средств шифрования является использование криптографических алгоритмов, принятых в качестве государственного стандарта либо утвержденных Правительством РФ или ФСБ. Изделия, реализованные на базе собственных оригинальных алгоритмов, а также изделия, реализующие алгоритмы иностранной разработки, на сертификацию не принимаются. Однако не исключается сертификация импортных средств защиты со встроенными отечественными криптографическими алгоритмами.

В настоящее время имеется стандарт на электронную цифровую подпись ГОСТ Р 34.10-2001 (введен в действие с 1 июля 2002 года) и стандарт на хеш-функцию ГОСТ Р 34.11-94. Подавляющее большинство отечественных криптографических средств защиты реализуют именно эти алгоритмы.

Согласно Приказу ФСБ России от 16.03.2009 г. №106 - «административный регламент Федеральной службы безопасности Российской Федерации по исполнению государственной функции по лицензированию деятельности по распространению шифровальных (криптографических) средств (далее - Регламент) определяет сроки и последовательность действий (административных процедур) при исполнении государственной функции по лицензированию деятельности по распространению шифровальных (криптографических) средств…»

Обязательным условием сертификации является наличие у разработчика средства защиты соответствующих документов, подтверждающих наличие у руководителя (лица, уполномоченного руководить работами по осуществлению лицензируемой деятельности) и инженерно-технических работников высшего профессионального образования или прохождения ими переподготовки (повышение их квалификации) в области защиты информации с использованием криптографических методов и средств обеспечения информационной безопасности, а также необходимый стаж работы в области лицензируемой деятельности.

Возможна приостановка действия сертификата на средство защиты:

«63. Приостановление действия лицензии осуществляется лицензирующим органом в случае привлечения лицензиата к административной ответственности за нарушение лицензионных требований и условий в порядке, установленном Кодексом Российской Федерации об административных правонарушениях.

Частью 5 статьи 13.12 Кодекса Российской Федерации об административных правонарушениях установлено, что грубое нарушение условий, предусмотренных лицензией на осуществление деятельности в области защиты информации (за исключением информации, составляющей государственную тай-

ну), влечет наложение административного штрафа на лицензиата или административное приостановление деятельности на срок до 90 суток.

64. При выявлении у лицензиата в ходе проведения проверки грубых нарушений лицензионных требований и условий лицензирующий орган направляет соответствующие материалы в суд.

65. Грубыми нарушениями лицензионных требований и условий являются:

- отсутствие у лицензиата на праве собственности или на ином законном основании помещений, технологического, испытательного, контрольно-измерительного оборудования, иных объектов и сооружений, необходимых для осуществления лицензируемой деятельности;
- отсутствие в штате у лицензиата следующего квалифицированного персонала:
    - руководителя и (или) лица, уполномоченного руководить работами по лицензируемой деятельности, имеющих высшее профессиональное образование и (или) профессиональную подготовку в области информационной безопасности, а также стаж работы в этой области не менее 5 лет;
    - инженерно-технических работников, имеющих высшее профессиональное образование или прошедших переподготовку (повышение квалификации) в области информационной безопасности с получением специализации, необходимой для работы с шифровальными (криптографическими) средствами;
- использование лицензиатом программ для электронно-вычислительных машин и баз данных без договора, заключенного с правообладателем в установленном порядке;
- одновременное нарушение двух и более условий, указанных в пункте 58 Регламента.

66. В случае вынесения судьей решения об административном приостановлении деятельности лицензиата за нарушение лицензионных требований и условий лицензирующий орган в течение суток со дня вступления данного решения в законную силу приостанавливает действие лицензии на срок административного приостановления деятельности лицензиата, что оформляется приказом лицензирующего органа, и направляет лицензиату в письменной форме уведомление о приостановлении действия лицензии.

67. Лицензиат обязан уведомить в письменной форме лицензирующий орган об устранении им нарушения лицензионных требований и условий, повлекшего за собой административное приостановление деятельности лицензиата.

Лицензирующий орган проводит проверку устранения лицензиатом нарушения, повлекшего за собой административное приостановление деятельности лицензиата».

Близким к понятию сертификации является понятие ***аттестации***. Отличие процесса аттестации технического средства от его сертификации состоит в том, что аттестации подвергается конкретный образец, предназначенный для эксплуатации в определенном помещении и в заданных условиях, и при этом

оценивается совокупность всех средств защиты информации, включая не только технические, но и организационные меры защиты. Объектом аттестации может быть не только отдельное техническое средство, но и совокупность помещений с расположенными в них техническими средствами, которые обслуживаются данным персоналом в соответствии с определенной нормативно-технической документацией. Таким объектом может являться, например, помещение, предназначенное для ведения конфиденциальных переговоров.

Целью процесса аттестации является подтверждение возможности обработки информации с ограниченным доступом определенной категории на рассматриваемом объекте. Категория обрабатываемой информации определяется собственником (владельцем, пользователем информации) в соответствии с действующим законодательством.

В 1994 году Председателем Гостехкомиссии России утверждено «Положение по аттестации объектов информатизации по требованиям безопасности информации», устанавливающее основные принципы, организационную структуру системы аттестации объектов информатизации по требованиям безопасности информации, порядок проведения аттестации, а также контроля и надзора за аттестацией и эксплуатацией аттестованных объектов информатизации.

В результате повышенного внимания к вопросам информационной безопасности растет потребность компаний в квалифицированных кадрах. Одним из критериев оценки квалификации специалиста является наличие у него того или иного сертификата.

На сегодняшний день существует две различных схемы сертификации специалистов в области безопасности, аналогичные схемам обучения. Первая схема охватывает различные аспекты той или иной технологии информационной безопасности. К такой схеме сертификации относится Certified Information System Security Professional (CISSP) или Certified Information System Auditor (CISA). Не менее известной является сдача экзаменов на получение статуса Certified Information Systems Auditor (CISA) в Information Systems Audit and Control Association (ISACA). Специалист, сертифицирующийся по второй схеме, зависит от конкретного продукта или решения, предложенного конкретной компанией. По такой схеме работают компании Cisco, Microsoft и другие. Существуют и смешанные системы сертификации.

- **CISSP** Программа CISSP была разработана международным консорциумом по сертификации в области безопасности информационных систем (International Information Security Systems Certification Consortium, ISC2). Для получения данного статуса необходимо сдать экзамен, возможность сдать который имеет только тот, кто обладает не менее 3-хлетним опытом работы в этой области (эта информация проверяется при регистрации на экзамен). Это стандартное требования для всех значимых сертификаций, которое позволяет отсечь новичков. Все экзаменационные вопросы выбираются из обширной базы, которая ежегодно пополняется новыми. Текущий экзамен (сдается на английском языке) постоянно актуализируется и всегда базируется на современных технологиях и последних достижениях

в рассматриваемых областях. В отличие от других систем сертификации в области информационной безопасности, он не привязан ни к какому конкретному производителю, что позволяет говорить о его независимости. Экзамен на получение сертификата CISSP длится 6 часов и состоит из 250 вопросов, сгруппированных в 10 тем (т.н. доменов):

- разграничение доступа (модели разграничения доступа, технологии идентификации и аутентификации, методы атак и т.п.);
- сетевая безопасность (сетевые технологии, VPN, межсетевые экраны, методы атак и т.п.);
- процедуры управления безопасностью (классификация данных, политика безопасности, стандарты, анализ рисков, обучение персонала);
- разработка безопасных приложений (вредоносный код, разработка ПО);
- криптография (криптографические протоколы шифрования, функции хэширования, PKI, методы атак);
- архитектура безопасности (модели безопасности и ее оценки, Общие критерии и т.д.);
- эксплуатация инфраструктуры безопасности (поддержка средств защиты, управление персоналом и т.п.);
- непрерывность бизнеса (оценка ущерба, восстановление работоспособности);
- законодательство (законы, расследование инцидентов);
- физическая безопасность (видеонаблюдение, охранная сигнализация, пожарная охрана, обнаружение физического вторжения).

Сдавший экзамен получает сертификат, однако свой статус необходимо подтверждать каждые 3 года. Это можно сделать двумя способами: повторной сдачей экзамена или «добычей» 120 так называемых кредитов, которые «зарабатываются» написанием профильных статей, выступлениями на тематических конференциях, посещением семинаров, обучением, чтением книг по информационной безопасности и т.п.

Аналогичная схема действует и для многих других сертификаций по информационной безопасности и она оправдана - технологии и ситуация на рынке меняется очень быстро. А значит «почивать на лаврах» не придется - необходимо заниматься самообразованием и быть всегда в курсе последних новинок в данной области.

- **SSCP** Статус Systems Security Certified Practitioner (SSCP) был разработан консорциумом ISC2 для тех, кто пока не может сдать экзамен на статус CISSP или только готовится к нему, а также для тех, кто не стремится на руководящие позиции и ему не требуется более высокий статус от ISC2. Учитывая одного прародителя, сертификация SSCP очень похожа на CISSP за небольшим исключением. Во-первых, вместо 10-ти доменов экзаменуемые проверяются всего по 7-ми: разграничение доступа (модели разграничения доступа, технологии идентификации и аутентификации, методы атак и т.п.), безопасность данных, администрирование безопасности, криптография, аудит и мониторинг, вредоносное ПО, управление рисками, реаги-

рование и восстановление. Во-вторых, число вопросов сокращено до 125, также вдвое сокращено и время на экзамен - до 3 часов. Для сдачи данного экзамена необходим опыт работы в течение 1-го года по специальности (вместо трех).

В обоих случаях (CISSP и SSCP) получению статуса предшествует подписание этического кодекса поведения (Code of Ethics), который описывает, как себя должен вести обладатель престижного сертификата. Такое требование является обязательным при получении многих сертификатов, например, CISA.

- **CISA.** В 1969 году была основана Ассоциация аудита и контроля информационных систем (Information Systems Audit and Control Association, ISACA). Сегодня она является признанным лидером в управлении, контроле и поддержке информационных систем, продвижении открытого стандарта CobiT и ратует за стандартизацию в области ИТ. Основная цель ассоциации - исследование, разработка, публикация и продвижение стандартизованного набора документов по управлению информационной технологией для ежедневного использования администраторами и аудиторами информационных систем. Для того, чтобы контролировать соблюдение требований стандартов по управлению ИТ инфраструктурой, ISACA (http://www.isaca.org/) предложила в 1978 году программу подготовки и сертификации аудиторов информационных систем (Certified Information Systems Auditor, CISA). Сегодня это самая известная программа подготовки внешних аудиторов. В настоящее время статусом CISA обладают около 48000 аудиторов по всему миру. Экзамен на получение данного статуса очень похож на CISSP - содержит 200 вопросов и занимает 4 часа. Различие состоит в темах, которые рассматривают в рамках курса подготовки и на экзамене. В данном случае внимание уделяется процессу аудита информационной системы (10% всех вопросов), управлению ИТ инфраструктурой (15% вопросов), управлению жизненным циклом системам и инфраструктурой (16%), доставке и поддержке ИТ - сервисов (14%), защита информационных активов (31%) и непрерывности и восстановлению бизнеса (14%). Для получения сертификации необходимо подписать соответствующий этический кодекс и обладать пятилетним опытом работы в области аудита, управления или безопасности. Требование 5-ти лет может быть снято, если кандидат обладает опытом проведения финансового аудита, 2 года был инструктором или имеет степень в университете, аккредитованном ISACA. Каждые 3 года статус CISA должен быть подтвержден.
- **CISM** Сертификат Certified Information Security Manager (CISM) был разработан ассоциацией ISACA, которая к тому моменту уже имела другую сертификацию - CISA. На сайте ISACA приводится следующая причина появления статуса CISM: «сертификат CISSP является стандартом де-факто в области информационной безопасности, но за его долгую историю выявились определенные недоработки данной квалификационной схемы. Поэтому появился статус CISM, который позволяет увязать информационную безопасность со стратегией развития бизнеса компании». Чтобы полу-

чить статус CISM необходимо трудиться по части информационной безопасности не менее 5 лет и 3 из них в области управления.

- **GIAc** Институт SANS (System Administration, Networking and Security Institute) считается одним из признанных авторитетов в области безопасности. Помимо различных курсов, тренингов, публикаций и исследований, при SANS создан специальный центр анализа инцидентов (Global Incident Analysis Center, GIAc), который наряду с другой своей деятельностью предлагает и сертификацию технических специалистов по безопасности. Здесь предлагают 3 уровня подтверждения своей квалификации - GSEc (базовый уровень), GCFW/GCIA/GCIH/GCNT/GCUX и GSE. GIAc выделил несколько направлений развития своих выпускников. Это межсетевые экраны, защита периметра и VPN- GIAc Certified Firewall Analyst - статус необходимо подтверждать каждые 4 года. Обнаружение атак - GIAc Certified Intrusion Analyst - статус необходимо подтверждать каждые 4 года. Управление инцидентами - GIAc Certified Incident Handling - статус необходимо подтверждать каждые 2 года. Уменьшение времени на ресертификацию связано с быстрым изменением ситуации на рынке «хакерских технологий» и необходимость соответствовать всем современным тенденциям. Безопасность Windows - GIAc Certified Windows Security - данный статус необходимо подтверждать каждые 2 года. Безопасность Unix - GIAc Certified Unix Security - данный статус необходимо подтверждать каждые 2 года.
- **GSE** Для получения высокой ступени GIAc в области информационной безопасности - GSE (GIAc Security Engineer), необходимо получить базовый статус GSEc и к нему еще все пять вышеперечисленных сертификаций - GCFW, GCIA, GCIH, GCNT и GCUX. Данная сертификация практически неизвестна в России, но на Западе она имеет такой, же статус для технических специалистов, что и CISSP для руководителей служб информационной безопасности. Трехуровневая схема позволяет постепенно наращивать потенциал как в знаниях и практике, так и в статусе.

Необходимость сертификации специалиста зависит от того, в какой фирме и по какому профилю он трудится или намерен трудиться. Например, в российской фирме разработчику средств защиты не потребуется ни один из перечисленных выше сертификатов. Однако если ваша цель - компании большой четверки, то без CISA (а для Ernst&Young еще и CISSP) вам не обойтись. Если вы стремитесь управлять процессами информационной безопасности у своего работодателя, то вам понадобится CISSP или CISM. Если вы просто хотите быть хорошим администратором безопасности или входить в группу реагирования на инциденты, то лучше сконцентрироваться на получении «вендорских» сертификатов, SSCP или GIAc. Юристу, занимающемуся расследованиями компьютерных преступлений, понадобятся сертификаты: CCCI (Certified Computer Crime Investigator), CCFT (Certified Computer Forensic Technician), CCCP (Certified Computer Crime Prosecutor) или CCCA (Certified Computer Crime Attorney).

И хотя эти сертификаты не являются общепризнанными и вряд ли знакомы большинству HR-менеджеров, но подготовка к их получению даст полезные и нужные знания.

1.4. Преступления в сфере компьютерной информации и вопросы защиты авторских прав

Преступлениям в сфере компьютерной информации в Уголовном Кодексе РФ посвящена отдельная глава. Действиям, относящимся к преступлениям в этой сфере, часто сопутствует совершение преступлений против личности, общественной безопасности и общественного порядка, в сфере экономики и др. Наличие статей о преступлениях в сфере компьютерной информации позволяет во многих случаях наказать лиц, совершивших и другие преступления, вину, которых доказать по этим преступлениям не удалось.

Ярким примером этому может служить уголовное дело жителя Петербурга Владимира Левина, 1967 года рождения, русского, микробиолога по образованию, холостого, ранее не судимого. Расследование этого дела осуществлялось отечественными правоохранительными органами в тесном контакте с правоохранительными органами США. Данное уголовное дело было возбуждено в отношении Левина и других граждан Российской Федерации, которые вступили в сговор с целью хищения денежных средств в крупных размерах, принадлежащих City Bank of America, расположенному в Нью-Йорке (США).

В Санкт-Петербурге была образована преступная группа, которая с 30 июня по 3 октября 1994 года с помощью персонального компьютера стандартной конфигурации, созданного в офисе АОЗТ «Сатурн», подключившись через Интернет, преодолев при этом несколько рубежей многоконтурной защиты от несанкционированного доступа (НСД), вводила в систему управления наличными фондами указанного банка ложные сведения. В результате преступниками было осуществлено не менее 40 переводов денежных средств на общую сумму 10 миллионов 700 тысяч 952 доллара США со счетов клиентов названного банка на счета лиц, входящих в состав преступной группы, проживавших в шести странах: США, Великобритании, Израиле, Швейцарии, ФРГ, России.

В результате проведения первой операции было похищено 400 тысяч долларов США, которые поступили на счет Королькова, контролировавшего деятельность двух коммерческих компаний в штате Калифорния (США) и являвшегося другом детства Левина.

Отсутствие в то время в УК РФ составов преступлений в сфере компьютерной информации затрудняло привлечение Левина и его сообщников к ответственности на территории России (поэтому его, в свое время, выманили в Англию, там арестовали, а затем передали в США, где он и был осужден). В принципе, подобных преступников можно преследовать за кражу, по обычным уголовным статьям. Часто доказать корыстный умысел, как правило, труднее, чем, например, факт неправомерного доступа к информации.

Преступления, не относящиеся к преступлениям в сфере компьютерной информации, могут совершаться с использованием компьютерной техники. Это

может быть размещение на сайте в Интернет заведомо ложных сведений, порочащих честь и достоинство другого лица, или отправка угроз по электронной почте. Такие действия не имеют признаков преступления в сфере компьютерной информации, но особенности совершения и расследования таких преступлений имеют много общего с компьютерными преступлениями типа неправомерного доступа к компьютерной информации или распространением «вредоносных программ».

Прежде, чем перейти к анализу статей УК РФ о преступлениях и сфере компьютерной информации, предварительно рассмотрим некоторые юридические термины, которые будем использовать в дальнейшем. Основное понятие - «преступление», которое дано в ст. 14 УК РФ:

1. Преступлением признается виновно совершенное общественно опасное деяние, запрещенное настоящим Кодексом под угрозой наказания.
2. Не является преступлением действие (бездействие), хотя формально содержащее признаки какого-либо деяния, предусмотренного настоящим Кодексом, но в силу малозначительности не представляющее общественной опасности.

Согласно ст. 28 УК РФ. «Деяние признается совершенным невиновно, если лицо, его совершившее, не осознавало и по обстоятельствам дела не могло осознавать общественной опасности своих действий (бездействия)...».

Кроме того, в ряде разбираемых статей УК присутствуют такие оценочные признаки преступных действий, как «существенный вред», «значительный вред» и «тяжкие последствия». Эти признаки зависят от многих показателей и определяются следователем и судом в каждом конкретном случае отдельно. К тяжким последствиям могут быть отнесены гибель людей, серьезные аварии на производстве и т.н. Существенный вред (значительный вред) включает и менее серьезные последствия, сводящиеся, например, к финансовому или моральному ущербу.

Развитие и совершенствование информационных технологий, увеличение производства технических средств и расширение сферы применения компьютерной техники, доступность подобных устройств, а главное - наличие человеческого фактора в виде удовлетворения собственных амбиций или жажды наживы породили новый вид общественно опасных деяний, в которых неправомерно используется компьютерная информация либо она сама становится объектом посягательства.

Средства компьютерной техники, в частности, компьютерная система, иногда используются преступником и как инструмент посягательства на другие объекты, например, как средство воздействия с различными целями на администрацию.

Например, в порядке выполнения своих служебных обязанностей, программист предприятия электрических и тепловых сетей (ПЭТС) И.А. Сиротин города Касимова создал программу, позволявшую выполнять начисление расчетов за тепловую энергию по частному сектору. Через некоторое время был Сиротин уволен с занимаемой должности. 26 февраля 1999 года контролер

ПЭТС Маломужева, обязанностью которой был ввод в компьютер квитанций и начисление расчетов, придя на работу, попыталась запустить данную программу, и произвела операции строго по инструкции, разработанной Сиротиным. При попытке выполнения пунктов меню, относящихся к генерации отчетов и закрытию месяца, на экране компьютера появлялась рамка, внутри которой имелась надпись, что по вопросам эксплуатации программы следует обращаться к Сиротину И.А. по указанному адресу и телефону. Программист Сиротин пояснил, что созданная им программа принадлежит ему и согласился ее вернуть за 17-20 тысяч рублей.

По данному факту было возбуждено уголовное дело по ч.1 ст. 273 УК России. Так как, согласно ГК РФ часть 4 от 18.12.2006 № 230-ФЗ (Раздел VII Права на результаты интеллектуальной деятельности и средства индивидуализации) имущественные права на программы для ЭВМ или базы данных, созданные в порядке выполнения служебных обязанностей или по заданию работодателя, принадлежат работодателю.

Несмотря на многообразие компьютерных преступлений, практически все способы их совершения имеют свои индивидуальные, присущие только им признаки, по которым их можно распознать и классифицировать по отдельным общим группам:

1. **Изъятие средств компьютерной техники.**
2. **Неправомерный доступ к компьютерной информации**:

- Преступления, совершаемые в отношении компьютерной информации, находящейся в глобальных компьютерных сетях или при обращении к ним.
- Преступления, совершаемые в отношении компьютерной информации, находящейся в ЭВМ, не являющихся компьютером в классическом понимании этого слова (таких, как пейджер, сотовый телефон, кассовый аппарат и т.п.).

3. **Изготовление или распространение вредоносных программ (вирусы, программы - взломщики и т.п.)**.
4. **Перехват информации.**
5. **Нарушение авторских прав (компьютерное пиратство).**

Рассмотрим каждую из групп более подробно.

К первой группе «Изъятие средств компьютерной техники или нарушение правил эксплуатации ЭВМ» относятся традиционные способы совершения обычных видов преступлений, в которых действия преступника направлены на изъятие чужого имущества.

К примеру, в Новосибирске гражданин Смирнов, взломав ножом входную дверь офиса ТОО «Садко», похитил персональный компьютер с периферийным оборудованием и уничтожил имеющуюся на диске программу бухгалтерского учета ТОО, причинив ущерб на общую сумму 17 миллионов 220 тысяч рублей.

Нарушение правил эксплуатации ЭВМ попадает под действие ст. 274 УК РФ.

Ст. 274. Нарушение правил эксплуатации ЭВМ, системы ЭВМ или их сети

1. Нарушение правил эксплуатации ЭВМ, системы ЭВМ или их сети лицом, имеющим доступ к ЭВМ, системе ЭВМ или их сети, повлекшее уничтожение, блокирование или модификацию охраняемой законом информации ЭВМ, если это деяние причинило значительный вред, — наказывается лишением права занимать определенные должности или заниматься определенной деятельностью на срок до пяти лет, либо обязательными работами на срок от ста восьмидесяти до двухсот сорока часов, либо ограничением свободы на срок до двух лет.
2. То же деяние, повлекшее по неосторожности тяжкие последствия, — наказываются лишением свободы на срок до четырех лет.

В этой статье под правилами эксплуатации ЭВМ могут пониматься не только инструкции, разработанные владельцем информационных ресурсов и информационной системы, но и правила эксплуатации ЭВМ, машинных носителей информации и периферийных устройств, разработанные изготовителем. Инструкции и правила эксплуатации могут быть установлены в форме положений, приказов, контракта, договора, а также содержаться в документации на соответствующие устройства. Внутренние инструкции ведомств, учреждений и организаций должны быть утверждены лицом, имеющим соответствующие полномочия, и не могут распространяться на ЭВМ и сети ЭВМ других организаций.

Заметим, что нарушение правил может выражаться как в действии, так и в бездействии. Если администратор системы не выполнил своевременно резервное копирование, и это стало причиной невозможности восстановить ценную информацию, то он может быть признан виновным по этой статье.

Любопытно, что в тексте статьи не упоминается несанкционированное копирование, которое так же, как и модификация, уничтожение или блокирование охраняемой законом информации, может принести значительный вред.

Ясно, что если лицо, имеющее доступ к ЭВМ, преднамеренно создает условия для совершения преступлений, предусмотренных другими статьями УК, то его действия могут быть дополнительно квалифицированы как соучастие в совершении этих преступлений.

Вторая группа «Неправомерный доступ к компьютерной информации» является наиболее распространенной. Эта группа преступлений попадает под действие ст. 272 УК РФ.

Ст. 272. Неправомерный доступ к компьютерной информации

1. Неправомерный доступ к охраняемой законом компьютерной информации, то есть информации на машинном носителе, в электронно-вычислительной машине (ЭВМ), системе ЭВМ или их сети, если это деяние повлекло уничтожение, блокирование, модификацию, либо копирование информации, нарушение работы ЭВМ, системы ЭВМ или их сети, -

   наказывается штрафом в размере до двухсот тысяч рублей или в размере заработной платы или иного дохода осужденного за период до восемнадцати

месяцев, либо обязательными работами на срок от ста двадцати до ста восьмидесяти часов, либо исправительными работами на срок до одного года, либо лишением свободы на срок до двух лет.

2. То же деяние, совершенное группой лиц по предварительному сговору или организованной группой либо лицом с использованием своего служебного положения, а равно имеющим доступ к ЭВМ, системе ЭВМ или их сети, - наказывается штрафом в размере от ста тысяч до трехсот тысяч рублей или в размере заработной платы или иного дохода осужденного за период от одного года до двух лет, либо обязательными работами на срок от ста восьмидесяти до двухсот сорока часов, либо исправительными работами на срок до двух лет, либо арестом на срок от трех до шести месяцев, либо лишением свободы на срок до пяти лет.

Обратим внимание на то, что в данной статье речь идет о несанкционированном доступе к компьютерной информации, а не ЭВМ или КС. Таким образом, доступ к ЭВМ с целью незаконного использования ее ресурсов не является составом преступления этой статьи.

С первого взгляда кажется, что ознакомление с конфиденциальной компьютерной информацией без последующей фиксации этой информации в той или иной форме также не является составом преступления данной статьи. Но, с точки зрения технического специалиста противоречия нет. Так, как любое представление информации в осознаваемой человеком форме в обязательном порядке повлечет копирование информации внутри ЭВМ. При выводе информации на экран монитора произойдет копирование ее в память видеокарты, при выводе звука информация будет скопирована в память звуковой карты. Таким образом, ознакомление с компьютерной информацией, в результате неправомерного доступа, автоматически сопровождается ее копированием. И, соответственно, является составом преступления данной статьи.

Для того чтобы владелец информации мог рассчитывать на возможность применения данной статьи для защиты своих прав, ему следует принять меры для ограничения доступа к защищаемой информации. Иначе не всегда можно будет доказать неправомерность доступа к этой информации. В данном случае можно провести аналогию с тем, что, согласно ст. 139 Гражданского кодекса, информация может составлять служебную или коммерческую тайну, если обладатель информации принимает меры к охране ее конфиденциальности. Для защиты информации могут использоваться как технические, так и организационные меры защиты, последние должны включать доведение правил обращения с охраняемой информацией до лиц, имеющих потенциальную возможность осуществления доступа к ней.

Открытым остается вопрос о том, предполагает ли неправомерный доступ к компьютерной информации использование штатных средств ЭВМ или возможно использование других способов осуществления доступа. Например, с помощью источников электромагнитного излучения, физического воздействия и т. п. Так, считывание остаточных магнитных полей на магнитном диске после стирания информации или подделку записи на магнитной карте с помощью са-

модельного устройства можно рассматривать как неправомерный доступ к компьютерной информации.

Наиболее ярким компьютерным преступлением по этой группе может служить описанное дело Левина или расследуемое ГУВД г. Москвы дело Гофмана, который в квартире по месту жительства, используя персональный компьютер, подключился к сети Интернет и обнаружил программу PC Authorise. Данная программа отвечает за прием к оплате кредитных карточек с переводом денежных средств на счета магазинов, а также за возврат денежных средств со счетов магазинов на счета кредитных карточек. Переписав указанную программу, Гофман распорядился об открытии членам своей группы счетов в коммерческих банках Москвы, а также о получении кредитных карточек, при помощи которых имелась бы возможность работать с денежными средствами, размещенными на данных счетах. Вышеперечисленные счета были открыты с целью аккумулирования похищенных денежных средств и их последующего обналичивания.

Создав, таким образом, условия для совершения хищений и получив возможность работать со средствами, размещенными на специально приспособленных счетах, посредством своего персонального компьютера Гофман выступал от имени продавца компьютерного магазина «Virtualynx Internet LLC 811-555 West Hastings St. Vancouver, BC V6B 4N5 604-893-7022». Сделав от чужого имени заказ на покупку товаров, Гофман оплачивал его, не принадлежащими ему денежными средствами со счетов, размещенных на пластиковых карточках. Затем делал отказ от покупки товара, зачисляя возвращаемые деньги на вышеуказанные счета своих сообщников. После зачисления деньги делились между соучастниками.

Примером преступления, совершенного в отношении компьютерной информации, находящейся в ЭВМ, не являющихся компьютером, в классическом понимании этого слова, может служить уголовное дело, возбужденное по факту неправомерного доступа к охраняемой законом компьютерной информации компании сотовой телефонной связи «ВОТЕК МОБАЙЛ», повлекшее ее копирование.

В соответствии с преступным планом, на Макеева возлагалась обязанность на совместные деньги приобрести в Москве несколько сотовых телефонных аппаратов фирмы «МОТОРОЛА» и несколько микропроцессоров со специальной программой. Данные микропроцессоры при техническом монтаже в данные телефонные аппараты давали возможность этим аппаратам работать в режиме автосканирования на частоте сотовой телефонной связи компании «ВОТЕК МОБАЙЛ». Одновременно Макеев должен был переоборудовать приобретенные им сотовые телефонные аппараты фирмы «МОТОРОЛА» и разработать три подробные инструкции по использованию данных аппаратов.

Лопатин, в соответствии с разработанной Макеевым инструкцией, на территории Воронежа должен был неправомерным доступом войти в компьютерную сеть компании «ВОТЕК МОБАЙЛ" и скопировать в память переоборудо-

ванных телефонных аппаратов несколько личных и абонентских номеров пользователей.

Помимо этого, Лопатин должен был внести скопированные им номера в электронные записные книжки переоборудованных аппаратов. Далее продать незаконно приготовленные к работе на частоте компании «ВОТЕК МОБАЙЛ» сотовые телефонные аппараты «МОТОРОЛА» с инструкцией по правильному извлечению из электронной записной книжки номеров пользователей для переговоров, а полученные от продажи третьим лицам деньги поделить с Макеевым.

Практика расследования преступлений, предусмотренных гл. 28 УК Российской Федерации, показала, что диспозиции статьи 272 могут быть успешно применены и к контрольно-кассовым аппаратам. Преступные манипуляции с данными контрольно-кассовых аппаратов рассчитаны в первую очередь на сокрытие доходов и уклонение от уплаты налогов, что в условиях проблем с пополнением доходной части бюджета имеет особую актуальность.

В ноябре 1998 года Следственным управлением ГУВД Московской области было возбуждено уголовное дело по факту совершения неправомерного доступа к охраняемой законом компьютерной информации в кассовых аппаратах частного предприятия «4001» г Павловский Посад. С июля по ноябрь 1998 года руководитель ЧП «4001» г Павловский Посад Московской области Турунин договорился с Курдиной сокрыть часть доходов от налогообложения. Для этого ежедневно, с 17 до 19 часов, в торговых палатках ЧП 4001» в гнезда двух контрольно-кассовых аппаратов АМС 100-Ф, являющихся разновидностью ЭВМ, подключали специально изготовленный самодельный прибор в виде микрокомпьютера. В результате этого осуществлялся доступ к компьютерной информации о проведенных через контрольно - кассовые аппараты финансовых операциях в течение текущей смены.

После подключения прибора к контрольно-кассовым аппаратам в буферной памяти контрольно-кассовых аппаратов уничтожалась вся информация о предшествующих финансовых операциях, в том числе информация о номере покупки и общей сумме выручки за текущую смену. После проведения подобной манипуляции обе торговые точки ЧП «4001» продолжали свою работу, накапливая информацию в буферной памяти о производимых финансовых операциях до 21 часа, после чего в фискальную память контрольно-кассовых аппаратов заносились заниженные данные о сумме выручки за смену.

Турунину и Курдиной предъявлено обвинение в совершении преступления, предусмотренного ч. 2 ст. 272 УК Российской Федерации.

Приведенные примеры относятся к «виртуальному» проникновению, однако в случае отсутствия на интересующем компьютере средств связи с внешним миром (или процесс доступа затруднен) остается непосредственный доступ.

В качестве иллюстрации рассмотрим один из вариантов осуществления доступа к информации, хранящейся на жестком диске.

Наиболее распространенным способом защиты компьютерной информации остается «пароль», а самой распространенной программой «паролирования» остается BIOS. По сложившемуся мнению установка подобного пароля полностью закрывает доступ к компьютеру. Однако для грамотного пользователя получение доступа к компьютеру не представляет трудностей. Дело в том, что каждая фирма-разработчик BIOSa предусматривает наличие универсального пароля для определенной версии своего продукта. Список паролей находится на Web-серверах соответствующих фирм, и его получение является лишь делом техники. Зная подобный универсальный ключ, можно беспрепятственно войти в компьютер, при этом законный владелец не сможет обнаружить факт вторжения, так как его личный пароль продолжает действовать.

Третья группа – «Изготовление или распространение вредоносных программ (вирусы, программы - взломщики и т.п.)» Эта группа преступлений попадает под действие ст. 273УК РФ.

Ст. 273. Создание, использование и распространение вредоносных программ для ЭВМ

1. Создание программ для ЭВМ или внесение изменений в существующие программы, заведомо приводящих к несанкционированному уничтожению, блокированию, модификации либо копированию информации, нарушению работы ЭВМ, системы ЭВМ или их сети, а равно использование либо распространение таких программ или машинных носителей с такими программами —

   наказывается лишением свободы на срок до трех лет со штрафом в размере от двухсот до пятисот минимальных размеров оплаты труда или в размере заработной платы или иного дохода осужденного за период от двух до пяти месяцев.
2. Те же деяния, повлекшие по неосторожности тяжкие последствия, — наказываются лишением свободы на срок от трех до семи лет.

В данной статье не различаются умышленное и неумышленное распространение вредоносных программ. Для квалификации действий как использование вредоносных программ либо распространение таких программ (по части первой данной статьи), необходимо доказать, что лицо, совершающее такие действия, знало о вредоносности этих программ или, могло предполагать это в силу своей квалификации и обстоятельств получения программы. С другой стороны, действия лица, способствовавшего распространению вредоносных программ, могут быть квалифицированы как совершение преступления по неосторожности. Например, если записанная на компьютер игровая программа оказалась заражена, вирусом и это привело к тяжким последствиям. Если при этом были нарушены какие-либо инструкции по борьбе с распространением компьютерных вирусов, то соответствующие действия могут быть квалифицированы по ч. 2 ст. 274 УК.

Обратим внимание на возможность санкционированных действий по созданию и использованию вредоносных программ, например, в научно-исследовательских целях, или для проведения оперативно-розыскных меро-

приятий. Многие программы, необходимые для проведения специальных экспертиз при расследовании преступлений в сфере компьютерной информации, согласно рассматриваемой статье, являются вредоносными. Следует принять соответствующие законодательные акты, регулирующие разработку и использование вредоносных программ, аналогично тому, как регулируется производство и применение лекарств. В настоящее время можно считать, что работать с вредоносными программами имеют право субъекты, уполномоченные на ведение оперативно-розыскной деятельности, а также учреждения и организации, имеющие лицензии на некоторые виды деятельности в области защиты информации. Сюда, же можно отнести организации, зарегистрированная деятельность которых предполагает работу с вредоносными программами (например, разработка антивирусных средств защиты).

Естественен вопрос: являются ли «безвредные» вирусы вредоносными программами? Ответ утвердительный: Да, являются, так как свойственная вирусам способность к несанкционированному распространению подразумевает несанкционированное изменение других программ. При этом в результате ошибки разработчика вместо безвредного вируса может получиться очень вредный. Так и произошло с Моррисом-младшим, первым широко известным создателем сетевого вируса. Написанная для забавы в 1975 году его программа, из-за допущенной ошибки нарушила работу тысяч компьютеров.

Ярким примером преступлений третьей группы является уголовное дело, возбужденное ГУВД Свердловской области по факту распространения Флягиным программ для ЭВМ, заведомо приводящих к несанкционированному уничтожению, блокированию информации и нарушению работы ЭВМ. Флягин использовал свой домашний персональный компьютер «Packard Bell» 486-СХ-33, модем «US-Robotics» и телефон, зарегистрированный на Екатеринбургской ПС. Им была установлена специализированная компьютерная программа «Maxi'mus 3.00». Используя (BBS -Bulletin Board Sistem - электронную доску объявлений), обеспечивающую работу компьютера с удаленными пользователями через телефонную сеть, Флягин распространял программы для ЭВМ, заведомо приводящие к несанкционированному уничтожению, блокированию, модификации либо копированию информации, нарушению работы ЭВМ, системы ЭВМ или их сети.

Сами же «вирусы» Флягин переписывал с помощью сети Интернет с одного из серверов в Бразилии.

Четвертая группа преступлений «Перехват информации». Преступления этой группы можно разделить на несколько видов в зависимости от каналов утечки речевой, электронной и другой обрабатываемой на объекте информации.

Различают технические каналы утечки информации, создаваемые непосредственно строительными и инженерными сооружениями и установленными в них техническими средствами (связь, вычислительная техника, слаботочная техника, электроснабжение, заземление и т.п.).

В зависимости от указанных каналов можно выделить несколько способов перехвата информации.

Электромагнитный (пассивный) перехват. Электронно-лучевая трубка, являющаяся центральным элементом компьютерного устройства для видео отображения информации на экране (дисплее), излучает в окружающее пространство электромагнитные волны, несущие в себе определенную информацию, данные («электронный смог»).

Волны, излучаемые этим прибором, примерно так же, как при телевизионном вещании, проникают сквозь различные физические преграды с некоторым коэффициентом ослабления, например, через стекло оконных проемов и стены строений. Принимать эти волны, как показывают данные многочисленных экспериментов, можно на расстоянии до 1000 метров. Как только эти сигналы приняты соответствующей аппаратурой и переданы на другой компьютер (преступника), можно получить изображение, идентичное изображению, возникающему на мониторе «передающего» компьютера, для чего достаточно настроиться на его конкретную индивидуальную частоту.

Впервые дистанционный перехват информации с дисплея компьютера открыто был продемонстрирован в марте 1985 года в Каннах на Международном конгрессе по вопросам безопасности ЭВМ. Сотрудник голландской телекоммуникационной компании PTT Вим-Ван-Эк шокировал специалистов тем, что с помощью разработанного им устройства из своего автомобиля, находящегося на улице, «снял» данные с экрана дисплея персонального компьютера, установленного на восьмом этаже здания, расположенного в ста метрах от автомобиля.

Непосредственный (активный) перехват. Наиболее простой способ перехвата электронной информации - захват канала, по которому передается информация. При этом программные средства позволяют в реальном времени просматривать передаваемую информацию, выбирая интересующие фрагменты практически незаметно для отправителя и получателя.

Как пример активного перехвата, но уже радиорелейной связи, можно привести действия преступной группы в Воронеже, собравшей из легально приобретенной аппаратуры сканеры, позволяющие считывать номера и персональные идентификационные коды абонентов сотовой сети в момент автоматического обмена этой информацией между зарегистрированной абонентской станцией и центральным процессором сотовой компании.

Средством перехвата информации могут быть также несанкционированные радиопередающие устройства («жучки»), звукозаписывающая аппаратура и др.

Пятая группа – «Нарушение авторских прав (компьютерное пиратство) - практически не требует комментариев. Достаточно посетить радио рынок в любом городе России, где за скромную плату вам предложат практически любой уже «вскрытый» программный продукт или набор взломщиков лицензионных программ.

Проблема компьютерного пиратства имеет больше социальный характер: рынок дополнительных услуг и гарантий, предлагаемых лицензионной продук-

цией, не способен составить достойную конкуренцию ценовой политике «пиратского рынка».

До 1992 года копирование и использование на территории России любых программ законодательно ничем не ограничивалось. Законом РФ «**О правовой охране программ для электронно-вычислительных машин и баз данных**», принятым 23 сентября 1992 года, программы для ЭВМ и базы данных впервые на территории России были отнесены к объектам авторского права. В этом законе программа для ЭВМ определяется как «объективная форма представления совокупности данных и команд, предназначенных для функционирования электронных вычислительных машин (ЭВМ) и других компьютерных устройств с целью получения определенного результата». Термин «программа для ЭВМ» включает также подготовительные материалы, полученные в ходе ее разработки, и порождаемые ею аудиовизуальные отображения. База данных определяется как «объективная форма представления и организации совокупности данных (статей, расчетов и т.д.), систематизированных таким образом, чтобы эти данные могли быть найдены и обработаны с помощью ЭВМ».

В настоящее время закон РФ «**О правовой охране программ для электронно-вычислительных машин и баз данных**», от 23 сентября 1992 г. утратил силу и с 01.01.2008г. вместо этого документа действует ч.4 ГК РФ от 18.12.2006 № 230-ФЗ. В разделе VII ГК РФ условия признания авторского права определяет ст. 1261, согласно которой «Авторские права на все виды программ для ЭВМ (в том числе на операционные системы и программные комплексы), которые могут быть выражены на любом языке и в любой форме, включая исходный текст и объектный код, охраняются так же, как авторские права на произведения литературы».

В статье 1262 (Государственная регистрация программ для ЭВМ и баз данных) указано, что для защиты авторских прав, правообладатель программы для ЭВМ и базы данных может зарегистрировать свои права, подав заявку в базу данных в федеральном органе исполнительной власти по интеллектуальной собственности.

Согласно ст. 1271 правообладатель для оповещения о своих правах может, начиная с первого выпуска программы для ЭВМ или базы данных в свет, использовать знак охраны авторского права, состоящий из трех элементов: © - буквы С в окружности или в круглых скобках; наименования (имени) правообладателя; года первого выпуска произведения в свет».

Вопросам авторского права ч.4 ГК РФ посвящены также ст. 1280, 1295, 1296, 1297 и другие, подробное рассмотрение которых может занять много времени, однако желающие могут ознакомиться с ними самостоятельно.

В случае нанесения крупного ущерба нарушителем авторского права, его действия могут быть квалифицированы по ст. 146 УК РФ.

Ст. 146. Нарушение авторских и смежных прав

1. Присвоение авторства (плагиат), если это деяние причинило крупный ущерб автору или иному правообладателю, -

наказывается штрафом в размере до двухсот тысяч рублей или в размере заработной платы или иного дохода осужденного за период до восемнадцати месяцев, либо обязательными работами на срок от ста восьмидесяти до двухсот сорока часов, либо исправительными работами на срок до одного года, либо арестом на срок до шести месяцев.

2. Незаконное использование объектов авторского права или смежных прав, а равно приобретение, хранение, перевозка контрафактных экземпляров произведений или фонограмм в целях сбыта, совершенные в крупном размере, - наказываются штрафом в размере до двухсот тысяч рублей или в размере заработной платы или иного дохода осужденного за период до восемнадцати месяцев, либо обязательными работами на срок от ста восьмидесяти до двухсот сорока часов, либо исправительными работами на срок до двух лет, либо лишением свободы на срок до двух лет.
3. Деяния, предусмотренные частью второй настоящей статьи, если они совершены:
б) группой лиц по предварительному сговору или организованной группой; в) в особо крупном размере; г) лицом с использованием своего служебного положения, -
наказываются лишением свободы на срок до шести лет со штрафом в размере до пятисот тысяч рублей или в размере заработной платы или иного дохода осужденного за период до трех лет либо без такового.

Примечание. Деяния, предусмотренные настоящей статьей, признаются совершенными в крупном размере, если стоимость экземпляров произведений или фонограмм либо стоимость прав на использование объектов авторского права и смежных прав превышают пятьдесят тысяч рублей, а в особо крупном размере - двести пятьдесят тысяч рублей.

Обязательным условием наступления уголовной ответственности по ст. 146 УК РФ является причинение крупного ущерба. Если считать, что копирование компьютерной информации с нарушением авторских нрав является неправомерным доступом к охраняемой законом компьютерной информации (ст. 272 УК РФ), то уголовная ответственность за такую форму нарушения авторских прав будет наступать независимо о нанесения ущерба. Такое предположение создает зависимость степени защищенности авторских прав от используемого материального носителя объекта авторского права.

Несмотря на видимые различия всех перечисленных выше групп компьютерных преступлений, практика расследования показывает их тесную взаимосвязь.

В октябре - ноябре 1997 года на коммерческом рынке Санкт-Петербурга стала распространяться база данных абонентов компании сотовой связи с указанием всех исчерпывающих данных о клиентах и пр. Указанная база продавалась на компакт-дисках наряду с другими телефонными базами. При проведении следственно-оперативных мероприятий были установлены лица, тиражировавшие эту информацию, а также источники этой информации - лица, осуществлявшие неправомерный доступ к базе данных и ее копирование.

При расследовании этого дела установлен целый ряд высокопрофессиональных и противоправных действий в сфере компьютерной информации, в том числе:

- подбор кодов к голосовым почтовым ящикам пейджеров путем доступа к центральному процессору пейджинговой системы через телефонные линии;
- «взлом» системы сотовых операторов путем внесения ложных идентификационных меток в аппаратуру сравнения кодов с целью создания телефонов-дублеров.

Между тем количество зарегистрированных «компьютерных» преступлений все еще не велико. Не получившие в России по экономическим причинам необходимого развития крупные государственные и корпоративные информационные системы именно в силу своей содержательной и технической отсталости не стали объектом вторжений со стороны как отечественных, так и зарубежных информационных преступников, хотя и подвергаются массовому «пиратскому» копированию.

Банковские информационные системы России стали создаваться и продолжают развитие с учетом имевшихся на Западе проблем с конфиденциальностью, многие из них и сейчас просто закрыты от внешнего доступа. Эти обстоятельства дают основание полагать, что угрозы информационной преступности именно в области компьютерной информации для российских субъектов реальны, однако пока не имеют той остроты, как в странах развитых в области информационных технологий. Практика последних лет показывает, что пока отечественные «преступные таланты» ищут жертвы для нападения в основном в зарубежных информационных системах.

Кроме того, многие организации даже при установлении факта подобного преступления предпочитают ограничиваться разрешением конфликта своими силами, поскольку убытки от расследования могут оказаться выше суммы причиненного ущерба (изъятие файлового сервера для проведения экспертизы может привести к остановке работы на срок до двух месяцев, что неприемлемо ни для одной организации). Руководство опасается подрыва своего авторитета в деловых кругах и в результате - потери большого числа клиентов, а так же неминуемого раскрытия в ходе судебного разбирательства системы безопасности организации или выявления собственной незаконной деятельности.

Даже при отсутствии указанных обстоятельств руководители организаций, работающих в информационной сфере, сомневаются в возможности положительного решения их проблем правоохранительными органами.

Однако органы внутренних дел проводят как организационные, так и практические мероприятия, направленные на совершенствование борьбы с компьютерными преступлениями**.** Специалисты, имеющие хорошую юридическую и техническую подготовку, востребованы не только при расследовании компьютерных преступлений или преступлений, совершаемых с применением компьютерной техники. Все чаще преступники и преступные сообщества используют компьютеры для хранения информации, для организации закрытой связи, для

проведения необходимых расчетов при подготовке преступлений. В компьютерах хранится «компромат», «черная бухгалтерия» и другие сведения, которые при правильной работе с ними могут существенно помочь в борьбе с организованной преступностью.

В Следственном комитете при МВД России создан отдел по организации расследования преступлений в сфере компьютерной информации, а в следственных управлениях крупных регионов - специализированные подразделения по расследованию данного вида преступлений. Оперативно-розыскная деятельность по выявлению, пресечению и раскрытию правонарушений в сфере телекоммуникаций и компьютерной информации осуществляется имеющимся в министерстве Управлением по борьбе с преступлениями в сфере высоких технологий и его подразделениями на местах.

В настоящее время активно ведется работа по подготовке и обучению сотрудников как следственных, так и оперативных подразделений. Для этих целей, помимо ведущих российских специалистов, приглашаются и специалисты правоохранительных органов зарубежных стран, уже давно столкнувшихся с проблемой компьютерной преступности.

Таким образом, создаются все необходимые условия для успешной борьбы с этим видом общественно опасных деяний.

Глава 2. Безопасность вычислительных систем и сетей

2.1. Задача обеспечения информационной безопасности в современных условиях. Информация как объект защиты

Современный уровень информационных технологий позволяет рассматривать информацию, как общественный ресурс развития, наравне с традиционными (сырье, электроэнергия и т.д.) ресурсами. За последнее десятилетие резко увеличился уровень производства и потребления обществом информационных продуктов и услуг. В нашей стране ускоренными темпами идет развитие систем телекоммуникаций, увеличиваются парки компьютерной техники, непрерывно растет число пользователей сотовой связи и сети Интернет.

Информация, являясь по своей физической природе нематериальным объектом, давно стала предметом торговли и обмена, а с появлением ряда правовых и регулирующих положений, приобретает черты материального объекта. Федеральным Законом «Об информации, информатизации и защите информации» определено, что информационные ресурсы, то есть отдельные документы или массивы документов, в том числе и в информационных системах, являясь объектом отношений физических, юридических лиц и государства, подлежат обязательному учету и защите, как всякое материальное имущество собственника. При этом собственнику предоставляется право самостоятельно в пределах своей компетенции устанавливать режим защиты информационных ресурсов и доступа к ним. Ответственность за выполнение мер защиты информации возлагается также и на пользователя информации. При этом следует особо подчеркнуть, что защищается только информация документированная, зафиксирован-

ная на материальном носителе информации с реквизитами, позволяющими её идентифицировать. Так, нематериальный объект, например электронный текст, может обрести юридическую силу, если у него есть, кроме прочих реквизитов, заверенная электронная подпись и дата.

По степени важности и ценности защищаемой информации выделяется три категории:

– информация, составляющая государственную тайну;
– персональная информация;
– информация, составляющая коммерческую тайну.

Возможности доступа к первой категории информации и владение ей, определяется государством. Выбор степени защиты второй и третьей категорий информации возлагается на собственников информации, поэтому, например, право отнесения той или иной информации, циркулирующей на предприятии, к категории коммерческой тайны предоставлено руководителю данного предприятия. И, наконец, прежде чем определить комплекс мер по защите своих информационных ресурсов, согласно законодательным актам важно напомнить основные цели защиты информации:

- предотвращение утечки, хищения, искажения, подделки информации;
- обеспечение безопасности личности, общества, государства;
- предотвращение несанкционированных действий по уничтожению, искажению, блокированию информации;
- защита конституционных прав граждан на сохранение личной тайны и конфиденциальности персональных данных;
- сохранение государственной тайны, конфиденциальности документированной информации.

Безопасность информационных систем и технологий обеспечивается реализацией основных функций безопасности.

Защита конфиденциальности – достигается путем применения сертифицированных средств защиты информации от несанкционированного доступа, реализации правил разграничения доступа к информации, применения алгоритмов специального преобразования данных при передаче информации в сети передачи данных, проведения специальных работ по предотвращению утечки конфиденциальной информации по техническим каналам, а также организационных мер по предотвращению разглашения конфиденциальной информации и неправомерных действий со стороны лиц, имеющих право доступа к конфиденциальной информации.

Защита целостности – достигается путем разработки и внедрения технологий резервирования и восстановления ресурсов, применения технологий электронной цифровой подписи, физической охраной средств вычислительной техники и носителей информации, другими организационными мерами.

Защита доступности – достигается путем резервирования технических средств, дублирования каналов передачи данных в сети, применением активного анализа трафика сети, а также организационными мерами.

Защита живучести системы – достигается распределенным резервированием баз данных, реализацией технологий восстановления ресурсов, а также организационными мерами, направленными на поддержание механизма реагирования на потенциальные угрозы при возникновении чрезвычайных ситуаций.

И, наконец, любая система обеспечения информационной безопасности должна выполнять следующий ряд задач:

- своевременное выявление и устранение угроз информационным и техническим ресурсам;
- выявление причин и условий, способствующих нанесению материального ущерба организации, предприятию и их клиентам при нарушении функционирования системы и несанкционированного использования информации;
- создание механизма и условий оперативного реагирования на угрозы безопасности и проявления негативных тенденций в функционировании;
- эффективное пресечение посягательств на ресурсы и информацию, циркулирующую в системе, на основе комплексного подхода к обеспечению безопасности;
- контроль эффективности мер защиты.

2.2. Источники угроз и способы нарушения информационной безопасности

Порядок исследований в сфере нарушений информационной безопасности можно представить в виде трехэтапной схемы:

1) исследование действий, попадающих под понятие нарушение (преступление) в информационной сфере;

2) исследование объектов обмена информацией и опасностей, угроз нанесения ущербов субъектам информационных отношений;

3) исследование факторов, уязвимостей конкретных объектов информатизации и действий, атак, реализующихся через имеющиеся уязвимости.

Дадим некоторые определения.

Информационная безопасность – состояние защищенности важных интересов личности, общества и государства от внутренних и внешних угроз.

Угроза (вообще) – потенциально возможное событие, действие (воздействие), процесс или явление, которое может привести к нанесению ущерба чьим-либо интересам.

Угроза интересам субъектов информационных отношений – потенциально возможное событие, процесс или явление, которое посредством воздействия на информацию или другие компоненты информационных систем может прямо или косвенно привести к нанесению ущерба интересам данных субъектов.

Уязвимость – причина нестабильности режима информационной безопасности, обусловленная просчетами и ошибками, допущенными в процессе проектирования и эксплуатации объекта информатизации.

Атака – действия, проявляющиеся при реализации угроз информационной безопасности через имеющиеся уязвимости.

Результатами реализации угроз информационной безопасности и осуществления способов воздействия на информационные ресурсы, информационные системы и процессы в общем случае являются:

- нарушение конфиденциальности (секретности) информации: разглашение, утрата, хищение, утечка и перехват и т.д. ;
- нарушение целостности информации (уничтожение, искажение, подделка и т.д.);
- нарушение доступности информации и работоспособности информационных систем (блокирование данных и информационных систем, разрушение элементов информационных систем, компрометация системы защиты информации и т.д.).

Одним из первых в области информационной безопасности задается следующий вопрос: Какие действия попадают под понятие преступление в информационной сфере? Ответ на это вопрос дает международная классификация способов совершения компьютерных преступлений, которая ведется Интерполом в классификаторе информационно-поисковой системы, начиная с 1990-х годов.

Все коды, характеризующие компьютерные преступления, имеют идентификатор, начинающийся с буквы **Q**. Для характеристики преступления могут использоваться до пяти кодов, расположенных в порядке убывания значимости совершенного.

1) QA – Несанкционированный доступ и перехват

QAH – компьютерный абордаж (хакинг) – доступ в компьютер или сеть без права на то. Этот вид компьютерных преступлений обычно используется хакерами для проникновения в чужие информационные сети.

QAI – перехват при помощи технических средств без права на то, осуществляемый либо прямо через внешние коммуникационные каналы системы, либо путем непосредственного подключения к линиям периферийных устройств.

QAT – кража времени, с целью неуплаты за пользование компьютерной системой или сетью.

QAZ – прочие виды несанкционированного доступа и перехвата

2) QD – Изменение компьютерных данных

QUL/QDT – логическая бомба, троянский конь, действия, позволяющие осуществлять функции, не планировавшиеся владельцем или пользователем программы.

QDV – компьютерный вирус, вредоносная самопорождающаяся программа, порождающая нежелательные программные действия и/или приводящая к утрате и искажению хранимых данных.

QDW – компьютерный червь, искажение или хищение данных посредством компьютерной сети.

QDZ – прочие виды изменения данных, взлом (крэкинг).

3) QF – Компьютерное мошенничество

QFC – мошенничество с банкоматами.

QFF – компьютерная подделка.

QFG – мошенничество с игровыми автоматами.
QFM – манипуляции с программами ввода-вывода.
QFP – мошенничества с платежными средствами.
QFT – телефонное мошенничество.
QFZ – прочие компьютерные мошенничества.

4) QR – Незаконное копирование

QRG – компьютерные игры.
QRS – прочее программное обеспечение.
QRT – топография полупроводниковых изделий.
QRZ – прочее незаконное копирование.

5) QS – Компьютерный саботаж

QSH – с аппаратным обеспечением.
QSS – с программным обеспечением.
QSZ – прочие виды саботажа.

6) QZ – Прочие компьютерные преступления

QZB – с использованием компьютерных досок объявлений.
QZE – хищение информации, составляющей коммерческую тайну.
QZS – передача информации конфиденциального характера.
QZZ – прочие компьютерные преступления.

Из приведенной классификации видно, что наибольшее значение имеют преступления, связанные с несанкционированным доступом и неправомерным завладением информации.

Однако, в нашей стране, в отличие от приведенного классификатора, наиболее распространенные (практически повсеместно совершающиеся), преступления имеют иную цель – пользование нужными свойствами неправомерно полученной информации (программы, базы данных), как то: выполнения расчетов с использованием программы, получения справок или отчетов из базы данных и связанное с этим незаконное копирование программ.

Вторым по распространенности злом следует признать разрушение информации, связанное с ущербом, наносимым вирусными программами, а затем идут действия по модификации информационных продуктов как товара (лишение их свойств защищенности), т.е. различные виды взлома.

Перейдем к рассмотрению следующего вопроса: Каковы угрозы, присущие объектам информатизации?

Современные объекты информационных систем состоят из следующих подсистем:

- рабочих станций или удаленных терминалов сети;
- серверов (служб Интернета, файлов, печати, баз данных и т.п.);
- межсетевых телекоммуникационных средств (коммутаторов, маршрутизаторов, серверов удаленного доступа и т.д.);
- каналов связи (проводных, беспроводных, оптических).

В связи с этим существует значительное число угроз информационной безопасности и принципов их классификации. Однако, очевидно, что в любой классификации необходимо рассмотреть стороны и мотивы происхождения уг-

роз. По отношению к рассматриваемым информационным системам и сетям угрозы делятся на внутренние и внешние угрозы.

Источниками внутренних угроз являются:

- лица, прямо или косвенно участвующие в процессах информационных отношений своих организаций (основные сотрудники организаций, другой технический и вспомогательный персонал и др.);
- аппаратные средства и программное обеспечение информационных систем (как объекты, подверженные дефектам, сбоям, отказам и авариям).

Источниками внешних угроз являются:

- лица и организации, прямо заинтересованные или косвенно вовлекаемые в процессы информационных отношений других организаций (преступники, недобросовестные партнеры, поставщики телекоммуникационных услуг и др.);
- сети инженерных, транспортных и телематических коммуникаций.
- природные явления и стихийные бедствия.

Из перечисленных угроз *по мотивации действий* выделяют следующие:

- непреднамеренные (неумышленные, случайные) угрозы;
- преднамеренные (умышленные, спланированные) угрозы.

По способам воздействия на объекты информационных отношений:

- информационные (несанкционированный доступ к информационным ресурсам; незаконное копирование данных в информационных системах; хищение информации из библиотек, архивов, банков и баз данных; нарушение технологии обработки информации; противозаконный сбор и использование информации; использование информационного оружия);
- программные (дефекты и уязвимости в программном обеспечении; компьютерные вирусы; программные закладки);
- физические (разрушение компьютерных средств и сетей; хищение носителей информации, ключей защиты; воздействие на лиц, имеющих доступ к информации);
- радиоэлектронные (внедрение средств съема информации в компьютерные средства, сети и помещения; перехват, расшифровка, подмена и уничтожение информации в каналах связи);
- организационно-правовые (навязывание или закупки не сертифицированных информационных средств или систем; нарушение требований законодательства в отношении режимов информационной безопасности).

Дальнейшая детализация классификационной схемы угроз весьма объемна, поэтому приведем наиболее распространенные, на наш взгляд, типовые угрозы информационной безопасности.

Основные непреднамеренные угрозы:

1) нелегальная установка и использование неучтенных программ (игровых, обучающих, технологических и др., не являющихся необходимыми для выполнения служебных обязанностей);

2) заражение компьютера вирусами;

3) разглашение, передача или утрата атрибутов разграничения доступа (паролей, ключей шифрования, идентификационных карточек, пропусков и т.п.);

4) неправомерное включение оборудования или изменение режимов работы устройств и программ;

5) неумышленная порча носителей информации;

6) игнорирование режимов соблюдения информационной безопасности;

7) вход в систему в обход средств защиты (загрузка посторонней операционной системы со сменных магнитных носителей и т.п.);

8) некомпетентное использование, настройка или неправомерное отключение средств защиты администраторами сетей и персоналом службы безопасности;

9) пересылка данных по ошибочному адресу абонента (устройства);

10) ввод ошибочных данных.

Основные преднамеренные угрозы:

1) несанкционированное копирование носителей информации;

2) хищение носителей информации (магнитных дисков, лент, микросхем памяти, запоминающих устройств и целых ПК);

3) незаконное получение паролей и других реквизитов разграничения доступа с последующей маскировкой под зарегистрированного пользователя;

4) внедрение аппаратных и программных закладок и вирусов («троянских коней» и «жучков»), позволяющих преодолеть систему защиты, скрытно и незаконно осуществлять доступ к системным ресурсам с целью регистрации и передачи критической информации или дезорганизации функционирования системы;

5) перехват данных, передаваемых по каналам связи, и их анализ с целью выяснения протоколов обмена, правил вхождения в связь и авторизации пользователя и последующих попыток их имитации для проникновения в систему;

6) незаконное подключение к линиям связи с целью прямой подмены законного пользователя путем его физического отключения после входа в систему и успешной аутентификации с последующим вводом дезинформации и навязыванием ложных сообщений;

7) несанкционированное использование терминалов пользователей, имеющих уникальные физические характеристики, такие как номер рабочей станции в сети, физический адрес, адрес в системе связи, аппаратный блок кодирования и т.п.;

8) внедрение агентов в число персонала системы (в том числе, возможно, и в административную группу, отвечающую за безопасность) или вербовка (пу-

тем подкупа, шантажа и т.п.) персонала и отдельных пользователей, имеющих определенные полномочия;

9) вскрытие шифров криптозащиты информации;

10) физическое разрушение системы (путем взрыва, поджога и т.п.) или вывод из строя всех или отдельных наиболее важных компонентов компьютерной системы (устройств, носителей важной системной информации, лиц из числа персонала и т.п.).

Ввиду неуклонного роста числа пользователей сети Интернет особую значимость приобретают угрозы, связанные с удаленным сетевым доступом – сетевые компьютерные атаки. Существует ряд организаций (*SANS Institute*, *CERT Coordination Center* и др.), которые занимаются экспертизой уязвимостей сетевых компьютерных средств, программного обеспечения, сообщают о найденных уязвимостях и публикуют предлагаемые меры по их устранению. Приведем распространенные службы сетевого программного обеспечения, представляющие наибольшую уязвимость в отношении сетевых компьютерных атак.

На платформе Windows

1. Служба web-сервиса Интернет *Internet Information Services* (*IIS*).
2. Компоненты доступа к данным *Microsoft Data Access Components* (*MDAC*).
3. Сервер баз данных *SQL Server*.
4. Сетевой протокол *NetBIOS*, разделяемые сетевые ресурсы.
5. Анонимный вход в операционную систему («*null*»-сессии).
6. Менеджер аутентификации локальной сети (*LANMAN hash*).
7. Аутентификация входа в Windows.
8. Браузер Интернет *Internet Explorer* (*IE*).
9. Удаленный доступ к реестру (*Remote Registry Access*).
10. Windows-сценарии (скрипты).

На платформе UNIX:

1. Удаленный вызов процедур (*RPC*).
2. Веб-сервер *Apache*.
3. *SSH* (удаленный терминал с шифрованием трафика).
4. Протокол управления сетью *SNMP*.
5. Протокол передачи файлов *FTP*.
6. *RSH*-сервисы (возможность входа на доверенные системы).
7. Служба печати (*LPD – Line printer daemon*).
8. Почтовый сервер *Sendmail*.
9. Службы разрешения доменных имен *BIND*/*DNS*.
10. Аутентификация входа в систему.

2.3. Аспекты практической компьютерной безопасности. Средства анализа защищенности систем и сетей

Первой и важнейшей задачей обеспечения информационной безопасности является анализ состояния защищенности компьютерных систем и сетей. Выполнение анализа защищенности программного обеспечения систем и сетей

достигается применением дополнительных инструментальных средств. К их числу относятся:

- средства анализа защищенности операционных систем (сканеры уязвимостей);
- средства анализа защищенности сетевых служб (сетевые сканеры).

Средства анализа защищенности операционных систем позволяют осуществлять ревизию механизмов разграничения доступа, идентификации и аутентификации, средств мониторинга, аудита и других компонентов операционных систем. Кроме этого, средствами данного класса проводится контроль целостности и неизменности программных средств и системных установок и проверка наличия уязвимостей системных и прикладных служб. Как правило, такие проверки проводятся с использованием базы данных уязвимостей операционных систем и сервисных служб, которые могут обновляться по мере выявления новых уязвимостей.

Средства анализа защищенности сетевых сервисов применяются для оценки защищенности компьютерных сетей по отношению к внутренним и внешним атакам. По результатам анализа защищенности сетевых сервисов средствами генерируются отчеты, включающие в себя список обнаруженных уязвимостей, описание возможных угроз и рекомендации по их устранению. Поиск уязвимостей основывается на использовании базы данных, которая содержит широко известные уязвимости сетевых сервисных программ и может обновляться путем добавления новых.

В настоящее время существует значительное число сканеров угроз безопасности, как коммерческих, так и некоммерческих для любой аппаратной платформы. Рассмотрим некоторые из них.

1) Средство сетевого анализа безопасности *Cisco Secure Scanner*

Cisco Secure Scanner (производитель *Cisco Systems*) позволяет проводить активный аудит ресурсов сети на наличие ошибок в области обеспечения защиты от несанкционированного доступа и на соответствие сетевых ресурсов политике безопасности. *Cisco Secure Scanner* предоставляет следующие возможности по анализу сетевой безопасности:

- инвентаризация систем и сервисов в корпоративной сети;
- определение возможных ошибок в системах безопасности путем сканирования и протоколирования;
- эффективное управление уязвимостью данных;
- принятие решений в области защиты данных на основе отчетов и диаграмм;
- определение и реализация политики безопасности для новых устройств сети.

Другими возможностями сканера являются: автоматическое определение узлов и сервисов, предоставление пользователю детальной информации обо всех устройствах, подключенных к наблюдаемой сети, построение карты доступных сервисов сети, используя порты *TCP/UDP* и запросы *SNMP*.

2) Средства активного аудита безопасности *Internet Security Systems*

Технология *Internet Security Systems* (производитель *ISS*) включает:

– технологию анализа защищенности или поиска уязвимостей;
– технологию обнаружения атак.

Реализует эту технологию семейство продуктов *SAFEsuite*, которое включает в себя:

1 Систему анализа защищенности на уровне сети *Internet Scanner*.

2 Системы анализа защищенности на уровне операционной системы и прикладного программного обеспечения *System Scanner* и *Online Scanner*.

3 Систему анализа защищенности на уровне систем управления базами данных *Database Scanner*.

4 Системы обнаружения атак на уровнях сети, операционных систем, баз данных и прикладного программного обеспечения *RealSecure*.

3) Программный комплекс для распределеннго анализа защищенности сетей *Distributed CyberCop Scanner*

Distributed CyberCop Scanner (производитель *Network Associates*) позволяет выполнять сканирования на географически распределенных сетях, накапливая результаты в общей базе данных. В дополнение к большому количеству проверок конфигураций межсетевых экранов *Distributed CyberCop Scanner* тестирует web-сервера, файловые сервера, рабочие станции, маршрутизаторы и другие сетевые устройства на предмет обнаружения слабых мест в защите с выдачей подробных графических отчетов и рекомендаций по усилению безопасности. Графические отчеты значительно упрощают процесс определения приоритетов, визуально отображая уровень риска обнаруженных уязвимостей и предоставляя возможность администраторам безопасности быстро определить наиболее слабые места сети. Пользователи имеют возможность осуществлять поиск уязвимостей по уникальному номеру *CVE* (*Common Vulnerabilities and Exposures*), первому публичному списку, обеспечивающему стандартизированные имена и описания более чем 500 известных уязвимостей.

Среди некоммерческих средств анализа защищенности можно выделить программы *Nessus* и *Nmap*, относящиеся к классу сетевых сканеров безопасности. Они используют много различных методов сканирования, основанных на особенностях протоколов стека *TCP/IP*.

Другими возможностями этих программ являются:

– определение операционной системы удаленного компьютера;
– «невидимое» сканирование;
– динамическое вычисление времени задержки и повтор передачи пакетов;
– параллельное сканирование;
– определение неактивных узлов сети методом параллельного опроса;
– сканирование с использованием ложных узлов сети;

– определение наличия пакетных фильтров;
– сканирование с использованием *IP*-фрагментации, а также произвольное указание *IP*-адресов и номеров портов сканируемых сетей.

2.4. Защита компьютеров и сетей. Антивирусное программное обеспечение

К основным видам антивирусного программного обеспечения относятся: антивирусные сканеры, антивирусные мониторы, ревизоры изменений, и эвристические анализаторы. Некоторые из них практически вышли из употребления в связи с низкой эффективностью, и, наоборот, другие еще не используются достаточно широко.

Первые из упомянутых, *антивирусные сканеры* производят поиск в файлах, памяти, и загрузочных секторах вирусных масок, т.е. уникального программного кода вируса. Вирусные маски, описания известных вирусов содержатся в антивирусной базе данных, и если сканер встречает программный код, совпадающий с одним из этих описаний, то он выдает сообщение об обнаружении соответствующего вируса.

Антивирусные мониторы, являясь резидентной разновидностью антивирусных сканеров («резидентный» означает «постоянно находящийся в памяти»), позволяют осуществлять проверку файлов или сообщений электронной почты в реальном масштабе времени.

Принцип работы *ревизоров изменений* основан на снятии оригинальных «отпечатков» (например, контрольных *CRC* сумм) с файлов, системных секторов и системного реестра. Эти «отпечатки» сохраняются в базе данных, а при следующем запуске ревизор сверяет «отпечатки» с их оригиналами и сообщает пользователю о произошедших изменениях, отдельно выделяя вирусоподобные и другие, не подозрительные, изменения.

Эвристический анализатор представляет собой программу, отслеживающую различные события и в случае «подозрительных» действий (действий, которые может производить вирус или другая вредоносная программа), запрещает это действие или запрашивает разрешение у пользователя. Иными словами, эвристический анализатор совершает не поиск уникального программного кода вируса (как это делают сканеры и мониторы), не сравнивает файлы с их оригиналами (наподобие ревизоров изменений), а отслеживает и нейтрализует вредоносные программы по их характерным действиям.

Среди антивирусного программного обеспечения явно выделяются несколько лидеров: *McAfee VirusScan*, *Symantec Norton Antivirus*, *AVP* Лаборатории Касперского.

McAfee VirusScan обеспечивает антивирусную защиту компьютера, включая обнаружение вирусов при работе с файлами и групповыми приложениями, блокирование враждебных объектов *Java/ActiveX*, зараженных сообщений электронной почты и опасных Интернет-ресурсов. Он способен обезвреживать даже некоторые удаленные сетевые атаки, например, типа *Distributed Denial of Service (DDoS)*.

В *Symantec Norton Antivirus* включены новые технологии распознавания вирусных атак:

– технология *Striker32*, которая обнаруживает вирусы и восстанавливает данные, поврежденные наиболее сложными полиморфными вирусами, что часто невозможно сделать с помощью других антивирусных средств;

– эвристическая технология *Bloodhound*, которая отыскивает новые и неизвестные макровирусы (макросы, внедряющиеся в документы), используя передовую эвристическую технологию, позволяющую автоматически пропускать «чистые» файлы и задерживать инфицированные прежде, чем они смогут причинить вред.

В антивирусный пакет Лаборатории Касперского *AVP* входят все передовые способы борьбы с вирусами. Это: антивирусный сканер для проверки мест хранения данных; антивирусный монитор для проверки всех используемых файлов в масштабе реального времени; ревизор изменений для контроля целостности данных на компьютерах; уникальный модуль фонового перехвата скрипт - вирусов; поведенческий блокиратор, обеспечивающий защиту от макровирусов на 100 %.

Средства защиты сетевых операционных систем

Средства защиты операционных систем реализуют все современные принципы информационной безопасности. Рассмотрим их на примере серверной сетевой операционной системы Microsoft Windows 2003 Server. В системах на базе этой операционной системы возможна идентификация пользователей сети и управление их доступом к ресурсам. В модели безопасности этой операционной системы используются доверительная проверка подлинности контроллерами доменов, делегирование полномочий между службами, а также объектно-ориентированное управление доступом.

В состав операционной системы Windows 2003 Server входят следующие службы обеспечения безопасности:

1 *Групповые политики безопасности.* Для управления рабочими средами пользователей и обеспечения безопасности сетевых ресурсов Windows 2003 Server поддерживает групповые политики. Они хранятся в доменах Windows 2003 Server (*Active Directory*) или в локальных базах данных на компьютерах.

2 *Инфраструктура открытого ключа*. Инфраструктура открытого ключа (*PKI – Public Key Infrastructure*) используется для проверки и подтверждения подлинности компьютеров и пользователей, вовлеченных в сетевое взаимодействие. Windows 2003 Server использует для обеспечения работы *PKI* службы сертификации (*Certification Services*).

3 *Шифрующая файловая система.* Windows 2003 Server поддерживает шифрованную файловую систему (*EFS – Encrypting File System*) для обеспечения безопасности данных на локальных жестких дисках. *EFS* зашифровывает файлы и папки, так что неавторизированный пользователь не сможет прочесть данные файлы. В корпоративных средах *EFS* обычно используется на исполнительских переносных компьютерах для защиты бизнес - информации в случаях, если компьютер будет физически украден.

4 *Протокол Kerberos v5*. Windows 2003 Server проверяет его подлинность пользователя, входящего в сеть при помощи протокола *Kerberos*, прежде чем позволить пользователю получить доступ к ресурсам сети. Kerberos является стандартизованным протоколом аутентификации.

5 *Протокол IPSecurity.* Для того чтобы обеспечить взаимодействие между двумя компьютерами в сети, Windows 2003 Server поддерживает протокол *Internet Protocol Security* (*IPSec*). *IPSec* шифрует данные на передающем компьютере и обеспечивает механизм дешифрования данных только на принимающем компьютере для обеспечения целостности данных.

6 *Делегирование администрирования безопасности.* Для управления сетями Windows 2003 Server системные администраторы могут разрешать пользователям определенных сетевых ресурсов выполнение специальных операций безопасности. Например, право осуществлять изменение паролей для отдела учета может быть делегировано определенному пользователю этого отдела компании.

Эффективное функционирование ни одной многопользовательской операционной системы невозможно без четкого разграничения доступа к ресурсам. Групповые политики безопасности являются одним из средств, позволяющих настраивать параметры безопасной работы пользователей в сети в операционных системах Windows 2003 Server. Политики являются правилами, которые определяют опции для настройки установок безопасности файлов, установки программного обеспечения, сценариев, запуска и выключения компьютеров, входа и выхода пользователя из системы, установок регистра и перенаправления папок.

Инфраструктура открытого ключа в Windows 2003 Server создает архитектуру для сетевой безопасности, которая закладывает фундамент для текущих и будущих потребностей бизнеса и предоставляют платформу для безопасных сетевых транзакций, подтверждаемых с помощью сертификатов.

Математическим аппаратом этого информационного обмена служит криптосистема с открытым ключом. *Сертификат* – это средство, позволяющее гарантированно установить связь между переданным открытым ключом и передавшей его стороной, владеющей соответствующим личным ключом. Он представляет собой набор данных, зашифрованных с помощью электронной подписи, по стандарту является *ITU-T X.*509. Информация сертификата подтверждает истинность открытого ключа и владельца соответствующего личного ключа. Сертификаты также используются для обеспечения гарантии того, что содержание послания не будет подделано за время прохождения его от автора до того момента, когда его прочтет потребитель. Участниками обмена открытыми ключами являются центры сертификации («электронные нотариусы»), которым доверяют создавать, заверять и отзывать сертификаты; центры регистрации, уполномоченные выполнять идентификацию и регистрацию пользователей сертификатов и, наконец, сами пользователи, которые могут передавать запросы на получение сертификатов через web-интерфейс.

Поддержка прикладных программ шифрования информации с открытым ключом осуществляется с помощью интерфейса прикладного программирования *CryptoAPI.* Он содержит ряд функций, позволяющих приложениям шифровать данные и ставить цифровую подпись различными способами, обеспечивая защиту личных ключей. Независимые модули – *CSP* (*Cryptographic Service Provider* – поставщик службы шифрования) – фактически выполняют все процедуры шифрования. В том числе шифрующая файловая система обрабатывает файлы, используя открытый ключ и алгоритм симметричного шифрования *Data Encryption Standard X* (*DESX*) с длиной ключа 56 бит, функции которого доступны с помощью интерфейса *CryptoAPI.*

IP Security представляет собой два протокола: *Authentication Header* (*AH*) и *Encapsulated Security Payload* (*ESP*). Протокол *AH* обеспечивает взаимную аутентификацию узлов сети и обеспечивает целостность передаваемых пакетов. Протокол *ESP* выполняет шифрование содержимого пакетов, и также гарантирует взаимную аутентификацию и целостность. Когда защищенные данные аутентифицированы, получатель знает, что сообщение поступило именно от того отправителя, с которым установлено защищенное соединение, и во время передачи не подвергалось изменениям.

Защита компьютерных сетей

При информационном обмене между организациями часто возникает задача безопасного информационного взаимодействия локальных сетей и отдельных компьютеров через открытые сети, например, через сеть Интернет. При её решении требуется обеспечивать:

1) защиту подключенных к открытой сети Интернет локальных сетей организаций и отдельных компьютеров от несанкционированных действий со стороны внешней среды;

2) защиту информации в процессе передачи по общедоступным каналам связи.

Решение первой задачи основано на использовании межсетевых экранов (*brandmauer*, *firewall*). *Межсетевые экраны* – программные или программно-аппаратные средства, предназначенные для защищенного подключения корпоративной сети к сетям общего пользования на базе протоколов *TCP/IP*, *X*.25; разграничения ресурсов внутри корпоративной сети; а также для обеспечения контроля информационных потоков между различными сегментами корпоративной сети и внешними сетями. Они поддерживают безопасность информационного взаимодействия путем фильтрации двустороннего потока сообщений, а также выполнения функций посредничества при обмене информацией. Для защиты локальных сетей межсетевой экран располагают на стыке между локальной сетью и Интернет. Для защиты отдельного удаленного компьютера, подключенного к Интернету, программное обеспечение межсетевого экрана устанавливается на этом же компьютере, а сам он в этом случае называется персональным.

Большинство компонент межсетевых экранов относятся либо к фильтрующим пакетным брандмауэрам, либо к брандмауэрам уровня приложений

(прокси-серверам). Первый из них выполняет отсев нежелательных сетевых пакетов на основании полей *IP*-дэйтаграмм (адресов и портов отправителей и получателей). Второй выполняет регистрации событий и аудита каждого из приложений, пользующихся сетевыми сервисами, выполняя также преобразование сетевых адресов. Программных коммерческих и некоммерческих реализаций межсетевых экранов насчитывается довольно много. Хорошим решением является применение для приложений на платформе Windows 2003 Server корпоративного брандмауэра *Microsoft Internet Security and Acceleration Server*, а для персональных применений *Symantec Personal Firewall*.

Виртуальные частные сети

Для защиты информации в процессе передачи её по общедоступным каналам связи разработана концепция виртуальных частных сетей (*VPN*, *Virtual Private Network*). Виртуальная сеть формируется на основе каналов связи открытой сети. Сам термин «виртуальная» подчеркивает, что каналы связи виртуальной сети моделируются с помощью каналов связи реальной. Открытая сеть, например Интернет, может служить основой для одновременного сосуществования множества виртуальных сетей, количество которых определяется пропускной способностью каналов доступа к Интернету. Защита *VPN* может строиться на уровне сокетов (*сетевой сокет* – совокупность *IP*-адреса и номера порта сетевого приложения, определяющего тип приложения), на основе протоколов *SSL* (*Securiry Socket Low*) и *SSH* (*Securiry Shell*), на транспортном (*TCP*) уровне и на сетевом (*IP*) уровне. Для решения задач *VPN* защита на последнем уровне наиболее предпочтительна ввиду следующих условий:

– модуль системы защиты реализуется в виде драйвера операционной системы, располагающегося между *IP*-стеком и драйвером сетевого адаптера, что позволяет контролировать весь проходящий трафик;

– защита работает на уровне драйверов, что затрудняет атаку на средство защиты, используя сервисы операционной системы;

– защита прозрачна для сервисов более высокого уровня и пользовательских приложений;

– защита организуется между любыми двумя точками сети, используя топологию сети;

– обеспечивается маскирование внутренней топологии сети.

Защита информации в *VPN* строится с использованием следующих технических приемов:

1 Шифрование исходного *IP*-пакета, что обеспечивает секретность содержащихся в пакете данных, таких как поля *IP*-заголовка и поле данных.

2 Цифровая подпись *IP*-пакетов, что обеспечивает аутентификацию пакета и источника-отправителя пакета.

3 Инкапсуляция *IP*-пакета в новый защищенный *IP*-пакет с новым заголовком, содержащим *IP*-адрес устройства защиты, что маскирует топологию внутренней сети.

Защита информации при передаче между виртуальными подсетями реализуется на алгоритмах асимметричных ключей и электронной подписи, защи-

щающей информацию от подделки. Фактически данные, подлежащие межсегментной передаче, кодируются на выходе из одной сети, и декодируются на входе другой сети, а алгоритм управления ключами обеспечивает их защищенное распределение между оконечными устройствами. Все манипуляции с данными прозрачны для работающих в сети приложений. При этом возможно организовать защиту информации на любом уровне: защита трафика, то есть всей информации, передаваемой по каналу связи, например, между географически удаленными филиалами компании; между сервером и пользователем; между клиентами; организовать защищенный доступ мобильных пользователей в локальную сеть организации.

Защита телекоммуникационного оборудования

Важным аспектом защиты живучести компьютерных сетей является защита телекоммуникационного оборудования. В этой области практически все решения по обеспечению информационной безопасности ведутся на аппаратном уровне. Такой подход естественен и обусловлен автономностью функционирования современных средств телекоммуникации, которые по своей сложности не уступают, а иногда даже превосходят персональные компьютеры. Основные средства поддержки сетей телекоммуникаций – коммутаторы и маршрутизаторы – обладают высокими аппаратно-программными характеристиками, имея в своем составе несколько процессоров, работающих под управлением специализированной операционной системы реального времени и нескольких высокоскоростных сетевых интерфейсов. Они являются также аппаратной основой реализации упомянутых выше *VPN* сетей. С другой стороны, телекоммуникационное оборудование ответственно за качество обслуживания клиентов сетей передачи данных, которые требуют все большей пропускной способности сети для обмена аудио- и видео- информацией в реальном масштабе времени.

Встроенные системы безопасности современных пакетных коммутаторов и маршрутизаторов включают:

– средства защиты от широковещательных штормов в сетях;

– защиту данных на втором (канальном) и третьем (сетевом) уровнях модели *OSI*;

– многоуровневые средства безопасности при доступе через консольный порт, не позволяющие неавторизованным пользователям изменять конфигурацию устройства.

Встроенное программное обеспечение позволяет анализировать трафик на одном порту, в группе портов или во всем телекоммуникационном устройстве. Особо выделяются аппаратно-программные межсетевые экраны, обладающие, по сравнению с чисто программными реализациями, множеством достоинств. Например, продукт *Cisco PIX Firewall* (производитель *Cisco Systems*) обладает возможностями аппаратного аудита сетевых пакетов и номеров сетевых портов; аппаратного шифрования трафика; программно-аппаратной фильтрацией активных *Java* скриптов и *ActiveX*; аппаратной трансляцией сетевых адресов.

Защита речевых сообщений в сотовой связи

Сотовые системы мобильной связи нового поколения требуют обеспечения двух из основных функций безопасности: конфиденциальности и аутентификации. Конфиденциальность должна исключить возможность извлечения информации из каналов связи кем-либо, кроме санкционированного получателя. Функция аутентификации заключается в том, чтобы помешать кому-либо, кроме санкционированного пользователя (отправителя), изменить канал, то есть получатель должен быть уверен, что в настоящий момент он принимает сообщение от санкционированного пользователя. Основным способом обеспечения конфиденциальности является шифрование, и, относительно недавно, оно стало использоваться для задачи аутентификации. Аутентификация сообщений через шифрование осуществляется за счет включения в текст кода идентификации, то есть фиксированного, или зависящего от передаваемых данных слова, которое знают отправитель и получатель, или которое они могут выделить в процессе передачи. Получатель расшифровывает сообщение, путем сравнения получает удостоверение, что принимаемые данные являются именно данными санкционированного отправителя.

К системе шифрования речевых сообщений в сотовой связи предъявляются следующие основные требования:

– нелинейные связи между исходным текстом и зашифрованным текстом;

– изменение параметров шифрования во времени.

В сетях сотовой связи *GSM* механизмы аутентификации осуществляются с помощью переносимого мобильным пользователем модуля подлинности – *SIM* (*Security Identification Module*) карты. Она содержит международный идентификационный номер подвижного абонента, индивидуальный ключ аутентификации, алгоритм аутентификации. Благодаря заложенной в *SIM* карту информации в результате взаимного обмена данными между подвижной станцией и сетью осуществляется полный цикл аутентификации и разрешается доступ абонента к сотовой сети.

Для обеспечения конфиденциальности разговоров пользователей сети связи (*GSM),* все сообщения передаются в защищенном виде. *SIM* карта абонента содержит алгоритм формирования ключей шифрования. Кроме этого, для исключения идентификации абонента путем перехвата сообщений, передаваемых по радиоканалу, каждому абоненту системы связи присваивается «временное удостоверение личности» – временный международный идентификационный номер пользователя *TMSI*, который действителен только в пределах зоны расположения. В другой зоне расположения ему присваивается новый временный идентификатор *TMSI*. Если абоненту еще не присвоен временный номер (например, при первом включении подвижной станции), идентификация проводится через международный идентификационный номер *IMSI*. После окончания процедуры аутентификации и начала режима шифрования временный идентификационный номер *TMSI* передается на подвижную станцию только в зашифрованном виде. Этот *TMSI* будет использоваться при всех последующих доступах к системе. Если подвижная станция переходит в новую область расположе-

ния, то ее *TMSI* должен передаваться вместе с идентификационным номером зоны, в которой *TMSI* был присвоен абоненту.

Глава 3. Криптографические методы защиты информации

3.1 Основные понятия криптографии

Проблема защиты информации путем ее преобразования, исключающего ее прочтение посторонним лицом, волновала человеческий ум с древних времен. Если вы хотите передать свое текстовое сообщение (последовательность символов некоторого алфавита) адресату так, чтобы оно осталось тайным для посторонних лиц, в этом случае у вас есть, по крайней мере, две возможности. Вы можете попытаться скрыть сам факт передачи текста, то есть прибегнуть к методам *стеганографии*, в арсенале которой - симпатические (невидимые) чернила, микроточки и тому подобные средства. Другая возможность заключается в попытке скрыть смысл сообщения от посторонних лиц, случайно или намеренно познакомившихся с передаваемым текстом. В этом случае вы можете прибегнуть к методам *криптографии*. Термин «криптография» происходит от двух греческих слов: «криптос» - тайна и «графейн» - писать, и означает тайнопись. «Тайнопись» как раз и подразумевает, что вы скрываете смысл своего сообщения.

История криптографии – ровесница истории человеческого языка. Более того, первоначально письменность сама по себе была криптографической системой, так как в древних обществах ею владели только избранные. Примером этого являются священные книги Древнего Египта, Древней Индии.

С широким распространением письменности криптография стала формироваться как самостоятельная наука. Первые криптосистемы встречаются уже в начале нашей эры. Так, Цезарь в своей переписке использовал уже систематический шифр, получивший его имя.

Большое развитие криптографические системы получили в годы первой и второй мировых войн прошлого века. Появление вычислительных средств ускорило разработку и совершенствование криптографических методов.

В настоящий момент проблема использования криптографических методов в информационных системах (ИС) стала особо актуальна.

С одной стороны, расширилось использование компьютерных сетей, в частности глобальной сети Интернет, по которым передаются большие объемы информации государственного, военного, коммерческого и частного характера, не допускающего возможность доступа к ней посторонних лиц.

С другой стороны, появление новых мощных компьютеров, технологий сетевых и нейронных вычислений сделало возможным дискредитацию криптографических систем еще недавно считавшихся практически не раскрываемыми.

Проблемой защиты информации путем ее преобразования занимается *криптология* (kruptos – тайный, logos – наука). Этот термин используется для обозначения всей области секретной связи. Криптология разделяется на два направления – *криптографию* и *криптоанализ*.

Криптография занимается поиском и исследованием математических методов преобразования информации. Криптографическое преобразование это метод предупреждения несанкционированного доступа к информации. В настоящее время разработано большое количество различных методов шифрования, созданы теоретические и практические основы их применения. Подавляющее число этих методов может быть успешно использовано и для закрытия информации с помощью ЭВМ.

В качестве информации, подлежащей шифрованию и дешифрованию, будем рассматривать *тексты*, построенные на некотором *алфавите*.

Алфавит – это конечное множество знаков используемых для кодирования информации.

Текст – упорядоченный набор из элементов алфавита.

Примеры алфавитов, используемых в современных ИС:

- алфавит Z_{33} – 32 буквы русского алфавита, за исключением буквы Ё и пробел;
- алфавит Z_{256} – символы, входящие в стандартные коды ASCII и КОИ-8;
- бинарный алфавит – $Z_2 = \{0,1\}$;
- восьмеричный алфавит или шестнадцатеричный алфавит.

Шифрование – преобразование *исходного текста,* который носит также название *открытого текста*, в *шифрованный текст (шифротекст или криптограмму)*.

Дешифрование или вскрытие шифра – процесс восстановления открытого текста по шифрованному тексту при неизвестном ключе.

Расшифрование – процесс восстановления исходного текста при известном ключе.

Ключ – информация, необходимая для беспрепятственного шифрования и расшифрования текстов.

Криптография дает возможность преобразовать информацию таким образом, что ее прочтение (восстановление) возможно только при знании ключа.

Криптоанализ – исследование возможности расшифрования информации без знания ключей.

В настоящее время криптография бурно развивается, в ней появляются новые направления. С 1976 года развивается «открытая криптография», особенностью которой является разделение ключей для зашифрования и расшифрования. При этом ключ для зашифрования не требуется делать секретным, поэтому его называют открытым ключом, более того, он может быть общедоступным и содержаться в телефонном справочнике вместе с фамилией и адресом его владельца.

Криптографические методы защиты информации в автоматизированных системах могут применяться и для защиты информации, обрабатываемой в ЭВМ или хранящейся в различного типа запоминающих устройствах, и для закрытия информации, передаваемой между различными элементами системы по линиям связи.

Для удобства дальнейшего изложения обозначим буквой A - открытое сообщение, B - шифрованное сообщение, f- правило шифрования, g - правило расшифрования. В этом случае зашифрование открытого сообщения A в шифрованное сообщение B можно записать в виде $f(A)=B$. Обратное преобразование (то есть получение открытого сообщения A путем расшифрования B) запишется в виде соотношения $g(B)=A$. Правило зашифрования f не может быть произвольным. Оно должно быть таким, чтобы по шифртексту B с помощью правила расшифрования g можно было однозначно восстановить открытое сообщение A.

Однотипные правила зашифрования можно объединить в классы. Внутри класса правила различаются между собой по значениям некоторого параметра, которое может быть числом, таблицей и т.д. В криптографии конкретное значение такого параметра обычно называют ключом. По сути дела, ключ соответствует конкретному правилу зашифрования из данного класса правил. Зачем нужен ключ? Во-первых, обычно шифрование производится с использованием специальных устройств. Должна быть возможность изменять значение параметров устройства, чтобы зашифрованное сообщение не смогли расшифровать даже лица, имеющие точно такое же устройство, но не знающие выбранного вами значения параметра. Во-вторых, многократное использование одного правила зашифрования f для открытых текстов создает предпосылки для получения открытых сообщений по шифртексту без знания правил расшифрования g. Поэтому необходимо своевременно менять правило зашифрования. Используя понятие ключа, процесс зашифрования можно описать в виде соотношения $f_a(A)=B$, в котором a - выбранный ключ, известный отправителю и адресату. Для каждого ключа a шифропреобразование f_a должно быть обратимым, то есть должно существовать обратное преобразование g_a, которое при выбранном ключе a однозначно определяет открытое сообщение A по шифрованному сообщению B: $g_a(B)=A$. Совокупность преобразований f_a и набор ключей, которым они соответствуют, будем называть *шифром*. Среди всех шифров можно выделить два больших класса: шифры замены и шифры перестановки.

Стойкость шифра - способность противостоять попыткам провести его вскрытие. При анализе шифра обычно исходят из принципа, сформулированного голландцем Огустом Керкгоффсом (1835-1903). Согласно этому принципу при вскрытии криптограммы противнику известно о шифре все, кроме используемого ключа. Одной из естественных характеристик шифра является число его возможных ключей. Ведь вскрытие шифра можно осуществлять перебором всех возможных его ключей.

Часто смешивают понятия: *шифрование* и *кодирование*. Для шифрования надо знать шифр и секретный ключ. При кодировании нет ничего секретного, есть только определенная замена букв или слов на заранее определенные символы. Методы кодирования направлены не на то, чтобы скрыть открытое сообщение, а на то, чтобы представить его в более удобном виде для передачи по техническим средствам связи, для уменьшения длины сообщения и т.д. В прин-

ципе, кодирование, конечно же, можно рассматривать как шифр замены, для которого «набор» возможных ключей состоит только из одного ключа (например, буква «а» в азбуке Морзе всегда кодируется знаками • — и это не является секретом).

В настоящее время для защиты информации широко используются электронные шифровальные устройства. Важной характеристикой таких устройств является не только стойкость реализуемого шифра, но и высокая скорость осуществления процессов шифрования и расшифрования. Для создания и обеспечения грамотной эксплуатации такой техники широко используются достижения современной криптографии, в основе которой лежат математика, информатика, физика, электроника и другие науки.

3.2 Разновидности шифров

3.2.1 Шифры замены

Шифром замены называется алгоритм шифрования, который приводит к замене каждого символа открытого сообщения на другие символы - *шифробозначения*, причем порядок следования шифробозначений совпадает с порядком следования соответствующих им символов открытого сообщения. Символами могут быть как буквы соответствующего алфавита, так и числа. В качестве примера преобразования, которое может содержаться в шифре замены, приведем такое правило: каждая буква исходного сообщения заменяется ее порядковым номером в алфавите. В этом случае исходный буквенный текст преобразуется в числовой. Сообщение расшифровывается путем обратной замены.

Виды шифров замены.

1. Простая замена. Каждый символ открытого текста заменяется одним символом шифротекста.
2. Омофонная (многозначная) замена. Каждому символу открытого текста ставится в соответствие несколько символов шифротекста.
3. Блочная замена. Шифрование производится блоками.
4. Много алфавитная замена. Состоит из нескольких шифров простой замены.

Шифры простой замены. Классическим примером шифра замены в художественной литературе является известный шифр «Пляшущие человечки» Конан Дойля. В нем буквы текста заменялись символическими фигурками людей. Ключом этого шифра являлись позы человечков, заменяющих буквы.

Историческим примером шифра замены является шифр Цезаря, которым пользовался Гай Юлий Цезарь, описанный историком Древнего Рима Светонием. Применительно к современному русскому языку этот шифр состоит в следующем: буквы исходного сообщения заменяются буквами того же алфавита циклически сдвинутого на 3 буквы влево. Например, единичный сдвиг влево русского алфавита приведет к тому, что буква А станет последней и последовательность букв будет следующая БВГДЕЖЗИЙКЛМНОПРСТУФХЦЧШЩЪЫЬЭЮЯА. Циклический сдвиг русского алфавита на 3 буквы влево представлен во второй строке табл. 1. Шифрование по Цезарю происходит согласно табл. 1.

Таблица 1

А	**Б**	**В**	**Г**	**Д**	**Е**	**Ж**	**З**	**И**	**Й**	**К**	**Л**	**М**	**Н**	**О**	**П**	**Р**	**С**	**Т**	**У**	**Ф**	**Х**	**Ц**	**Ч**	**Ш**	**Щ**	**Ъ**	**Ы**	**Ь**	**Э**	**Ю**	**Я**
Г	**Д**	**Е**	**Ж**	**З**	**И**	**Й**	**К**	**Л**	**М**	**Н**	**О**	**П**	**Р**	**С**	**Т**	**У**	**Ф**	**Х**	**Ц**	**Ч**	**Ш**	**Щ**	**Ъ**	**Ы**	**Ь**	**Э**	**Ю**	**Я**	**А**	**Б**	**В**

Данная таблица является ключом шифра замены. Зная ее, можно осуществить как зашифрование, так и расшифрование. При шифровании буква А заменяется буквой Г, Б – Д, В – Е и т.д. Так, например слово РАЗУМ превращается в слово УГКЦП.

Примечание: можно делать сдвиг не на три, а на произвольное количество букв. При алфавитном порядке расположения заменяющего алфавита всего ключей может быть 32 (число букв в русском алфавите за исключением буквы Ё). При произвольном расположении букв замены число ключей =32!

Шифр «Альбам». Этот шифр заключается в разбиении алфавита на 2 части и подписыванием одной части под другой.

Таблица 2

А	**Б**	**В**	**Г**	**Д**	**Е**	**Ж**	**З**	**И**	**Й**	**К**	**Л**	**М**	**Н**	**О**	**П**
Р	**С**	**Т**	**У**	**Ф**	**Х**	**Ц**	**Ч**	**Ш**	**Щ**	**Ъ**	**Ы**	**Ь**	**Э**	**Ю**	**Я**

Замена имеет симметричный характер: (А-Р, Р-А), (Б-С, С-Б) и т.д. Так, слово РАЗУМ при использовании шифра «Альбам» превращается в слово АРЧГЬ. Табл. 2 является ключом шифра «Альбам».

Шифр «Атбаш». Этот шифр применялся в «Ветхом Завете». Замена имеет симметричный характер, применительно к русскому алфавиту шифр «Атбаш» задается следующим образом: (А-Я, Я-А), (Б-Ю, Ю-Б) и т.д. В этом случае слово РАЗУМ превращается в слово ПЯШМУ. Табл. 3 является ключом шифра «Атбаш».

Таблица 3

А	**Б**	**В**	**Г**	**Д**	**Е**	**Ж**	**З**	**И**	**Й**	**К**	**Л**	**М**	**Н**	**О**	**П**
Я	**Ю**	**Э**	**Ь**	**Ы**	**Ъ**	**Щ**	**Ш**	**Ч**	**Ц**	**Х**	**Ф**	**У**	**Т**	**С**	**Р**

Другим примером шифра замены может служить лозунговый шифр. Здесь запоминание ключевой последовательности основано на лозунге - легко запоминаемом слове. Например, выберем слово - лозунг «учебник» и заполним вторую строку таблицы по следующему правилу: сначала выписываем слово - лозунг, а затем выписываем в алфавитном порядке буквы алфавита, не вошедшие в слово-лозунг.

Таблица 4

у	**ч**	**е**	**б**	**н**	**и**	**к**	**а**	**в**	**г**	**д**	**ж**	**з**	**й**	**л**	**м**
о	**п**	**р**	**с**	**т**	**ф**	**х**	**ц**	**ш**	**щ**	**ъ**	**ф**	**ь**	**э**	**ю**	**я**

Ключом шифра является последовательность букв в слове «учебник» и дальнейшее смещение букв алфавита. В данном случае число вариантов ключа существенно больше числа букв алфавита.

Если с помощью шифра простой замены зашифровано длинное сообщение, его можно прочесть, не имея ключа. Дело в том, что частоты появления символов в шифрованном тексте будут совпадать с частотами появления соот-

ветствующих им символов в исходном тексте. Поэтому для дешифрования достаточно подсчитать относительные частоты встречаемости различных символов в шифрованном сообщении и сравнить их с вероятностями встречаемости букв в текстах, приведенными в табл. 5. и табл.6.

Таблица 5

Вероятность букв в русских текстах

буква	**Аа**	**Бб**	**Вв**	**Гг**	**Дд**	**Е,Ё**	**Жж**	**Зз**	**Ии**	**Йй**	**Кк**
вер-ть	0.069	0.013	0.038	0.014	0.024	0.071	0.007	0.016	0.064	0.010	0.029
буква	**Лл**	**Мм**	**Нн**	**Оо**	**Пп**	**Рр**	**Сс**	**Тт**	**Уу**	**Фф**	**Хх**
вер-ть	0.039	0.027	0.057	0.094	0.026	0.042	0.046	0.054	0.023	0.003	0.008
буква	**Цц**	**Чч**	**Шш**	**Щщ**	**Ъ**	**Ы**	**Ь**	**Ээ**	**Юю**	**Яя**	
вер-ть	0.005	0.012	0.006	0.004	0.001	0.015	0.013	0.002	0.005	0.017	0.146

В табл. 5 даны оценки вероятностей появления букв русского языка и пробела, полученные на основе анализа научно-технических и художественных текстов общим объемом более 1 000 000 символов.

Таблица 6

Вероятность букв в английских текстах

буква	**Aa**	**Bb**	**Cc**	**Dd**	**Ee**	**Ff**	**Gg**	**Hh**	**Ii**
вер-ть	0.064	0.013	0.025	0.028	0.097	0.076	0.013	0.04	0.056
буква	**Jj**	**Kk**	**Ll**	**Mm**	**Nn**	**Oo**	**Pp**	**Qq**	**Rr**
вер-ть	0.001	0.039	0.031	0.017	0.057	0.062	0.018	0.002	0.047
буква	**Ss**	**Tt**	**Uu**	**Vv**	**Ww**	**Xx**	**Yy**	**Zz**	
вер-ть	0.052	0.076	0.018	0.007	0.016	0.002	0.015	0.001	0.185

Для того чтобы установить однозначное соответствие между символами алфавита и символами зашифрованного сообщения, исходя только из анализа частоты появления символов, нужен очень большой текст. Поэтому задача дешифрования шифра простой замены в случае небольших текстов не имеет простого алгоритма решения. Если шифрованное сообщение написано без пробелов между символами, возникают дополнительные трудности при разбиении шифротекста на отдельные символы и слова.

Шифры омофонной замены использовал Бенджамин Франклин. В современном понимании шифр Франклина является шифром пропорциональной замены, в котором количество возможных шифробозначений пропорционально частоте встречаемости букв в открытом тексте.

Блочный шифр характеризуется тем, что в нем текст делится на блоки и проводится простая замена блоков.

Блочные шифры, в которых заменялись пары букв, применяли во время второй мировой войны немцы в линиях связи. При шифровании открытый текст разбивался на блоки по две буквы, например

КР ИП ТО ГР АФ ИЯ.

Ключом являлись два квадрата, в которых записывался алфавит в произвольном порядке рис. 1. Первая буква выбиралась в левом квадрате, вторая – в пра-

вом. Мысленно строился прямоугольник, и в шифротекст включались буквы из незанятых его углов. В данном случае вместо К – Ж, вместо Р – Ф и т.д.

ы	щ	э	ю	ь
м	б	г	д	е
в	ж	и	з	к
л	с	н	о	п
а	т	р	у	ф
х	ц	ч	ш	я

ц	ю	э	ч	ъ
е	м	н	о	ш
ж	л	к	п	щ
б	в	а	г	д
р	з	и	ф	я
с	т	у	х	ы

Рис.1

Если буквы оказывались на одной строке, то буква заменялась буквой той же позиции, но из другого квадрата. Слово КРИПТОГРАФИЯ после зашифрования имело вид ЖФКЗФБЕРРУЩР. Преимущество такого шифра достаточная проста и быстрота зашифровывания и расшифровывания, отсутствие потребности в словарях, простота в смене ключевых квадратов.

Когда длина блока велика, таблица замены становится необозримой и саму замену приходиться задавать не таблицей, а некоторым алгоритмом преобразования. Примером этому служит шифр **DES** (*Data Encryption Standard*).

Шифры многоалфавитной замены могут, например, использовать пять шифров простой замены, а какой из них конкретно применяется для шифрования данной буквы открытого текста – зависит от ее положения в тексте.

Наибольшее распространение получил алгоритм многоалфавитной замены с использованием таблицы Виженера, которая представляет собой квадратную матрицу $R \times R$, R – количество символов в используемом алфавите. В первой строке располагаются символы в алфавитном порядке. Начиная со второй строки, символы записываются с циклическим сдвигом на одну позицию влево. Для русского алфавита матрица Виженера имеет вид, представленный на рис. 2.

$$\begin{pmatrix}
А & Б & В & Г & Д & Е & Ж & З & И & Й & К & Л & М & О & П & Р & С & Т & У & Ф & Х & Ц & Ч & Ш & Щ & . & . & . & Ю & Я & _ \\
Б & В & Г & Д & Е & Ж & З & И & Й & К & Л & М & О & П & Р & С & Т & У & Ф & Х & Ц & Ч & Ш & Щ & Ъ & . & . & . & Я & _ & А \\
В & Г & Д & Е & Ж & З & И & К & Л & М & Н & О & П & Р & С & Т & У & Ф & Х & Ц & Ч & Ш & Щ & Ъ & Ы & . & . & . & _ & А & Б \\
. & . & . & . & . & . & . & . & . & . & . & . & . & . & . & . & . & . & . & . & . & . & . & . & . & . & . & . & . & . & . \\
_ & А & Б & В & Г & Д & Е & Ж & З & И & Й & К & Л & М & Н & О & П & Р & С & Т & У & Ф & Х & Ц & Ш & . & . & . & Э & Ю & Я
\end{pmatrix}$$

Рис.2

Шифрование осуществляется с помощью ключа, состоящего из М неповторяющихся символов. Из матрицы Виженера выделяется матрица шифрования размерностью $(M+1) \times R$, включающая первую строку и строки первые элементы, которых совпадают с символами ключа. Пусть в качестве ключа взято слово «книга», тогда матрица шифрования имеет вид, представленный на рис.3.

а	б	в	г	д	е	ж	з	и	й	к	л	м	н	о	п	р	с	…	я	
к	л	м	н	о	п	р	с	т	у	ф	х	ц	ч	ш	щ	ъ	ы	…	и	й
н	о	п	р	с	т	у	ф	х	ц	ч	ш	щ	ъ	ы	ь	э	ю	…	л	м
и	й	к	л	м	н	о	п	р	с	т	у	ф	х	ц	ч	ш	щ	…	ж	з
г	д	е	ж	з	и	й	к	л	м	н	о	п	р	с	т	у	ф	…	б	в
а	б	в	г	д	е	ж	з	и	й	к	л	м	н	о	п	р	с	…	я	

Рис.3

Зашифруем исходный текст «Солнечный день».

С	О	Л	Н	Е	Ч	Н	Ы	Й		Д	Е	Н	Ь
К	Н	И	Г	А	К	Н	И	Г	А	К	Н	И	Г
Ы	Ы	У	Р	Е	А	Ъ	В	М		О	Т	Х	Я

Рис.4

Ы Ы У Р Е А Ъ В М _ О Т Х Я - шифротекст.

Стойкость методов много алфавитной замены выше методов простой замены, так как одни и те же символы исходной последовательности могут заменяться разными.

3.2.2 Шифры перестановки

Шифром перестановки называется алгоритм шифрования, который приводит к изменению только порядка следования символов исходного сообщения. Примером преобразования, которое может содержаться в шифре перестановки, является следующее правило. Каждая буква исходного сообщения, стоящая в тексте на позиции с четным номером, меняется местами с предшествующей ей буквой. В этом случае ясно, что и исходное, и шифрованное сообщение состоят из одних и тех же букв.

Например: МАМА - АМАМ. КРИПТОГРАФИЯ - ИПКРГРТОИЯАФ. (ИП↔КР ГР↔ТО ИЯ↔АФ)

Широкое распространение получили шифры перестановки, использующие некоторую геометрическую фигуру. Преобразования этого шифра состоят в том, что исходный текст вписывается в фигуру по ходу одного «маршрута», а затем по ходу другого выписывается из нее. Такой шифр называют маршрутной перестановкой или маршрутной транспозицией. В шифре простой колонной перестановки исходный открытый текст записывается построчно в прямоугольник (число букв в строке фиксировано), шифротекст получается считыванием букв по колонкам. Расшифрование производится аналогично: шифротекст записывается поколонно, а открытый текст можно затем причесть по горизонтали.

В О С К Р Е
А М Я А Н С
Т Е М А Т И
Я А К С Е Ч
Ш К О Л А Т

Рис.5

Например, фраза "Воскресная математическая школа" становится: "ЕСИЧТ АЕТНР КААСЛ ОКМЯС ОМЕАК ШЯТАВ". Ключ - число 6. Т - дополнительная буква.

Теоретически маршруты могут быть значительно более изощренными, однако запутанность маршрутов усложняет использование таких шифров.

Широко распространен вид шифра маршрутной перестановки, называемый шифром вертикальной перестановки (ШВП). В нем вновь используется прямоугольник, в который сообщение вписывается по строкам слева направо.

Выписываются буквы по вертикали, а столбцы при этом берутся в порядке, определяемом ключом. Пусть, например, этот ключ таков: (5,4,1,7,2,6,3,8), и с его помощью надо зашифровать сообщение: ВОТПРИМЕРШИФРАВЕРТИКАЛЬНОЙПЕРЕСТАНОВКИ. Впишем сообщение в прямоугольник, столбцы которого пронумерованы в соответствии с ключом:

5	1	4	7	2	6	3	8
В	О	Т	П	Р	И	М	Е
Р	Ш	И	Ф	Р	А	В	Е
Р	Т	И	К	А	Л	Ь	Н
О	Й	П	Е	Р	Е	С	Т
А	Н	О	В	К	И		

Рис.6

Теперь, выбирая столбцы в порядке, заданном ключом, и выписывая последовательно буквы каждого из них сверху вниз, получаем такую криптограмму:

ОШТЙНРРАРКМВЬС_ТИИПОВРРОАИАЛЕИПФКЕВЕЕНТ_

Число ключей ШВП не более m!, где m - число столбцов таблицы. Как правило, m гораздо меньше, чем длина текста n (сообщение укладывается в несколько строк по m букв), а, значит, и m! много меньше n!.

В случае, когда ключ ШВП не рекомендуется записывать, его можно извлекать из какого-то легко запоминающегося слова или предложения.

Для этого существует много способов. Наиболее распространенный способ, когда буквам приписывают числа в соответствии с обычным алфавитным порядком букв. Например, пусть ключевым словом будет ПЕРЕСТАНОВКА. Присутствующая в нем буква А получает номер 1. Если какая-то буква входит несколько раз, то ее появления нумеруются последовательно слева направо. Поэтому второе вхождение буквы А получает номер 2. Поскольку буквы Б в этом слове нет, то буква В получает номер 3 и так далее. Процесс продолжается до тех пор, пока все буквы не получат номера.

Таким образом, мы получаем следующий ключ:

П Е Р Е С Т А Н О В К А

9 4 10 5 11 12 1 7 8 3 6 2

Рис.7

Для повышения стойкости полученный шифротекст можно подвергнуть шифру перестановки повторно. Существуют еще более сложные шифры перестановки, однако почти все они легко взламываются с помощью компьютера.

Не смотря на то, что во многих современных криптографических алгоритмам и используется перестановка, ее применение ограничено узкими рамками, так как в этом случае требуется память большого объема и накладываются ограничения на длину шифруемых сообщений.

3.2.3.Шифры гаммирования.

Более полувека назад К. Шеннон дал следующее определение совершенного шифра: это шифр, при использовании которого перехват криптограммы не дает противнику никакой информации о передаваемом сообщении, даже если противник обладает неограниченными вычислительными ресурсами [25].

Приведем пример такого шифра. Пусть имеется сообщение $t_1,\ldots,t_n$, представляющее собой последовательность символов из алфавита **A**, состоящего, как и ранее, из 32 букв русского языка и пробела (буквы Е и Ё не различаются). Ключ **K** представляет собой последовательность чисел $k_1,\ldots,k_n$ из множества чисел **M**={0,…,32}. Зашифрованный текст $s_1,\ldots,s_n$ вычисляется по следующей формуле:

$$s_i=(C(t_i)+k_i)\bmod 33,\ i=1,\ldots,n, \qquad (1)$$

где C: **A** → **M** – функция, отображающая символ в его порядковый номер. Запись $d=(a+b)\bmod m$ означает, что d совпадает с остатком от деления на m суммы чисел a и b, например, $1=(4+7)\bmod 10$.

Расшифровать сообщение можно с помощью формулы:

$$t_i=C^{-1}((s_i+(33-k_i))\bmod 33),\ i=1,\ldots,n, \qquad (2)$$

В данном случае через C^{-1} обозначается функция, отображающая число из множества от 0 до 32 в символ (букву или пробел) с соответствующим номером.

Будем предполагать, что ключ выбирается случайно равновероятно из $\mathbf{M}^n$ – множества векторов длины n, координаты которых принимают значения из **M** (или то же самое, что каждый из элементов ключа k_i, $i=1,\ldots,n$, выбирается случайно равновероятно и независимо из **M**).

Определенный таким образом шифр называется шифром гаммирования со случайной равновероятной гаммой (*гаммой принято называть последовательность чисел $k_1,\ldots,k_n$, складываемую по модулю с шифруемым сообщением*).

При таком методе шифрования количество символов в криптограмме совпадает с количеством символов сообщения, то есть совпадают их длины. Чтобы скрыть от противника длину сообщения, его можно дополнить пробелами до некоторой фиксированной длины, которую не превосходит стандартное сообщение. В приведенном ниже примере, мы будем дополнять сообщения до 10 символов.

Зашифруем с помощью описанного выше шифра гаммирования сообщение "ПОКУПАТЬ" на ключе "05 12 03 29 24 12 30 14 11". Для этого, заменим буквы нашего сообщения их порядковыми номерами (воспользовавшись табл. 7 получим табл. 8) и сложим полученные номера с элементами ключевой последовательности по модулю 33:

Таблица 7

А	**Б**	**В**	**Г**	**Д**	**Е**	**Ж**	**З**	**И**	**Й**	**К**	**Л**	**М**	**Н**	**О**	**П**	**Р**
00	01	02	03	04	05	06	07	08	09	10	11	12	13	14	15	16
С	**Т**	**У**	**Ф**	**Х**	**Ц**	**Ч**	**Ш**	**Щ**	**Ъ**	**Ы**	**Ь**	**Э**	**Ю**	**Я**		
17	18	19	20	21	22	23	24	25	26	27	28	29	30	31	32	

Таблица 8

П	О	К	У	П	А	Т	Ь	
15	14	10	19	15	00	18	28	32

15 14 10 19 15 00 18 28 32 – шифруемое сообщение в цифровом виде;
<u>05 12 03 29 24 12 30 14 11</u> – ключ;
20 26 13 15 06 12 15 09 10 – результат шифрования.

Получаем такую криптограмму: ФЪНПЖМПЙК

Криптоаналитик противника, зная алгоритм шифрования и имея зашифрованный текст, но, не имея ключа, не сможет извлечь для себя никакой другой информации, кроме самого факта передачи сообщения. Делая разные предположения о ключе, криптоаналитик будет получать разные открытые тексты. Изменяя значение k_i от 0 до 32, он получит все возможные значения i-го символа открытого текста, независимо от значения i-го символа криптограммы. Таким образом, из любого шифрованного текста можно получить произвольный текст такой же длины. В частности, если предположить, что был выбран ключ, удовлетворяющий соотношению $k_i=(33-C(t_i)+s_i)\mathrm{mod}\ 33$, $i=1,\ldots,n$, криптограмма $s_1,\ldots,s_n$ будет расшифрована в сообщение $t_1,\ldots,t_n$. Например, если использовать ключ "28 23 01 22 27 23 18 09 18", криптограмма "20 26 13 15 06 12 15 09 10" будет дешифрована в сообщение "ПРОДАВАТЬ" – прямо противоположное по смыслу исходному ("ПОКУПАТЬ"). Так как ключи выбирались случайно равновероятно, криптоаналитик противника на основе шифротекста не сможет отдать предпочтение ни одному из возможных сообщений из девяти символов (всего их 33^9). Единственное, что может сделать противник в данном случае – это отсортировать сообщения на более вероятные и менее вероятные, исходя из анализа обстановки.

Предположим, что ключ $K=(Y_1,Y_2,Y_3)$ состоит их трех чисел, выбранных случайно равновероятно и независимо из множества $\{0,\ldots,32\}$. С помощью рекуррентного соотношения $Y_t=(Y_{t-1}+Y_{t-3})\mathrm{mod}\ 33$ порождаются элементы последовательности $Y_1,\ldots,Y_{n+1}$ для $t>3$. Затем по формуле

$$Z_t=(Y_t+Y_{t+1})\mathrm{mod}\ 33,\ \ t=1,\ldots,n, \qquad (3)$$

вычисляется псевдослучайная последовательность $Z_1,\ldots,Z_n$, используемая вместо случайной гаммы. Как и в предыдущем примере, шифрование заключается в сложении по модулю 33 элементов гаммы с порядковыми номерами символов шифруемого текста, полученными из табл. 7.

Зашифруем на ключе K=(04,31,15) сообщение

«ВЫДАЧУ КРЕДИТОВ ПРЕКРАТИТЬ»

Рекуррентная последовательность $Y_1,\ldots,Y_{n+1}$ в данном случае будет иметь вид: "04 31 15 19 17 32 18 02 01 19 21 22 08 29 18 26 22 07 00 22 29 29 18 14 10 28 09".

Сложим по модулю 33 порядковые номера символов нашего сообщения с элементами псевдослучайной последовательности (гаммы), полученной по формуле (3):

02 27 04 00 23 19 32 10 16 05 04 08 18 14 02 32 15 16 05 10 16 00 18 08 18 28
<u>02 13 01 03 16 17 20 03 20 07 10 30 04 14 11 15 29 07 22 18 25 14 32 24 05 04</u>
04 07 05 03 06 03 19 13 03 12 14 05 22 28 13 14 11 23 27 28 08 14 17 32 23 32
Получаем такую криптограмму:

ДЗЕГЖГУНГМОЕЦЬНОЛЧЫЬИОС_Ч_

Общее число возможных текстов из 26 символов составляет 33^{26}, а количество различных ключей в данном случае 33^3= 35937. Следовательно, количество возможных вариантов расшифрования при неизвестном ключе не превосходит 35937. Таким образом, криптоаналитик имеет 35937 вариантов сообщения, из которых он должен выбрать единственный правильный. Возникает вопрос – можно ли вообще отличить настоящее сообщение от ошибочных вариантов? Если сообщение представляет собой осмысленный текст на русском языке, то его видимо удастся отличить от ложных, так как, из 33^{26} слов из рассматриваемого алфавита осмысленными текстами является только малая часть. Согласно исследованиям, проведенным еще К. Шенноном [24], осмысленных текстов из 20 букв на английском языке порядка 10^6. Приблизительно такая же оценка справедлива и для русского языка.

Ключ может быть подобран, так что после зашифрования сообщение будет представлять совершенно безобидный осмысленный текст. Например, сообщение «ВЫДАЧУ КРЕДИТОВ ПРЕКРАТИТЬ» при использовании гамма равной 13 20 03 04 26 14 03 01 15 00 08 24 17 19 15 00 00 00 28 30 21 13 23 02 29 17 будет зашифровано в сообщение «ПОЗДРАВЛЯЕМ ВАС ПРАЗДНИКОМ»

3.3 Системы шифрования с закрытым и открытым ключом

Систему шифрования с закрытым ключом называют также системой с симметричным ключом. Схема криптографического преобразования с симметричным ключом предполагает наличие одного закрытого ключа (КЗ), как у Отправителя, так и у Получателя рис.8.

Отправитель на закрытом ключе КЗ зашифровывает передаваемое сообщение М с помощью определенного криптографического алгоритма и, в зашифрованном виде, отправляет его Получателю. Алгоритм криптографического преобразования определяется соответствующим стандартом. Получатель с помощью точно такого же закрытого ключа КЗ и криптографического алгоритма расшифровывает (восстанавливает) принятое шифрованное сообщение М(К). Такая криптосистема обладает хорошей устойчивостью к дешифрованию.

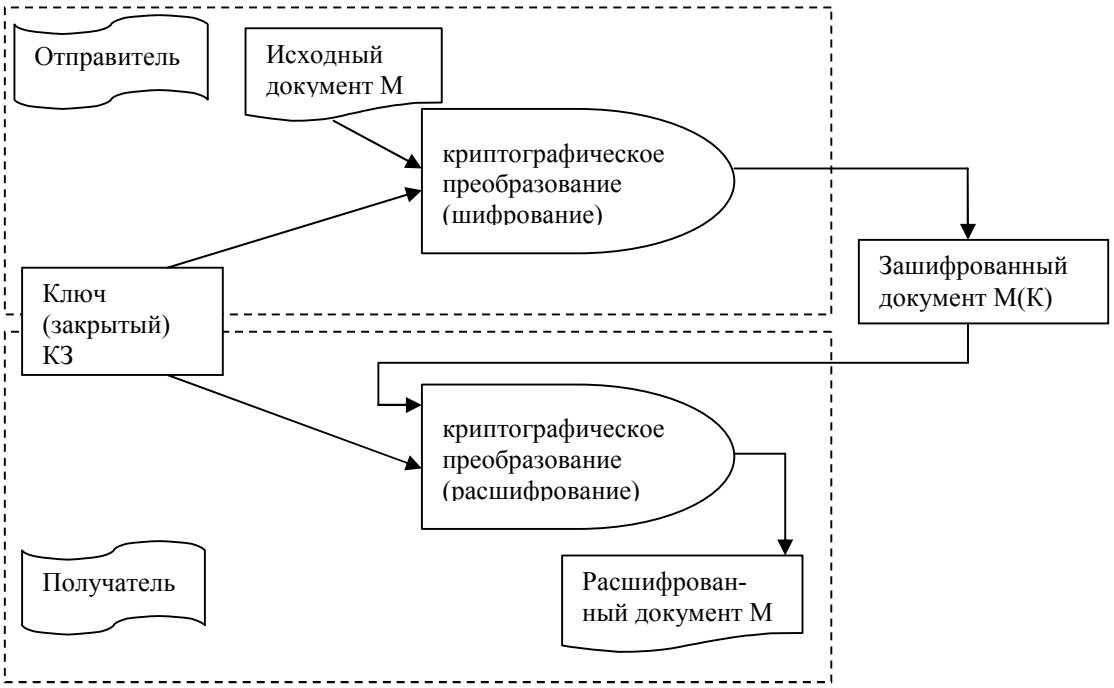

Рис.8. Схема криптографического преобразования с симметричным ключом

Основные недостатки систем шифрования с симметричным – секретным ключом в том, что закрытым ключом владеют минимум два человека, совершающие обмен секретными сообщениями, при компрометации ключа у одного из них, компрометируется вся система в целом. Это приводит также к тому, что в такой криптографической системе невозможно определить, кто ответственен за компрометацию закрытого ключа.

Другой недостаток – это необходимость распределения секретных ключей связан с тем, что защита от подделки сообщений с помощью имитовставки, полученной на симметричном ключе, не обеспечивает защиту информации от подделки одним из владельцев секретного ключа. Это приводит к тому, что недобросовестный участник информационного обмена может сфабриковать якобы полученное сообщение, либо отказаться от сообщения, посланного им самим.

Эти проблемы позволяет решить криптография с открытым ключом.

В основе применения систем с открытым ключом лежит использование необратимых или односторонних функций.

Предположим, что имеется пара преобразований КЗ и КО, удовлетворяющих условиям:

1. Для любого сообщения x выполняется равенство КО (КЗ (x))=x.
2. КЗ и КО легко вычисляются для любых исходных данных.
3. Преобразования КЗ и КО сложно обратить, то есть зная КО и x трудно получить КЗ(x), а зная КЗ и КЗ(x) нельзя получить КО (КЗ(x)).

В данном случае преобразование КЗ обеспечивает шифрование информации, а КО – расшифрование. Для того чтобы обеспечить секретную связь между абонентами A_1 и A_2, нужно чтобы каждый из них создал свою пару преобразо-

ваний. Абонент A_1: КЗ $_1$, КО $_1$ и абонент A_2: КЗ $_2$, КО $_2$, и передал своему корреспонденту преобразование для расшифрования $КО_i$ (при этом каждый из абонентов должен держать в секрете свои ключи расшифрования $КЗ_i$). Информация шифруется с использованием закрытого ключа КЗ, а расшифровывается с использованием открытого ключа КО.

Рис.9. Обмен открытыми ключами при секретной связи

Зашифрованное абонентом $\mathbf{A_1}$ сообщение КЗ $_1(x)$ сможет расшифровать владелец ключа расшифрования КО $_1$ – абонент $\mathbf{A_2}$. В свою очередь абонент $\mathbf{A_2}$ шифрует свои сообщения с помощью закрытого ключа $КЗ_2$, принадлежащего ему.

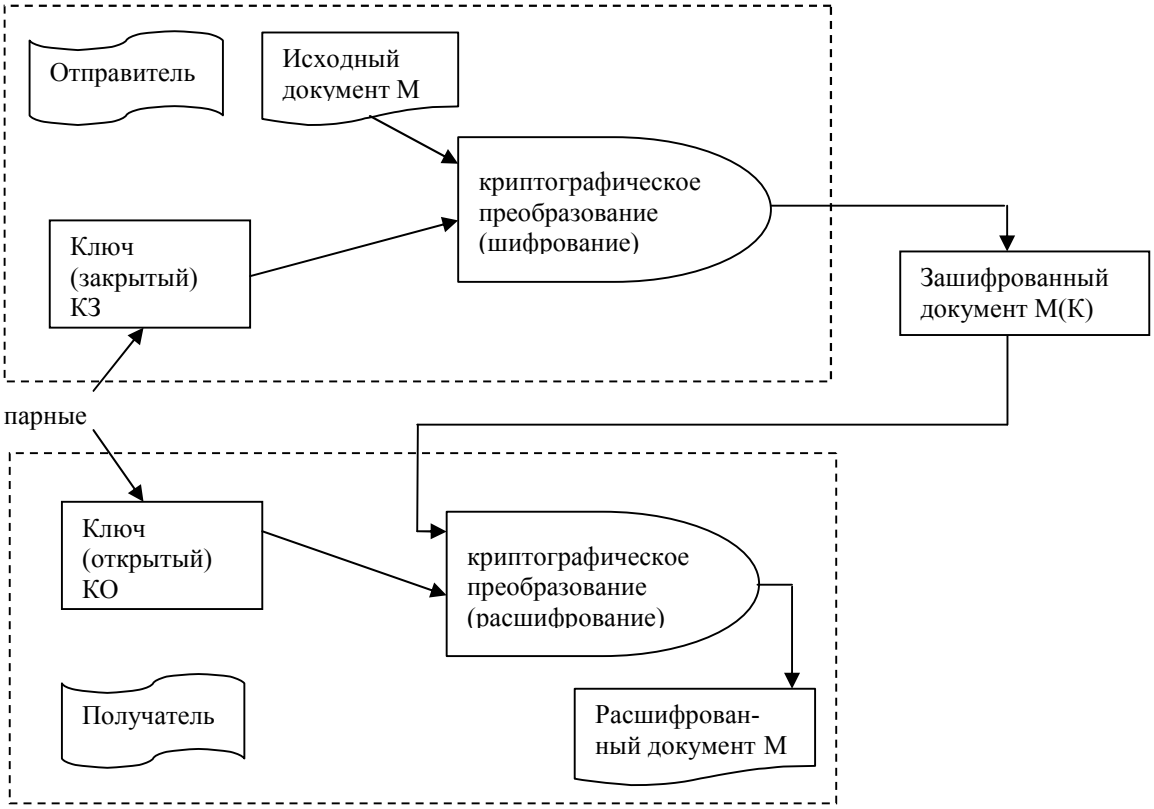

Рис. 10. Схема криптографического преобразования с асимметричным ключом

Схема криптографического преобразования с асимметричным ключом представлена на рис.10.

В системе с асимметричными ключами зашифрование и расшифрование осуществляются на разных, математически связанных (парных) ключах. Как было отмечено выше в такой системе Отправитель изготавливает себе ключевую пару - закрытый КЗ и открытый КО ключи. Закрытый ключ КЗ остается у отправителя, открытый ключ КО - передается всем получателям. Сообщение, зашифрованное на закрытом ключе КЗ, может быть расшифровано только на

открытом ключе КО. Таким образом, в криптографической системе закрытым ключом КЗ владеет только один человек. Соответственно, зашифровать сообщение М так, что оно будет расшифровано с помощью парного открытого ключа КО, может только владелец закрытого ключа КЗ. Алгоритмы асимметричного криптографического преобразования стандартизированы.

Главным достоинством такой системы является владение закрытым ключом КЗ только одного человека и его единоличная ответственность за компрометацию этого ключа.

Недостаток этой системы - сложность алгоритмов, что снижает скорость криптографического преобразования.

При шифровании с открытым ключом нет необходимости в передаче секретного ключа между взаимодействующими субъектами, что упрощает криптозащиту информации

Недостатком систем шифрования с открытым ключом является относительно низкая производительность, поскольку при шифровании и расшифровании используются весьма ресурсоемкие операции, например, такие как возведение большого числа в большую степень.

При необходимости организовать обмен шифрованными сообщениями между несколькими абонентами, пользуются специальными протоколами открытого распределения ключей. С классической системой открытого распределения ключей Диффи и Хэллмана, а также с ее модификациями, можно ознакомиться в [22, с. 200-202].

3.3.1 RSA-криптосистема с открытым ключом

Одной из наиболее распространенных криптосистем с открытым ключом является система *RSA,* предложенная Ривестом, Шамиром и Эдлеманом (*Rivest, Shamir, Adleman*). Ее стойкость основана на большой трудоемкости известных алгоритмов разложения произведения двух простых чисел на сомножители.

Чтобы организовать передачу шифрованных сообщений с помощью криптосистемы *RSA*, получатель должен сделать следующее:

1. С помощью специального алгоритма сгенерировать два больших простых числа p,q, которые необходимо держать в секрете.
2. Сообщить отправителю (или поместить в некоторый общедоступный каталог) число n, равное произведению p и q ($n=pq$), а также случайным образом выбранное целое число E, взаимно простое с произведением $(p\text{-}1)(q\text{-}1)$ (т. е. наибольшим общим делителем этих чисел является число 1).
3. Для расшифрования сообщений, зашифрованных на открытом ключе n, E, получателю необходимо иметь число D, являющееся мультипликативным обратным числа E по модулю $(p\text{-}1)(q\text{-}1)$, то есть остаток от деления произведения DE на $(p\text{-}1)(q\text{-}1)$ должен быть равен единице: $DE \equiv 1 mod((p\text{-}1)(q\text{-}1))$. Найти такое число получателю легко, так как наибольший общий делитель E и $(p\text{-}1)(q\text{-}1)$ равен единице по выбору E.

Таким образом, отправитель знает открытый ключ: n и E, а получатель, кроме этого, имеет секретный ключ D.

Любое передаваемое сообщение можно представить в виде последовательности целых чисел из заданного интервала. Будем считать, что отправитель передает секретное сообщение, представленное последовательностью чисел $X_1,\ldots,X_k$, $0 \le X_i \le n$-1, для всех i от 1 до k.

Отправитель для каждого блока X_i передаваемого сообщения, вычисляет

$$C_i = (X_i^E) \bmod n$$

и передает C_i по открытому каналу связи.

Имея n, E и C_i, получатель может расшифровать сообщение, воспользовавшись соотношением

$$X_i = (C_i^D) \bmod n \qquad (4)$$

Таким образом, получатель, вычислив $(C_i^D) \bmod n$, действительно получит i-й блок первоначального сообщения.

Рассмотрим в качестве примера случай p=3, q=11, n=3*11=33, E=7 и D=3.

Легко убедиться, что каждое из чисел E=7 и DE=21 взаимно просто со значением (p-1)(q-1)=20. Для передачи сообщения M="05" отправителю необходимо вычислить C=(5^7) mod 33=14. Получатель может расшифровать сообщение C=14, возведя его в степень D по модулю n: 5=14^3mod 33.

Пусть, как и ранее, наш алфавит состоит из букв русского языка (без буквы Ё) и пробела. Занумеровав элементы этого алфавита числами от 0 до 32, можно зашифровать произвольное сообщение на русском языке. Например, сообщение «ПРОЦЕНТНЫЕ СТАВКИ ПОВЫСИТЬ» в зашифрованном виде на ключе n=33, E=7 будет выглядеть следующим образом:

«27 25 20 22 14 07 06 07 03 14 32 08 06 00 29 10 02 32 27 20 29 03 08 02 06 19»

Очевидно, что шифр в этом примере является шифром простой замены. Известно, что такой шифр можно вскрыть, исследовав частоты встречаемости и взаимное расположение чисел в криптограмме. Однако в данном случае дешифровать получившуюся криптограмму можно гораздо быстрее, если составить полную таблицу зашифрования (см. табл. 9). При таком малом значении n противнику это легко сделать, так как по предположению открытый ключ: n=33, E=7 – ему известен.

Таблица 9

А	**Б**	**В**	**Г**	**Д**	**Е**	**Ж**	**З**	**И**	**Й**	**К**	**Л**	**М**	**Н**	**О**	**П**	**Р**	**С**	**Т**	**У**	**Ф**	**Х**	**Ц**	**Ч**	**Ш**	**Щ**	**Ъ**	**Ы**	**Ь**	**Э**	**Ю**	**Я**	
00	01	02	03	04	05	06	07	08	09	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25	26	27	28	29	30	31	32
00	01	29	09	16	14	30	28	02	15	10	11	12	07	20	27	25	08	06	13	26	21	22	23	18	31	05	03	19	17	24	04	32

Из таблицы зашифрования легко получить таблицу расшифрования, отсортировав столбцы табл. 9 по последней строке.

Таблица 10

00	01	02	03	04	05	06	07	08	09	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25	26	27	28	29	30	31	32
00	01	08	27	31	26	18	13	17	03	10	11	12	19	05	09	04	29	24	28	14	21	22	23	30	16	20	15	07	02	06	25	32
А	**Б**	**И**	**Ы**	**Я**	**Ъ**	**Т**	**Н**	**С**	**Г**	**К**	**Л**	**М**	**У**	**Е**	**Й**	**Д**	**Э**	**Ш**	**Ь**	**О**	**Х**	**Ц**	**Ч**	**Ю**	**Р**	**Ф**	**П**	**З**	**В**	**Ж**	**Щ**	

Сложность составления таблицы дешифрования пропорциональна количеству различных блоков, которые могут встретиться в шифруемом сообщении. Поэтому, для того чтобы шифр, основанный на криптосистеме *RSA*, не допускал дешифрование при неизвестном ключе, необходимо (но не достаточно) выполнение следующих двух условий.

Во-первых, число n, которое ограничивает максимальный размер блока и количество различных блоков, должно быть большим.

Во-вторых, шифруемые сообщения должны быть достаточно разнообразны. Недопустимо использование криптосистем с открытым ключом в случае, если сообщения являются комбинацией относительно небольшого количества стандартных фраз.

При выполнении указанных выше требований будет невозможно дешифрование на основе анализа частоты встречаемости и взаимного расположения различных блоков шифрованного сообщения.

Другим известным приемом дешифрования системы *RSA* является метод дешифрования итерациями, заключающийся в повторном шифровании до тех пор, пока вновь не будет получен открытый текст.

Пример 1. Пусть p=383, q=563, n=215629, E=49, (p-1)(q-1)= 214684. В этом случае открытый текст полностью восстанавливается уже через 10 шагов повторного шифрования. Чтобы в этом убедиться, достаточно показать, что $49^{10}\equiv 1 \bmod((p-1)(q-1))$. Выполнение последнего соотношения можно проверить даже с помощью калькулятора: (49^4=5764801 $\Rightarrow$ $49^4\equiv 183017 \bmod (214684)$ и т. д. $\Rightarrow$ $49^9\equiv 56957 \bmod (214684)$ $\Rightarrow$ $49^{10}\equiv 1 \bmod (214684)$).

Доказано, что вероятность успешной атаки методом дешифрования итерациями маловероятна, если p-1 и q-1 имеют большие простые сомножители p' и q', и, в свою очередь, p'-1 и q'-1 также имеют большие простые сомножители.

Рассмотрим теперь "лобовой метод" вскрытия системы *RSA*, который заключается в определении числа D, мультипликативного обратного E по модулю (p-1)(q-1). Это легко сделать, если известны числа p и q. Следовательно, решив задачу разложения на сомножители целого числа n, можно дешифровать систему *RSA*. Для того чтобы усложнить задачу разложения n на простые сомножители, числа p и q должны выбираться случайным образом и иметь достаточно большие значения. Кроме того, числа p и q не должны быть "слишком близкими" друг к другу.

Покажем, как можно использовать близость значений p и q. Предположим, что $p>q$. Для величин $x=(p+q)/2$ и $y=(p-q)/2$ ($n=pq$) справедливо соотношение

$$x^2 - y^2 = n \qquad (5)$$

Чтобы найти разложение n на простые сомножители, достаточно подобрать целые числа x и y, удовлетворяющие соотношению (5). Данное уравнение имеет единственное решение, так как $(x+y)(x-y)=n$, а n единственным образом раскладывается на простые сомножители $p=x+y$, $q=x-y$. Перебирая в порядке возрастания варианты $x^2 > n$ или $x > \sqrt{n}$ легко найти это решение, так как $x=(p+q)/2$ будет близким к $\sqrt{n}$, при условии, что p и q близки.

Пример 2. Пусть $n=pq$ = 899. Чтобы разложить n на простые сомножители p и q воспользуемся описанным выше способом. Так как $\sqrt{n} \approx 29.98$, берем x=30, вычисляем 30^2 – 899 = 1 и с первой попытки находим решение уравнения (5): x=30, y=1. Отсюда p=30+1=31, q=30-1=29.

Кроме указанных выше ограничений на выбор p,q,E и D к данным параметрам предъявляются и другие требования, влияющие на стойкость криптосистемы *RSA*. Более подробно эти требования изложены в [22].

3.4 Электронная цифровая подпись

Задача цифровой подписи состоит в том, чтобы обеспечить защиту электронного документа не только от подделки посторонним злоумышленником, но и от действий недобросовестных участников информационного обмена. Требования, предъявляемые к цифровой подписи, сформулируем следующим образом:

1. Цифровая подпись доказывает, что подписавший документ согласен с его содержанием.
2. Цифровая подпись является неотъемлемой частью подписанного документа и не может быть перенесена на другой документ.
3. После того, как документ подписан, его невозможно изменить.
4. От подписи нельзя отказаться, то есть подписавший не сможет впоследствии утверждать, что документ подписан без его согласия.

3.4.1 Механизм формирования электронной цифровой подписи

Свойство криптографической системы с асимметричными ключами предоставлять закрытый ключ КЗ только одному человеку используется для формирования реквизита электронного документа - электронной цифровой подписи.

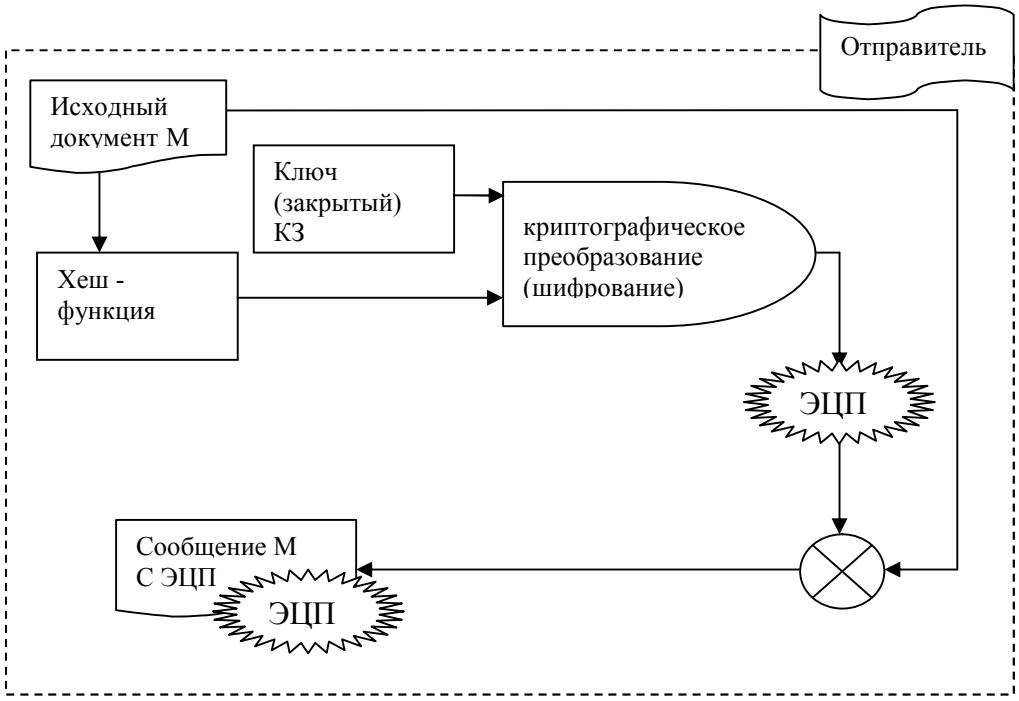

Рис. 11. Схема формирования ЭЦП

Рассмотрим механизм формирования электронной цифровой подписи. Схема формирования ЭЦП представлена на рис. 11.

Создается исходный документ. Владелец закрытого ключа КЗ вычисляет по стандартному алгоритму хэш-функцию от подписываемого сообщения. Хэш-функция похожа на контрольную сумму символов сообщения, но обладает чувствительностью даже к перестановке символов сообщения. Далее хэш-функция зашифровывается на закрытом ключе КЗ асимметричным криптографическим алгоритмом. Зашифрованная хеш-функция присоединяется к сообщению. При этом присоединённая подпись содержит в себе, в виде атрибута, подписанные данные, являясь своеобразным конвертом. В результате получено сообщение с ЭЦП.

Проверка электронной цифровой подписи производится с использованием парного открытого ключа КО. Механизм проверки ЭЦП представлен на рис.12.

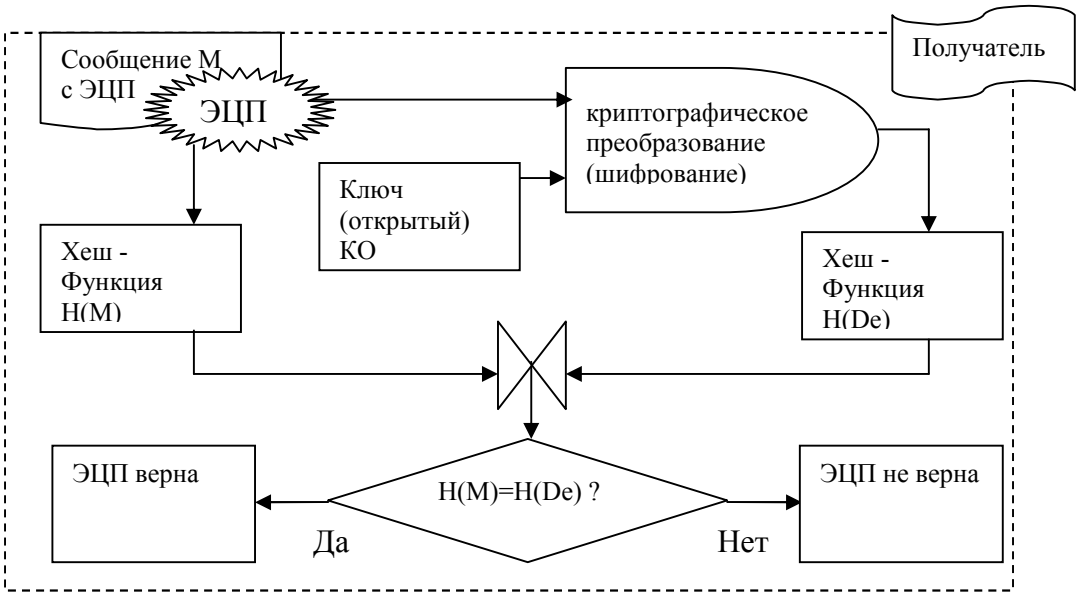

Рис.12. Механизм проверки ЭЦП

Для проверки ЭЦП вычисляется хэш-функция H(M) сообщения и электронная цифровая подпись расшифровывается с помощью открытого ключа КО (восстанавливается зашифрованная хэш-функция H(De)). Далее хэш-функции H(M) и H(De) сравниваются. При их совпадении делается вывод о верности электронной цифровой подписи. В противном случае делается вывод о неверной электронной цифровой подписи.

Описанный механизм цифровой подписи обеспечивает проверку подлинности документов более надежно, чем обычная подпись под бумажным документом. При этом цифровая подпись не является полным аналогом обычной подписи. Секретный ключ, позволяющий подписывать электронные документы, может быть передан другому лицу, а также потерян или украден. Поэтому вырабатывают специальные процедуры, позволяющие дезавуировать цифровую подпись. (Закон РФ «Об электронной цифровой подписи» 2002г.)

Особенностью цифровой подписи является то, что она не связана с подписанным экземпляром электронного документа. Уничтожая экземпляр бумажного документа, можно быть уверенным, что второго, точно такого, больше нет. Могут существовать его копии, подлинность которых в свою очередь должна быть заверена. Подписанный цифровой подписью электронный документ может быть копирован произвольное количество раз. Электронная подпись будет верна для всех этих экземпляров.

Приведенная схема построения алгоритма цифровой подписи на основе системы шифрования с открытым ключом, удобна для изложения основных идей, но не отражает всего многообразия реальных систем цифровой подписи. Так, система шифрования и цифровой подписи *RSA* хорошо соответствует данной схеме. А системы типа Эль-Гамаля (к которым принадлежит и Российский стандарт цифровой подписи – ГОСТ Р 34.10-94) не совсем точно укладываются в приведенную схему. Хотя также имеется секретный ключ для выработки цифровой подписи и открытый ключ для ее проверки. Однако процесс получения цифровой подписи не является шифрованием.

Положительный результат проверки позволяет сделать два важных вывода:

- электронная цифровая подпись сформирована с помощью закрытого ключа, парного открытому ключу, используемому при проверке (подтверждение авторства);
- подписанное сообщение не было изменено после подписания (подтверждение отсутствия искажения информации в сообщении).

В соответствии с Федеральным законом от 10.01.2002 №1-ФЗ "Об электронной цифровой подписи", владельцем закрытого ключа подписи выступает физическое лицо, что позволяет ему с помощью средств электронной цифровой подписи создавать свою электронную цифровую подпись в электронных документах (подписывать электронные документы). То есть, важной особенностью электронной цифровой подписи является ее однозначная принадлежность конкретному физическому лицу, которое и несет ответственность за содержимое подписанного им электронного документа. Действительно, если к закрытому ключу электронной цифровой подписи имеет доступ двое и более человек, определить, кто несет из них ответственность за содержимое подписанного электронного документа довольно затруднительно, что равносильно компрометации закрытого ключа. Именно поэтому электронная цифровая подпись трактуется Федеральным законом как аналог собственноручной подписи.

При применении ЭЦП возникает ряд проблем.

1. Во-первых, отмечены случаи кражи и злоупотребления электронной подписью, переданной (в нарушение установленного порядка) руководителем своему секретарю и т.п. Ситуация понятная: многие наши руководители пока не готовы и не считают нужным регулярно сидеть за компьютером и подписывать документы, если они не имеют большого значения для деловой деятельности. Вот и переходят дискетки, USB-брелки и прочие "безделушки" в другие руки, и рано или поздно нахо-

дятся сотрудники, которые не прочь использовать чужую электронную подпись в собственных интересах.

2. Во-вторых, часто можно слышать, что важным достоинством ЭЦП является невозможность автора подписи отказаться от нее. Действительно, отказаться от своей ЭЦП гораздо труднее, чем, например, от факсимильного оттиска. Однако, если удастся доказать, что автор подписи не мог подписать конкретный документ в силу определенных обстоятельств, оспорить ЭЦП будет не сложнее, чем любой другой вид подписи.
3. В-третьих, ЭЦП - лишь один из способов защиты целостности и аутентичности электронного документа. В ряде случаев организации не применяют ЭЦП из-за того, что это экономически нецелесообразно или создает неудобства в работе. Главная причина в том, что во многих случаях затраты на сложные методы защиты себя не окупают, особенно при работе в "закрытых" корпоративных системах, в которых высокий уровень защиты и контроля и так должен обеспечиваться.

Показательно, что в банковской отрасли, где требования к обеспечению информационной безопасности весьма высоки, относятся к ЭЦП с умеренным энтузиазмом и используют их в основном в системах "Клиент-банк". При работе в защищенных системах, в которых предусмотрен строгий контроль действий пользователей, ЭЦП используется редко.

Еще один важный пример - электронная почта. Здесь ЭЦП и шифрование используются редко, несмотря на доступность этой технологии и на то, что за рубежом сообщения электронной почты признаются деловыми документами. В большинстве случаев авторы сообщений не видят необходимости в такой защите, тем более что шифрованные сообщения могут привлечь нежелательное внимание со стороны как хакеров, так и государственных служб, борющихся с терроризмом, отмыванием денег и т.п.

В корпоративных системах часто используются несертифицированные средства, не менее эффективные, чем "законная" ЭЦП. В этом случае не возникает проблемы с признанием юридической силы документов, поскольку заключаются соответствующие двусторонние или многосторонние соглашения. Кроме того, есть возможность самостоятельно выбирать средства защиты, режим работы "внутреннего" удостоверяющего центра и т.д.

Специалисты - криптографы считают, что вероятность взлома или компрометации современных ЭЦП спустя 10 лет - высокая, и это нужно учитывать как в законодательстве, так и в правилах хранения документов с ЭЦП.

Хранение документов, подписанных ЭЦП, должно быть организовано таким образом, чтобы гарантировать возможность проверки подлинности подписи на протяжении всего срока хранения документа. Если же с помощью ЭЦП подписан документ постоянного срока хранения, то удостоверяющий центр должен будет обеспечить такой же срок хранения своих документов, оборудования и программного обеспечения в рабочем состоянии.

ЭЦП бывают двух видов – присоединённые (attached signature) и отсоединённые (detached signature). Принципиальное отличие их состоит в том, что присоединённая подпись содержит в себе, в виде атрибута, подписанные данные, являясь своеобразным конвертом. Отсоединённая же подпись связана с данными, для неё внешними. Не смотря на то, что по структуре оба этих типа подписей одинаковы, за исключением одного атрибута, функционально работа с ними принципиально отличается, каждый из двух типов подписей имеет свои положительные и отрицательные стороны.

Присоединённая подпись хороша тем, что и данные, и подпись в ней неразрывно связаны, что значительно упрощает передачу данных. Кроме того, присоединённая подпись не позволяет изменять подписанные данные без разрушения самой подписи.

Недостатки присоединённой подписи являются обратной стороной её преимуществ. Являясь, по сути, конвертом для данных, она требует, даже для ознакомления с данными, извлечения их из конверта – снятия ЭЦП. Для этого требуются специальные средства работы с ЭЦП. Не получится и изменить данные в ЭЦП, пожертвовав действительностью подписи – фактически, снятие конверта означает только копирование данных из электронной цифровой подписи.

Отсоединённая подпись лишена подобных недостатков – подписанные данные при создании ЭЦП никак не изменяются и готовы для работы в любой момент, даже при отсутствии средств проверки электронной цифровой подписи. В этом случае сами данные доступны, без проверки подписи. Однако такая демократичность тоже не лишена недостатков – отсоединённая подпись самостоятельно никак не привязана к подписываемым данным и может «потеряться».

Известные на сегодняшний день «расширенные» и «усовершенствованные» ЭЦП являются производными от обычной, стандартной электронной цифровой подписи. Они содержат в составе своих атрибутов информацию для дополнительных проверок условий использования электронной цифровой подписи, которой могут воспользоваться специальные средства и механизмы проверки ЭЦП. Тем не менее, такая усовершенствованная подпись может быть проверена как стандартная – дополнительные атрибуты не являются обязательными в структуре ЭЦП. В некоторых случаях такая дополнительная информация помогает решать некоторые функциональные задачи.

3.4.2 Хеш-функция

При описании механизма выработки цифровой подписи было отмечено, что владелец закрытого ключа КЗ вычисляет по стандартному алгоритму хэш-функцию от подписываемого сообщения.

Под термином хеш-функция понимают преобразования, которые отображают строки переменной длины во множество строк фиксированной длины, как правило, меньшей, чем у исходных строк.

Значение хеш-функции H от сообщения x будем называть хеш-кодом, и обозначать $H(x)$. Любое изменение документа x влечет за собой изменение его хеш-кода.

Таким образом, чтобы подписать документ x, необходимо сначала вычислить его хеш-код $H(x)$, который затем следует преобразовать с помощью секретного ключа. Тогда подписанный документ выглядит как пара $x, E(H(x))$. Хеш-функция H, с помощью которой определяется хеш-код подписываемого документа, является общеизвестной. Чтобы убедиться в подлинности документа, достаточно вычислить значения $H(x)$ и $D(E(H(x)))$ и сравнить их между собой.

Не любая функция, отображающая сообщение произвольной длины в хеш-код фиксированной длины, может быть использована в алгоритме цифровой подписи. Примером этому может служить функция s, значением которой является сумма по модулю два всех байтов сообщения. В этом случае для исходного сообщения x нетрудно подобрать сообщение y, для которого $s(y)=s(x)$. Значит, перехватив подлинное сообщение x и его цифровую подпись $E(s(x))$, злоумышленник может подменить его сообщением y, используя в качестве цифровой подписи $E(s(x))=E(s(y))$.

Требования к хеш-функции, которая может быть использована в алгоритме цифровой подписи:

1. Хеш-функция должна обрабатывать сообщения произвольной длины.
2. Результатом применения хеш-функции является хеш-код фиксированной длины.
3. Вычисление хеш-функции от заданного сообщения должно выполняться сравнительно быстро.
4. Операция нахождения сообщения x, имеющего известный хеш-код $H(x)$, должна быть трудно выполнимой. То есть для имеющегося сообщения x сложно найти несовпадающее с ним сообщение y такое, что $H(y) = H(x)$ (наличие такой пары называют коллизией). Следовательно, перехватив сообщение x с цифровой подписью $E(H(x))$, злоумышленник не сможет подобрать другое сообщение y, имеющее ту же цифровую подпись.

Функции, удовлетворяющие требованиям 1-4, называют слабыми хеш-функциями.

Функцию $H(x)$ называют сильной, если дополнительно выполняется условие:

5. Очень сложно подобрать пару сообщений x, y таких, что $H(x)=H(y)$.

Предположим последнее требование не выполняется, и имеется алгоритм подбора сообщений с совпадающими хеш-кодами. Пусть x, y такие, что $H(x)=H(y)$. Возможно, что одно из этих сообщений является вполне безобидным, а второе очень выгодным злоумышленнику. Например, в первом содержится указание о переводе 1000 рублей на счет детского сада, а во втором 100 000 на счет злоумышленника. Тогда злоумышленник может каким-либо образом добиться подписания безобидного сообщения x, а затем использовать полу-

ченную цифровую подпись $E(H(x))$ для подтверждения сообщения y, пользуясь тем, что цифровые подписи этих сообщений совпадают.

Требования несовпадения хеш-кодов для разных файлов приходят в определенное противоречие с требованиями их компенсации за счет подбора текста. На самом деле хорошую хеш-функцию построить очень сложно, и ее надежность в конечном итоге определяется надежностью всей подписи.

Российский стандарт на хеш-функцию (ГОСТ Р 34.11-94) удовлетворяет требованиям к сильной хеш-функции. Данный стандарт определяет алгоритм и процедуру вычисления хеш-функции для любой последовательности двоичных символов, которые применяются в криптографических методах обработки и защиты информации, в том числе для реализации процедур электронной подписи (ЭЦП) при передаче, обработке и хранении информации в автоматизированных системах. Длина хеш-кода, создаваемого согласно с алгоритмом этого стандарта составляет 256 бит.

Кратко ГОСТ Р 34.11-94 можно описать следующим образом. Исходными данными для процедуры вычисления значения функции H является

- подлежащая хешированию последовательность M из множества всех конечных слов в алфавите B={0,1}. (Чтение слов и нумерация знаков алфавита (символов) осуществляется справа налево (номер правого символа в слове равен единице, второго справа - двум и т.д.).);
- стартовый вектор хеширования H – произвольное фиксированное значение длиной 256 бит;
- контрольная сумма Σ, начальное значение которой равно нулю и длина равна 256 битам;
- переменная L, начальное значение которой равно длине сообщения.

Сообщение M делится на блоки длиной 256 бит и обрабатывается справа налево.

Хеш-функции широко используются также в целях аутентификации пользователей. Существует большое множество криптографических протоколов, основанных на применении хеш-функций.

Покажем, каким образом можно использовать криптосистему *RSA* для построения системы цифровой подписи.

Отправитель сообщений вырабатывает параметры p, q, E и D (придерживаясь ранее введенных обозначений, будем считать, что E является ключом зашифрования, а D – расшифрования). Чтобы подписать сообщение M, отправитель вычисляет $P=(M^E)\bmod n$. Получатель, имея M и P, вычисляет $P^D \equiv M(\bmod n)$ и убеждается, таким образом, в подлинности документа.

Пример 3. Пусть p=3, q=11, n=33, E=7 и D=3. Отправитель сообщения M="14" вычисляет цифровую подпись $20=(14^7)mod\ 33$ и посылает получателю пару "14,20". Чтобы проверить подлинность сообщения "14", получателю достаточно убедиться в том, что $14=(20^3)\bmod 33$.

Для приведенного алгоритма цифровой подписи противник может использовать следующий способ атаки: взять произвольное P_1 и вычислить сообщение

$M_1=(P_1^D)\bmod n$, имеющее цифровую подпись P_1. Однако при таком способе атаки он не сможет предвидеть полученное значение M_1. Скорее всего, сообщение M_1 будет совершенно не похоже на открытый текст и, следовательно, противник не сможет ввести получателя в заблуждение. Данная атака представляет реальную опасность в случае передачи каких-либо числовых данных, для которых допустимы все возможные значения подписываемых блоков (или, по крайней мере, существенная доля). Использование хорошей хеш-функции не позволит осуществить данный способ подделки сообщений, так как противник не сможет подобрать текст, имеющий подписанный им хеш-код.

3.4.3 Сертификация открытых ключей

При использовании криптосистем с открытым ключом важной является проблема обеспечения достоверности передаваемых открытых ключей. Представим, что злоумышленник **C** подменил открытый ключ абонента **A,** во время его передачи абоненту **B,** на свой открытый ключ. В этом случае **C** сможет расшифровывать все сообщения абонента **B**, предназначенные для **A**. Аналогичная атака на цифровую подпись приведет к тому, что сообщения, подписанные злоумышленником, будут считаться подлинными, а настоящие сообщения – ложными.

Данная проблема решается путем сертификации открытых ключей. Центр сертификации выдает абонентам сети связи сертификаты их открытых ключей. Сертификат открытого ключа представляет подписанный цифровой подписью центра сертификации набор данных, включающий идентификатор владельца сертификата, его открытый ключ, и, возможно, некоторую дополнительную информацию, например, такую как время выдачи и срок действия сертификата, информацию о владельце ключа и центре сертификации, выдавшем сертификат и т.п. Наиболее распространенной является форма сертификата, соответствующая стандарту X.509, принятому Сектором стандартизации электросвязи Международного союза электросвязи (ITU-T). Получив от абонента **A** его открытый ключ в виде сертификата, абонент B может легко проверить его подлинность с помощью открытого ключа центра сертификации. Ключ подлинный, если цифровая подпись сертификата верна. Не зная закрытого ключа центра сертификации злоумышленник **C** не сможет подменить сертификат.

Описанная схема распределения открытых ключей абонентам сети для организации обмена подписанными и шифрованными сообщениями предполагает наличие доверенного канала связи с центром сертификации.

Существуют региональные центры сертификации географически приближенные к абонентам. Такие региональные центры сертификации получают сертификат у центра сертификации более высокого уровня. Это необходимо для того, чтобы абоненты, получившие сертификаты в разных региональных центрах сертификации смогли проверить подлинность сертификатов друг друга.

Таким образом, абоненты должны иметь свой сертификат, сертификат регионального центра сертификации и сертификат центра сертификации, выдавшего сертификат региональному центру.

Центры сертификации объединяются в иерархию нескольких уровней. Самый верхний центр сертификации в этой иерархии называют корневым. Этот центр выдает себе сертификат сам. Такой сертификат называют самоподписанным. Это сертификат своего открытого ключа на своем закрытом ключе.

Многоуровневая организация центров сертификации является более безопасной, так как при компрометации закрытого ключа отдельного сертификационного центра не нарушается работа всей системы.

Совокупность технологий, стандартов, протоколов и служб, позволяющих обеспечить управление ключами с использованием цифровых сертификатов, называют Инфраструктурой открытого ключа (Public Key Infrastructure, PKI).

Глава 4. Лабораторный практикум

4.1 Лабораторная работа № 1

Тема: Шифр простой замены. Пример создания программного кода зашифровывающего и расшифровывающего сообщение по алгоритму шифра простой замены.

Задача. Создать программный код зашифровывающий, а затем расшифровывающий предложение, записанное на русском языке. Использовать шифр простой замены, в котором каждая буква русского алфавита заменяется другой буквой этого же алфавита. При этом замена осуществляется по правилу: первая буква заменяется последней, вторая – предпоследней и т.д. Так, А заменяется на Я, Б – на Ю, В - на Э и т. д.

Формализация задачи. Решение поставленной задачи сводится к замене букв исходного текста (алфавит по порядку) буквами алфавита записанного в обратном порядке. *Исходные данные*: Буквы русского алфавита, записанные в алфавитном порядке за исключением буквы Ё, буквы русского алфавита за исключением буквы Ё, выписанные в обратном порядке. Шифруемое сообщение: «простая замена один из самых древних шифров». *Выходные данные:* Сообщение до его шифровки, после шифровки и после расшифровки.

Разработка алгоритма. Для решения поставленной задачи определяем количество символов преобразуемой строки. Образуем новую строку по длине равную исходной строке. Далее организуем цикл, в котором просматриваем все символы преобразуемой строки, определяем позицию номер k этого символа в исходном алфавите. Если в исходном алфавите символ не найден, то в данную позицию новой строки заносим этот символ без изменений, в противном случае в данную позицию новой строки заносим символ из нового алфавита, позиция которого совпадает с позицией номер k исходного алфавита.

Реализация алгоритма на ЭВМ. Создадим программный код.

1. Запустите программу Microsoft Excel (Пуск – Все Программы – Microsoft Office Excel 2007).
2. Лист 1 рабочей книги Excel переименуйте. Назовите Лаб. раб. №1.
3. Нажмите Alt-F11. Откроется окно редактирования VBA.
4. В редакторе VBA выполнить команду Insert/Module.

5. В стандартном модуле VBA поместить следующий код программы.

```
Private n As Long
'исходный алфавит
Const АБВ As String = "абвгдежзийклмнопрстуфхцчшщъыьэюя"
'новый алфавит
Const НовАБВ As String = "яюэьыъщшчцхфутсрпонмлкйизжедгвба"
Private Sub AnotherCipher()
Dim STR As String, strT As String, strR As String
‘строка которую будем зашифровывать
STR = "Простая замена один из самых древних шифров"
‘ переход к нижнему регистру
STR = LCase(STR)
‘печать в окно Immediate
Debug.Print STR
' шифровка
Decode STR, strR, АБВ, НовАБВ
Debug.Print strR
'расшифровка
Decode strR, strT, НовАБВ, АБВ
Debug.Print strT
End Sub

Private Sub Decode(STR, STRS, Oldkey, NewKey)
Dim n As Long, i As Long
Dim tmp As String
'определяем количество символов исходной строки
n = Len(STR)
'вводим преобразованную строку, состоящую из n пробелов
STRS = Space(n)
For i = 1 To n
'выделяем один символ исходной строки
tmp = Mid(STR, i, 1)
'определяем место символа исходной строки в исходном алфавите
k = InStr(1, Oldkey, tmp)
If k = 0 Then
'если в исходном алфавите такого символа нет
'то переносим его в новую строку не изменяя
Mid(STRS, i, 1) = tmp
Else
'заменяем соответствующий пробел на символ нового алфавита
Mid(STRS, i, 1) = Mid(NewKey, k, 1)
End If
Next i
End Sub
```

6. В программе применяется объект Debug, который представляет собой отладчик и позволяет выводить промежуточные значения (с помощью метода Print) в окно Immediate. Это окно отражается на экране выбором команды View/ Immediate Window и используется при отладке программ.
7. Синтаксис функций обработки строковых выражений приведен в Приложении табл. 1.

8. Выполнить команду Debug/Compile VBA.Отобразить окно Immediate с помощью команды View/ Immediate Window.
9. Для того чтобы проверить, как работает созданная программа, поместите курсор в поле кода подпрограммы `AnotherCipher` нажмите клавишу F5 или выберите команду RUN/RUN SUB/USERFORM.
10. Результатом работы данной программы будет вывод в окно Immediate сообщения до его шифровки, после шифровки и после расшифровки рис.13.

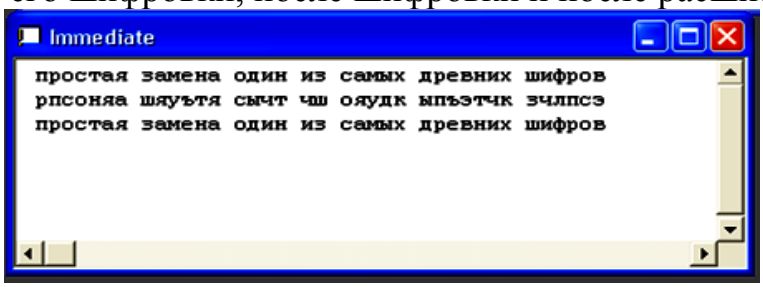

Рис.13

Индивидуальные задания по лабораторной работе №1.

Варианты заданий приведены в табл. 11 и табл. 12. Уровень сложности заданий табл. 12 значительно выше.

Правильность работы шифраторов проверить: используя отладчик Debug, позволяющий выводить промежуточные значения (с помощью метода Print) в окно Immediate. Вывести в окно Immediate сообщения до его шифровки, после шифровки и после расшифровки.

Таблица 11

Создать программный код шифра замены по правилу:

<table>
<tr><th>№</th><th>Правило замены</th></tr>
<tr><td>0</td><td>Гласные буквы русского алфавита не изменяются. Первый десяток согласных заменяется на второй десяток согласных (второй - на первый) по следующей таблице:
<table>
<tr><td>Б</td><td>В</td><td>Г</td><td>Д</td><td>Ж</td><td>З</td><td>К</td><td>Л</td><td>М</td><td>Н</td></tr>
<tr><td>Щ</td><td>Ш</td><td>Ч</td><td>Ц</td><td>Х</td><td>Ф</td><td>Т</td><td>С</td><td>Р</td><td>П</td></tr>
</table>
(шифр типа масонской замены - «простая литорея»)</td></tr>
<tr><td>1</td><td>Заменить буквы сообщения составленного на русском языке, согласно лозунговому шифру, используя лозунг «право».</td></tr>
<tr><td>2</td><td>Заменить буквы сообщения составленного на русском языке согласно шифру «Альбам»</td></tr>
<tr><td>3</td><td>Заменить буквы сообщения составленного на русском языке, согласно лозунговому шифру с лозунгом «зерно»</td></tr>
<tr><td>4</td><td>Заменить буквы сообщения составленного на русском языке буквами циклически сдвинутого русского алфавита на 7 букв влево.</td></tr>
<tr><td>5</td><td>Заменить буквы сообщения составленного на английском языке, согласно лозунговому шифру с лозунгом «phrase».</td></tr>
<tr><td>6</td><td>Заменить буквы сообщения составленного на английском языке, согласно лозунговому шифру с лозунгом «labour».</td></tr>
</table>

7	Заменить буквы английского сообщения согласно шифру Цезаря, примененному к английскому языку.
8	Заменить буквы сообщения составленного на русском языке согласно шифру Атбаш, примененному к русскому алфавиту.
9	Заменить буквы сообщения составленного на русском языке согласно шифру Цезаря, примененному к русскому алфавиту.

Таблица 12

Создать программный код шифра замены по правилу:

№	Правило замены
0	Заменить буквы сообщения составленного на русском языке, согласно шифру простой колонной перестановки
1	Заменить буквы сообщения составленного на английском языке их кодами согласно базовой таблице кодировки ASCII (шестн.).
2	Заменить буквы сообщения составленного на русском языке их порядковыми номерами в алфавите.
3	Заменить буквы сообщения составленного на английском языке их порядковыми номерами в алфавите.
4	Заменить буквы сообщения составленного на русском языке их кодами согласно кодировке Windows 1251.
5	Заменить буквы сообщения составленного на английском языке их кодами согласно базовой таблице кодировки ASCII (дес.).
6	Заменить буквы сообщения составленного на русском языке по следующей таблице **А Б В Г Д Е Ж З И Й К Л М Н О П Р** 09 23 01 04 07 02 14 13 21 31 17 25 29 06 22 11 26 **С Т У Ф Х Ц Ч Ш Щ Ъ Ы Ь Э Ю Я** 00 19 30 08 18 16 28 03 27 32 15 10 20 24 12 05
7	Заменить буквы сообщения составленного на русском языке по следующей таблице **А Б В Г Д Е Ж З И Й К Л М Н О П Р** 00 01 02 03 04 05 06 07 08 09 10 11 12 13 14 15 16 **С Т У Ф Х Ц Ч Ш Щ Ъ Ы Ь Э Ю Я** 17 18 19 20 21 22 23 24 25 26 27 28 29 30 31 32
8	Заменить буквы сообщения составленного на русском языке согласно шифра Виженера с ключом «победа».
9	Заменить буквы сообщения составленного на русском языке согласно шифру Виженера с ключом «мысль»

4.2 Лабораторная работа № 2

Тема: Создание пользовательской формы – Шифратор Цезаря.

Задача: Задано:

а) исходный текст зашифровать с помощью шифра Цезаря;

б) шифротекст расшифровать, зная ключ – шифр Цезаря.

Формализация задачи. Определим исходные и выходные данные. Исходные данные – строка исходного текста - str .

Выходные данные – а) строка шифротекста strT;

б) строка расшифрованного (исходного) текста strR .

Разработка алгоритма. Для решения поставленной задачи можно применить стандартный алгоритм шифрования (расшифровывания) Цезаря. Применяем операцию циклического (модульного) сложения. От обычного сложения эта операция отличается тем, что если сумма превышает число 32, то из нее вычитается 32, обратная операция – вычитание - характеризуется тем, что если в результате получается отрицательное число, то к нему прибавляется 32.

Реализация алгоритма на ЭВМ. Спроектируем пользовательскую форму.

1. Откройте документ Microsoft Excel.
2. Откройте окно редактирования VBA. Для этого на вкладке Разработчик нажмите кнопку Visual Basic.
3. В открывшемся окне выберите команду Insert/UserForm. В редакторе Visual Basic появятся: окно пользовательской формы и панель инструментов Панель элементов. На Панели элементов находятся все необходимые для проектирования формы элементы.
4. Используя диалоговое окно Свойства (для вызова этого окна, если оно отсутствует, выполните команду View/Properties Windows) и Панель элементов, простым перетаскиванием элементов управления на форму, создайте пользовательскую форму в виде, представленном на рис.14.

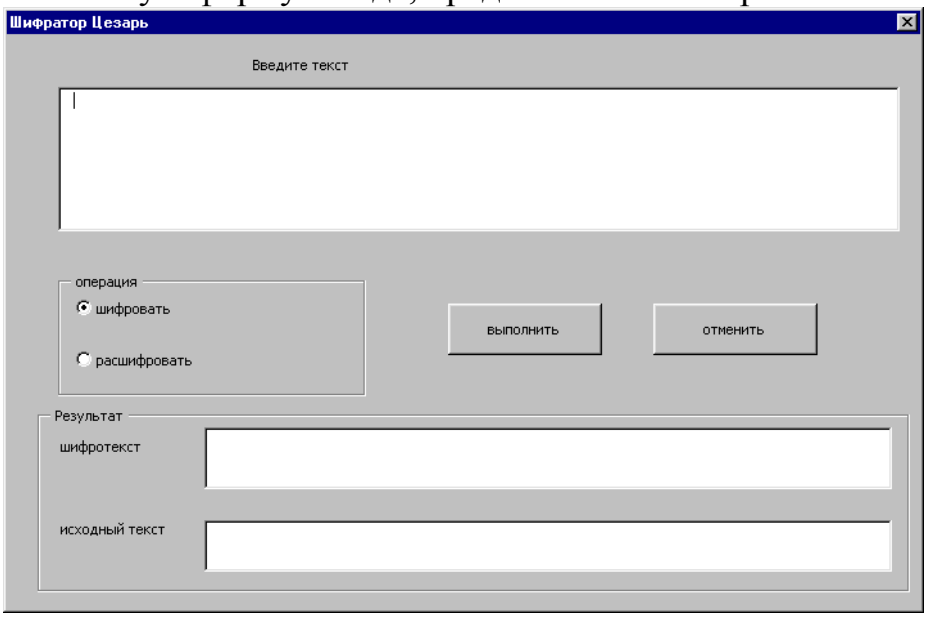

Рис.14

5. Надписи, отображаемые на элементе управления, для формы – текст, отображаемый в строке заголовка формы, определите с помощью значения свойства Caption.
6. Чтобы написать процедуру обработки событий нажатия кнопки «Выполнить» или «Отменить» (событие Click), дважды щелкните на элементе

управления CommandButton, или воспользуйтесь командой контекстного меню View Code.

7. В окно редактирования кода необходимо ввести следующие процедуры:

```
Private Sub UserForm_Initialize()
CommandButton1.Caption = "выполнить"
CommandButton2.Caption = "отменить"
OptionButton1.Caption = "шифровать"
OptionButton2.Caption = "расшифровать"
'первоначальный выбор переключателя
OptionButton1.Value = True
OptionButton2.Value = False
End Sub

Sub текст(видимость)
'процедура управляет видимостью
Frame2.Visible = видимость
TextBox1.Visible = видимость
TextBox2.Visible = видимость
TextBox3.Visible = видимость
End Sub
Private Sub CommandButton1_Click()
Dim str As String, strT As String, strR As String
Dim n As Long, i As Long
str = TextBox1.Text
n = Len(str)
strT = Space(n)
If OptionButton1.Value = True Then
If TextBox1.Text = "" Then MsgBox ("Введите исходный текст"):
GoTo 1
'сдвиг на 3 знака шифровка
For i = 1 To n
Mid(strT, i, 1) = Caesar(Mid(str, i, 1), 3)
Next i
End If
TextBox2.Text = strT
If OptionButton2.Value = True Then
str = TextBox1.Text
n = Len(str)
strR = Space(n)
If TextBox1.Text = "" Then MsgBox ("Введите шифротекст"): GoTo
1
'сдвиг на -3 знака расшифровка
For i = 1 To n
Mid(strR, i, 1) = Caesar(Mid(str, i, 1), -3)
Next i
End If
TextBox3.Text = strR
1:
End Sub
Private Function Caesar(A, Sh)
Dim chrnew As Integer
```

```
Select Case Asc(A)
       Case 224 To 255 'строчные буквы
       chrnew = ModMew(Asc(A) + Sh - 224, 32) + 224
       Caesar = Chr(chrnew)
       Case 192 To 223 'прописные буквы
       chrnew = ModMew(Asc(A) + Sh - 192, 32) + 192
       Caesar = Chr(chrnew)
       Case Else
       Caesar = A
       End Select
End Function
Private Function ModMew(A, B)
If A >= 0 Then
ModMew = A Mod B
Else
ModMew = (B + A) Mod B
End If
End Function
Private Sub CommandButton2_Click()
'закрыть форму
UserForm1.Hide
'при закрытии формы очищаем текстовые поля
TextBox1.Text = ""
TextBox2.Text = ""
TextBox3.Text = ""
End Sub

Private Sub OptionButton1_Click()
OptionButton1.Value = True
расшифровать = False
End Sub

Private Sub OptionButton2_Click()
шифровать = False
OptionButton2.Value = True
End Sub
```

8. Для запуска формы с листа выполнить команду Вид/Панели инструментов/Элементы управления. На панели инструментов нажмите кнопку Режим конструктора. Выберите элемент управления Кнопка и перетащите ее на рабочий лист. По двойному щелчку на Кнопке попадаем в поле, в котором необходимо писать процедуру работы Кнопки

```
Private Sub CommandButton1_Click()
UserForm1.Show
End Sub
```

Индивидуальные задания по лабораторной работе №2.

Варианты заданий приведены в табл. 13 и табл. 14. Уровень сложности заданий табл. 14 значительно выше.

Правильность работы шифраторов проверить: предусмотрев вывод сообщения в окно Шифратора при шифровке, после шифровки и его расшифровке, а при расшифровке также после расшифровки и его повторной шифровки. Визуально сравнить результаты.

Таблица 13

№	Создать пользовательскую форму шифратора.	№	Создать пользовательскую форму шифратора.
0	Шифра Атбаш	5	Шифра «Альбам»
1	Шифра по правилу: буквы исходного сообщения заменяются буквами циклически сдвинутого на 6 букв влево русского алфавита	6	Шифра по правилу: буквы исходного сообщения на английском языке заменяются буквами циклически сдвинутого на 5 букв влево латинского алфавита
2	Лозунгового шифра с лозунгом «компьютер»	7	Лозунговому шифру с лозунгом «mail».
3	Шифра типа масонской замены - «простая литорея»	8	Лозунгового шифра с лозунгом «осень»
4	Лозунговому шифру с лозунгом «ache».	9	Лозунгового шифра с лозунгом «август»

Таблица 14

№	Создать пользовательскую форму шифратора.	№	Создать пользовательскую форму шифратора.
0	Шифра вертикальной перестановки с ключом «экзамен»	5	Шифра вертикальной перестановки с ключом «студент»
1	Шифра Виженера с ключом «экзамен»	6	Шифра простой колонной перестановки
2	Шифра со случайной гаммой.	7	Шифра гаммирования с ключом 03 30 21
3	Шифра гаммирования с ключом 09 11 23 17	8	Шифра вертикальной перестановки с ключом «мечта»
4	Шифра вертикальной перестановки с ключом 5 3 1 2 4 6	9	Шифра Виженера с ключом «мелодия»

4.3 Лабораторная работа № 3

Тема: Системы с закрытым ключом. Шифрование методом подстановки.

Цель работы: научиться выполнять шифрование текста в Microsoft Excel методом подстановки.

Суть метода: Шифрование методом подстановки основано на замене в исходном тексте одних символов алфавита другими по определенному алгоритму или с помощью таблицы соответствия.

Задание 1: Шифрование средствами электронных таблиц.

Реализация алгоритма на ЭВМ.

1. Запустите программу Microsoft Excel (Пуск – Все Программы – Microsoft Office Excel 2007).
2. Лист 1 рабочей книги Excel переименуйте. Назовите Лаб. раб. № 3.
3. На листе Лаб. раб. № 3 наберите исходные данные, как показано на рис.15.

	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P
1	метод подстановки															
2	ключ=	13														
3																
4	исходный текст	с	о	л	н	е	ч	н	ы	й		д	е	н	ь	
5																

Рис.15

4. Используем текстовые функции СИМВОЛ и КОДСИМВ. Заметим, что пустая ячейка листа Excel, соответствующая пробелу имеет код символа 32. Воспользуемся логическими функциями: ЕСЛИ и ЕПУСТО, а также арифметической функцией остаток от деления ОСТАТ. Алфавит предполагаем состоящим из 256 элементов, то есть в данном случае любая буква русского алфавита может быть заменена любым символом из таблицы символов текстового редактора Word. Подстановка состоит в том, что к коду символа добавляется значение ключа и определяется символ, соответствующий этому коду**.**

Поместив курсор в ячейку B6, в строке формул сделайте запись =ЕСЛИ(ЕПУСТО(B4);СИМВОЛ(32);СИМВОЛ(ОСТАТ(КОДСИМВ(B4)+B2;256))).

5. Выполните авто заполнение ячеек B6-O6. В результате в строке 6 получим зашифрованную фразу «солнечный день» рис.16.

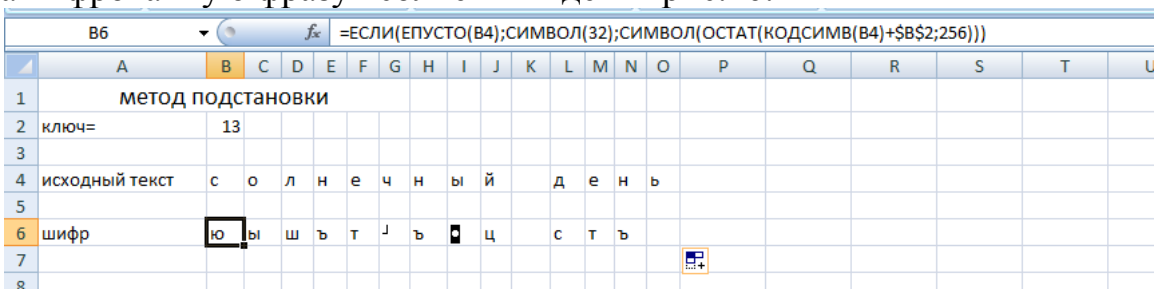

Рис.16

6. Выполним расшифровку строки 6. При этом вместо проверки ЕПУСТО выполняем проверку на наличие в ячейке символа 32 и определяем символ, соответствующий коду, уменьшенному на значение ключа. Таким образом, поместив курсор в ячейку B8, в строке формул сделайте запись =ЕСЛИ(B6=СИМВОЛ(32);СИМВОЛ(32);СИМВОЛ(ОСТАТ(КОДСИМВ(B6)-B2;256)))
7. Выполните авто заполнение ячеек B8-O8. В результате в строке 8 получили расшифрованную фразу «солнечный день» рис.17.

B8 =ЕСЛИ(B6=СИМВОЛ(32);СИМВОЛ(32);СИМВОЛ(ОСТАТ(КОДСИМВ(B6)-B2;256)))

	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O
1	метод подстановки														
2	ключ=	13													
3															
4	исходный текст	с	о	л	н	е	ч	н	ы	й		д	е	н	ь
5															
6	шифр	ю	ы	ш	ъ	т	]	ъ	■	ц		с	т	ъ	
7															
8	расшифровка	с	о	л	н	е	ч	н	ы	й		д	е	н	ь
9															

Рис.17

Задание 2: Шифрование средствами VBA.

Реализация алгоритма на ЭВМ.

1. Откройте лист Лаб. раб. № 3 нажмите Alt-F11. Откроется окно редактирования VBA.
2. В редакторе VBA выполнить команду Insert/Module.
3. Выберите команду Insert/UserForm. В редакторе Visual Basic появятся: окно пользовательской формы и панель инструментов Панель элементов. На Панели элементов находятся все необходимые для проектирования формы элементы.

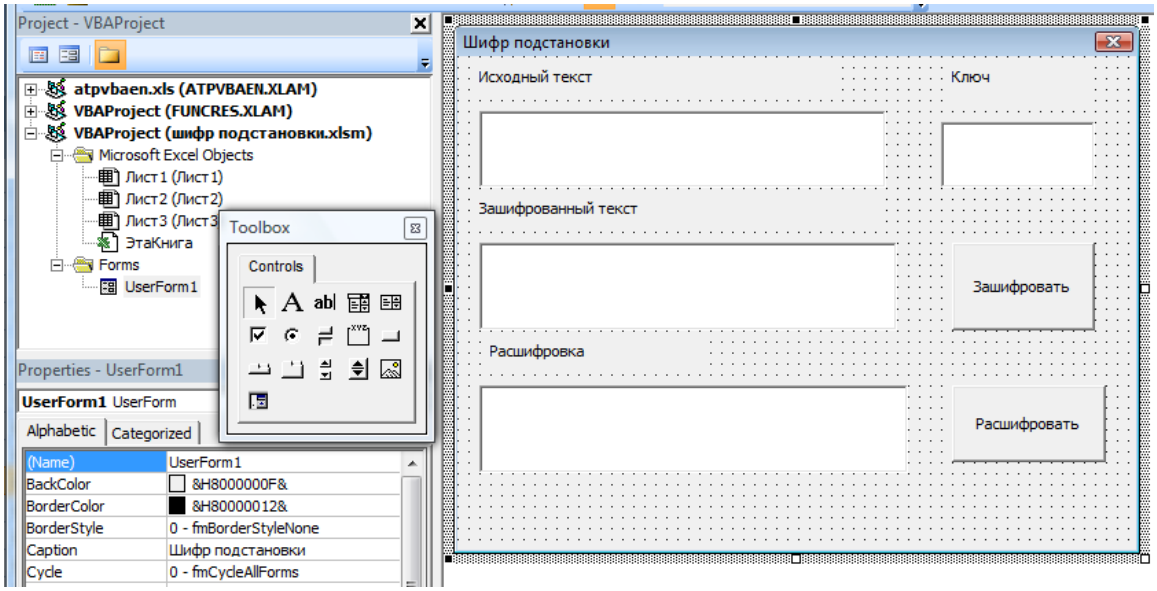

Рис.18

4. Используя диалоговое окно Свойства (для вызова этого окна, если оно отсутствует, выполните команду View/Properties Windows) и Панель элементов, простым перетаскиванием элементов управления на форму, создайте пользовательскую форму в виде, представленном на рис.18.
5. Надписи, отображаемые на элементе управления, для формы – текст, отображаемый в строке заголовка формы, определите с помощью значения свойства Caption.
6. Чтобы написать процедуру обработки событий нажатия кнопки «зашифровать» (событие Click), дважды щелкните на элементе управления CommandButton1, или воспользуйтесь командой контекстного меню View Code.
7. В окно редактирования кода необходимо ввести следующий текст:

```
Private Sub CommandButton1_Click()
'шифровка
m = TextBox1.Value
n = Len(m)
c = Space(n)
k = TextBox4.Value
If TextBox1.Text = "" Then MsgBox "Введите текст": GoTo 1
If TextBox4.Text = "" Then MsgBox "Введите ключ": GoTo 1
For i = 1 To n
r = Ca(Mid(m, i, 1), k)
c = c & r
Next i
TextBox2.Value = c
1:
End Sub
Private Function Ca(A, Sh)
Dim chrnew As Integer
Select Case Asc(A)
       Case 224 To 255 'строчные буквы
       chrnew = ModMew(Asc(A) + Sh - 224, 32) + 224
       Ca = Chr(chrnew)
       Case 192 To 223 'прописные буквы
       chrnew = ModMew(Asc(A) + Sh - 192, 32) + 192
       Ca = Chr(chrnew)
       Case Else
       Ca = A
       End Select
End Function
Private Function ModMew(A, B)
If A >= 0 Then
ModMew = A Mod B
Else
ModMew = (B + A) Mod B
End If
End Function

Private Sub CommandButton2_Click()
'расшифровка
m = TextBox2.Value
c = Space(n)
k = TextBox4.Value
If TextBox2.Text = "" Then MsgBox "Введите шифротекст": GoTo 1
If TextBox4.Text = "" Then MsgBox "Введите ключ": GoTo 1
n = Len(m)
For i = 1 To n
r = Ca(Mid(m, i, 1), -k)
c = c & r
Next i
TextBox3.Value = c
1:
End Sub
```

8. Выполните команду Debug/Compile VBA.

9. Для того чтобы проверить, как работает созданная программа, поместите курсор в поле кода программы и нажмите клавишу F5 или выберите команду RUN/RUN SUB/USERFORM.
10. В результате диалог будет выглядеть, как представлено на рис.19.

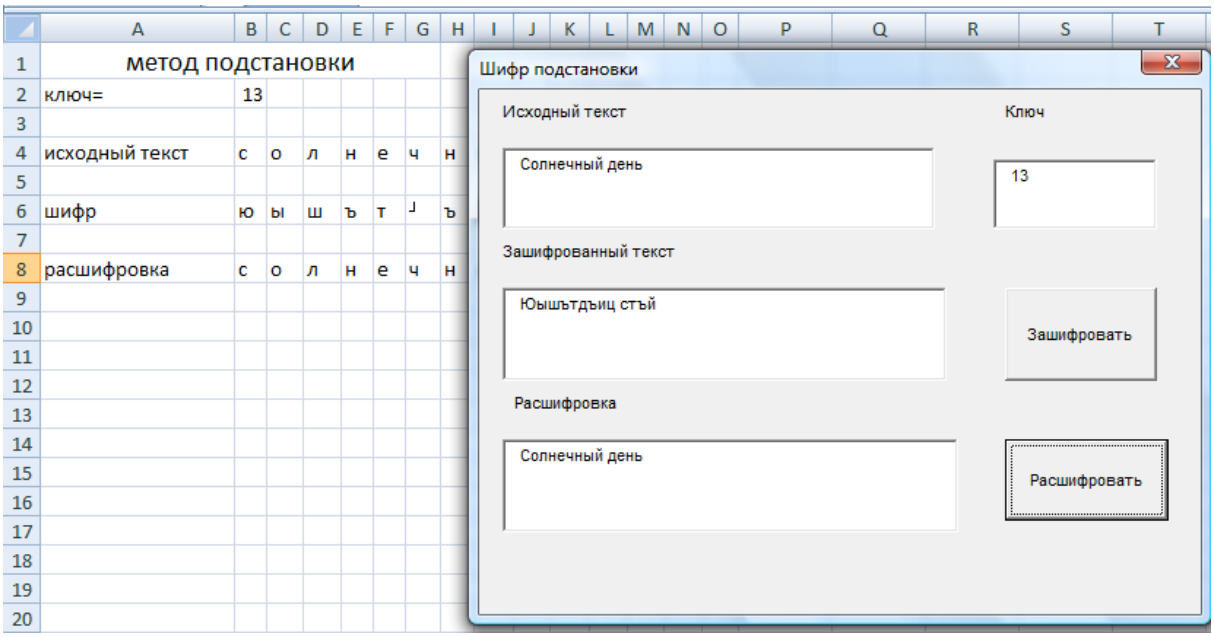

Рис.19

11. Для запуска формы с листа Лаб. раб. № 3 создадим кнопку запуска программы. Обычную кнопку (элемент управления формы) и кнопку команды (элемент ActiveX) можно использовать для запуска макроса, выполняющего определенные действия при нажатии пользователем кнопки.
12. Для добавления кнопки (элемент управления формы) ознакомитесь, доступна ли вкладка Разработчик. Если вкладка Разработчик недоступна, то ее нужно отобразить.

    a. Нажмите кнопку Microsoft Office , а затем щелкните Параметры Excel.
    b. В категории Основные в разделе Основные параметры работы с Excel установите флажок **Показывать вкладку "Разработчик" на ленте**, а затем нажмите кнопку ОК.

13. На вкладке Разработчик в группе Элементы управления нажмите кнопку **Вставить**, а затем в разделе Элементы управления формы выберите элемент Кнопка .

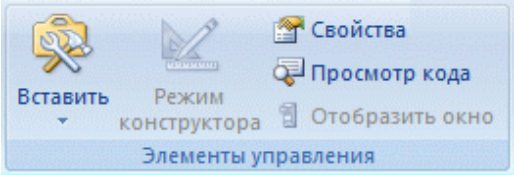

Рис.20

14. Щелкните на листе место, где должен быть расположен левый верхний угол кнопки. Подпишите кнопку «Запуск программы»
15. Для запуска формы с листа Лаб. раб. №3 щелкните на кнопке «Запуск программы» правой кнопкой мышки. В контекстном меню выберите команду **Назначить макрос**… В появившемся диалоговом окне нажмите кнопку **Создать**. В результате попадаем в поле, в котором необходимо писать процедуру работы Кнопки

```
Private Sub CommandButton1_Click()
UserForm1.Show
End Sub
```

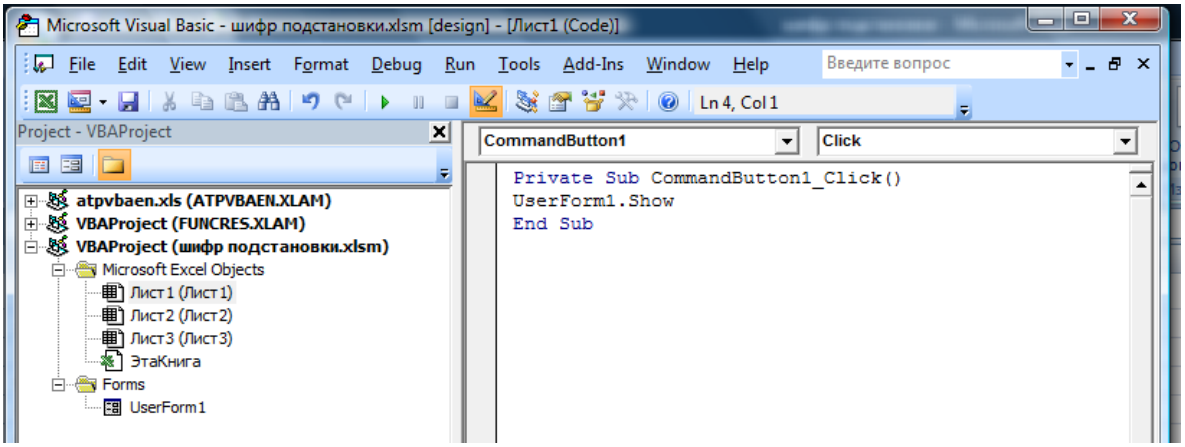

Рис.21.

16. Перейдите на лист Лаб. раб №3. И проверьте работу кнопки «Запуск программы».
17. Нажмите кнопку Microsoft Office , выберете команду Сохранить как Книга Excel с поддержкой макросов.

Индивидуальные задания по лабораторной работе №3.

Задание 1. Работа алгоритма шифрования средствами электронных таблиц была проверена на значениях ключа до 50. Было обнаружено, что реализованный таким образом алгоритм шифрования для фразы «солнечный день» не работает при следующих значениях ключа: 4, 5, 9, 15, 18, 19, 21, 23, 27, 28, 50. Объясните: в чем причина?

Задание 2. Реализованный алгоритм шифрования средствами VBA позволяет шифровать фразы, записанные на русском языке. При этом в зашифрованном тексте строчная буква появляется на месте строчной буквы в исходном тексте. Пробелы в шифротексте появляются в тех же позициях, в каких они находятся в исходном тексте. Объясните причину указанных недостатков.

Задание 3. Сравните зашифрованный текст, полученный при шифровании средствами электронных таблиц и зашифрованный текст, полученный при шифровании средствами VBA. Объясните причину различия шифротекстов.

Задание 4. Зашифровать выражения. Варианты заданий приведены в табл. 15.

Таблица 15

№	Текст	№	Текст
1	Высокие деревья больше подвластны ветрам, а честолюбивые люди - ударам судьбы. Пенн	11	Никто так не падок на лесть, как тот честолюбец, который хотел бы быть первым, но не смог им стать. Спиноза
2	Чем тоньше лед, тем больше всем хочется узнать, выдержит ли он. Биллингс	12	Моя заветная мечта - сказать десятком предложений то, на что другим требуется целая книга. Ницше
3	Однажды испорченную репутацию, вероятно, можно восстановить, но мир будет все время оглядываться на то место, где была трещина. Холл	13	Если Вы подберете голодную собаку и устроите ей роскошную жизнь, она никогда не укусит Вас. В этом главная разница между собакой и человеком. Марк Твен
4	Важно не только уметь сказать нужную вещь в нужный момент, но и уметь не сказать не нужного, когда очень хочется. Сала	14	Истинная дружба - медленно растущее растение, которое должно быть испытано в беде и несчастье, прежде чем заслужить такое название. Джордж Вашингтон
5	Молчание - самое совершенное выражение презрения. Бернард Шоу	15	Наша необразованность в основном преодолима. Мы не знаем, потому что не хотим знать. Хаксли
6	Не насмехайся над природными недостатками тех, кто не может их исправить. Жестоко бить калеку его же костылями. Фуллер	16	Чтобы добиться успеха в этом мире, недостаточно быть просто глупым, нужно еще иметь хорошие манеры. Вольтер
7	Лицемер: человек, убивший своих родителей... и просящий о снисхождении на основании того, что он сирота. Линкольн	17	Бояться надо не тех, кто не согласен с вами, а тех, кто не согласен с Вами и боится Вам об этом сказать. Наполеон
8	Веселость нрава дарит нам долголетие в жизни, а потом и в памяти окружающих. Она рождена добром. Бови	18	Музыка стоит на втором месте после молчания, когда речь идет о том, чтобы выразить невыразимое. Хаксли
9	Испробуй все возможности. Всегда важно знать, что ты сделал все, что мог. Диккенс	19	Гордец редко бывает благодарным, ибо всегда считает, что получил меньше, чем заслуживает. Бичер
10	Необходимость - мать изобретательности. Свифт.	20	Я обычно сужу о человеке по тому, что вызывает его смех. Мизнер

4.4 Лабораторная работа № 4

Тема: Системы с закрытым ключом. Шифр многоалфавитной замены.

Суть метода: Шифрование производится по алгоритму многоалфавитной замены с использованием таблицы Виженера. Шифрование средствами VBA.

Реализация алгоритма на ЭВМ.

1. Запустите программу Microsoft Excel (Пуск – Все Программы – Microsoft Office Excel 2007).
2. Лист 1 рабочей книги Excel переименуйте. Назовите Лаб. раб. №4.
3. В каждую ячейку первой строки листа, начиная с ячейки A1, последовательно введите буквы русского алфавита.
4. На вкладке Разработчик в группе Элементы управления нажмите кнопку **Вставить**, а затем в разделе Элементы ActiveX выберите элемент Поле (элемент ActiveX). Вставьте данное текстовое поле в строку 3.
5. На вкладке Разработчик в группе Элементы управления нажмите кнопку **Вставить**, а затем в разделе Элементы ActiveX выберите элемент Кнопка (элемент управления формы). Выберите на листе место, где должен быть расположен левый верхний угол кнопки. Подпишите кнопку «Подготовка».
6. В результате двойного щелчка на кнопке «Подготовка» попадаем в поле (Microsoft Excel Object Лист 1), в котором необходимо писать процедуру работы Кнопки

```
Private Sub CommandButton1_Click()
Dim i, j, n, c As Integer
Dim st As String
st = TextBox1.Text
n = Len(st)
Cells(4, 35).Value = n
If TextBox1.Text = "" Then MsgBox "Введите набор символов"
For j = 0 To n - 1
For i = 1 To n
Cells(5 + j, i).Value = Mid(st, j + i, 1)
If i + j > n Then
For c = 1 To (j)
Cells(5 + j, i + c - 1).Value = Mid(st, c, 1)
Next c
GoTo 1
End If
Next i
1:
Next j
End Sub
```

7. Выполните команду Debug/Compile VBA.
8. Вернитесь на лист Лаб. раб. №4. В результате щелчка по кнопке «Подготовка» на лист будет выведено сообщение "Введите набор символов" (рис. 22). Это предполагает, что может быть введен произвольный алфавит, за исключением числовых значений.

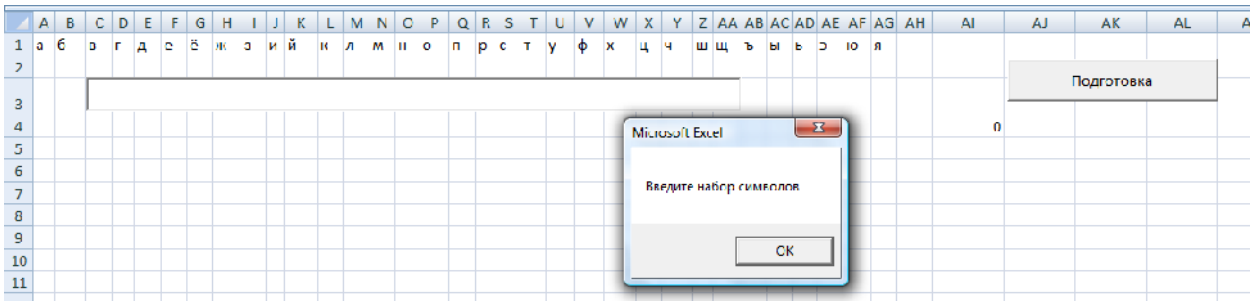

Рис. 22

9. Вводим в текстовое поле строки 3 русский алфавит «абвгдеёжзийклмнопрстуфхцчшщъыьэюя », дополнив его после буквы «я» пробелом.
10. Щелчок на кнопке «Подготовка» приведет к тому, что в строках с 5 по 38 будет представлена таблица Виженера, которая частично видна на рис.24.
11. Нажмите Alt-F11. Откроется окно редактирования VBA.
12. В редакторе VBA выполнить команду Insert/Module. Выберите команду Insert/UserForm. В редакторе Visual Basic появятся: окно пользовательской формы и панель инструментов Панель элементов. На Панели элементов находятся все необходимые для проектирования формы элементы.
13. Используя диалоговое окно Свойства (для вызова этого окна, если оно отсутствует, выполните команду View/Properties Windows) и Панель элементов, простым перетаскиванием элементов управления на форму, создайте пользовательскую форму в виде, представленном на рис.23.

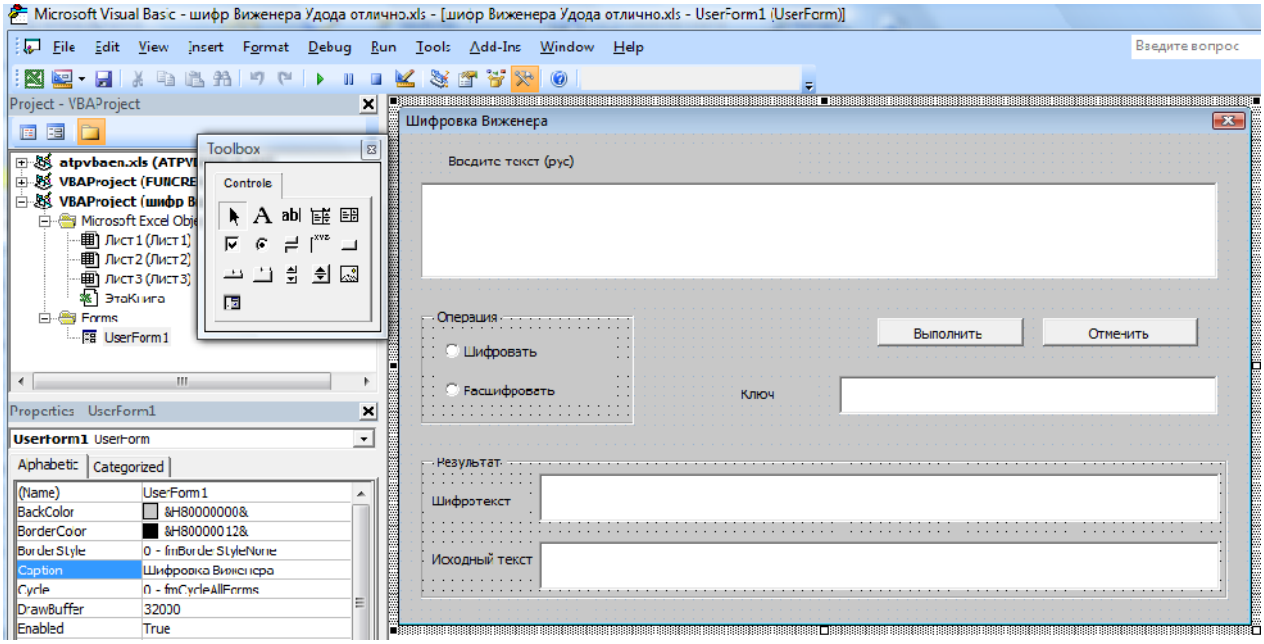

Рис.23

14. Чтобы написать процедуру обработки событий нажатия кнопки «зашифровать» (событие Click), дважды щелкните на элементе управления CommandButton1, или воспользуйтесь командой контекстного меню View Code.
15. В окно редактирования кода необходимо ввести следующий текст:

```
Private Sub UserForm_Initialize()
CommandButton1.Caption = "Выполнить"
CommandButton2.Caption = "Отменить"
OptionButton1.Caption = "Шифровать"
OptionButton2.Caption = "Расшифровать"
OptionButton1.Value = True
OptionButton2.Value = False
End Sub


Sub текст(видимость)
Frame2.Visible = видимость
TextBox1.Visible = видимость
TextBox2.Visible = видимость
TextBox3.Visible = видимость
End Sub

Private Sub CommandButton1_Click()
Dim str As String, strT As String, strR As String, key As
String, bb As String, st As String, s As String
Dim n, c, k, l As Long, i, j As Long
Dim a, b, x As Integer

str = TextBox1.Text
n = Len(str)
strT = Space(n)
key = TextBox4.Text
k = Len(key)
c = Sheets("Лист1").Cells(4, 35).Value
bb = Space(n)
x = 1

If OptionButton1.Value = True Then
If TextBox1.Text = "" Then MsgBox "Введите исходный текст":
GoTo 1
If TextBox4.Text = "" Then MsgBox "Введите ключ": GoTo 1
'прописывание текста через ключ
For i = 1 To n
If x <= k Then
Mid(bb, i, 1) = Mid(key, x, 1)
Else:
x = 1
Mid(bb, i, 1) = Mid(key, x, 1)
End If
x = x + 1
Next i
'MsgBox bb

'кодирование
For i = 1 To n
For j = 1 To c
```

```
If Sheets("Лист1").Cells(4 + j, 1).Value = Mid(bb, i, 1) Then
a = j + 4
Next j

For l = 1 To c
If Sheets("Лист1").Cells(5, l).Value = Mid(str, i, 1) Then
b = l
GoTo 2
Else:
If l = c Then
s = Mid(str, i, 1)
MsgBox "Такого символа нет: " & s & "!": GoTo 1
End If

End If
Next l
2:
Mid(strT, i, 1) = Sheets("Лист1").Cells(a, b).Value
Next i
End If
TextBox2.Text = strT

'расшифровка
If OptionButton2.Value = True Then
If TextBox1.Text = "" Then MsgBox "Введите шифротекст": GoTo 1
If TextBox4.Text = "" Then MsgBox "Введите ключ": GoTo 1

st = TextBox1.Text
n = Len(st)
strR = Space(n)
bb = Space(n)
x = 1
key = TextBox4.Text
k = Len(key)
'пропись через ключ
For i = 1 To n
If x <= k Then
Mid(bb, i, 1) = Mid(key, x, 1)
Else:
x = 1
Mid(bb, i, 1) = Mid(key, x, 1)
End If
x = x + 1
Next i
'MsgBox bb

For i = 1 To n
For j = 1 To c
If Mid(bb, i, 1) = Sheets("Лист1").Cells(4 + j, 1).Value Then
a = j + 4
For l = 1 To c
If Mid(st, i, 1) = Sheets("Лист1").Cells(a, l).Value Then
```

```
b = l
GoTo 3
Else:
If l = c Then
s = Mid(st, i, 1)
MsgBox "Такого символа нет: " & s & "!": GoTo 1
End If

End If
Next l
End If
Next j
3:
Mid(strR, i, 1) = Sheets("Лист1").Cells(5, b).Value
Next i

End If
TextBox3.Text = strR
1:
End Sub

Private Sub CommandButton2_Click()
UserForm1.Hide
TextBox1.Text = ""
TextBox2.Text = ""
TextBox3.Text = ""
End Sub

Private Sub OptionButton1_Click()
OptionButton1.Value = True
Расшифровать = False
End Sub

Private Sub OptionButton2_Click()
Шифровать = False
OptionButton2.Value = True
End Sub
```

16. Перейдите на лист Лаб. раб. №4. На вкладке Разработчик в группе Элементы управления нажмите кнопку **Вставить**, а затем в Элементы ActiveX выберите элемент Кнопка (элемент управления формы) . Выберите на листе место, где должен быть расположен левый верхний угол кнопки. Подпишите кнопку «Форма».
17. Для запуска формы с листа Лаб. раб. №4 с помощью кнопки «Форма» необходимо в Microsoft Excel Object Лист 1 поместить следующий код работы Кнопки

```
Private Sub CommandButton2_Click()
UserForm1.Show
End Sub
```

18. В результате окно диалога шифрования будет выглядеть, как представлено на рис.24.

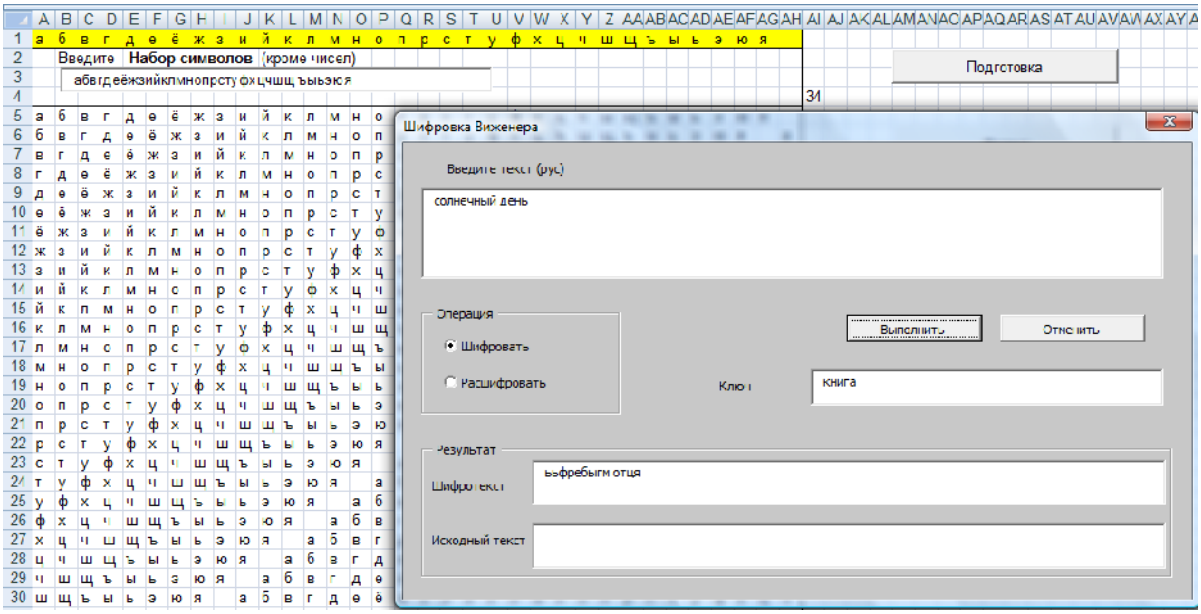

Рис.24

19. Окно диалога расшифровки показано на рис. 25.

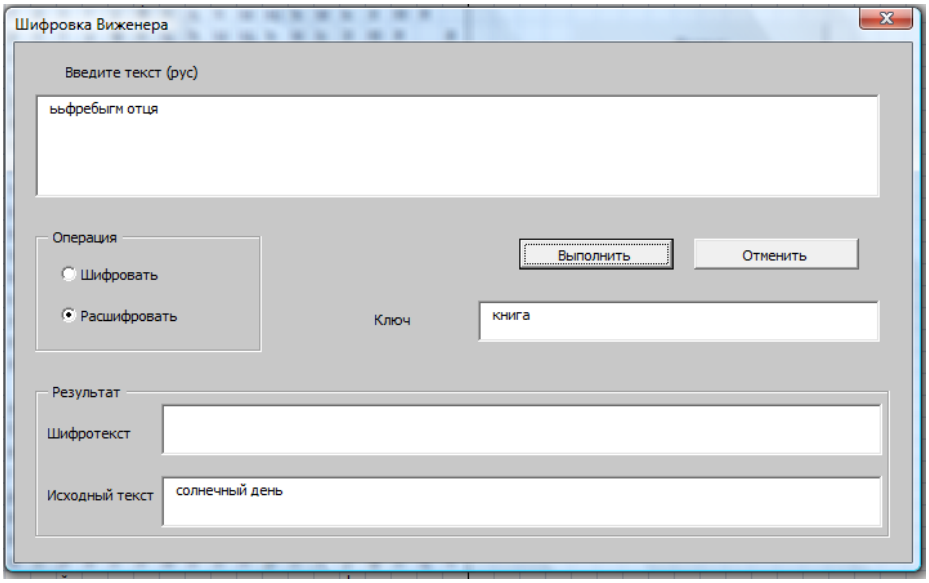

Рис. 25

20. Нажатие кнопки «Отменить» приведет к закрытию окна формы.

Замечание. Обратите внимание, что и исходный, и зашифрованный текст необходимо вводить в поле Введите текст (рус). Для того чтобы не набирать шифротекст вручную, его достаточно выделить и скопировать нажатием клавиш Ctrl+c. Для того чтобы вставить скопированный текст, поместите курсор в поле Введите текст (рус) и нажмите клавиши Ctrl+v.

4.5 Лабораторная работа № 5

Тема: Системы с закрытым ключом. Шифрование методом перестановки.

Суть метода: Шифрование методом подстановки основано на перестановке символов в исходном тексте по определенному алгоритму. В данной лабораторной работе будем использовать маршрутную перестановку, а именно простую колонную перестановку. Шифрование производим средствами VBA.

Реализация алгоритма на ЭВМ.

1. Откройте лист Лаб. раб. № 5 нажмите Alt-F11. В открывшемся окне редактирования VBA выполните команду Insert – UserForm. Создайте на форме три текстовых поля и две кнопки. Первое текстовое поле будет содержать исходный текст, второе – шифротекст, третье поле – ключ, определяющий размер таблицы перемешивании символов. Окончательный вид UserForm представлен на рис. 26.

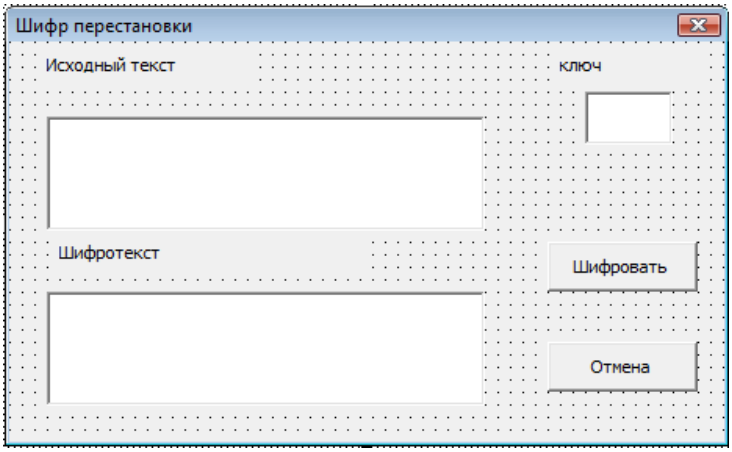

Рис.26

2. Процедуру обработки событий нажатия кнопки «Шифровать», введем в окно редактирования кода

```
Private Sub CommandButton1_Click()
Dim i, j As Integer
Dim M, c As String
M = TextBox1.Value
k1 = TextBox3.Value
k = Len(M)
If TextBox1.Text = "" Then MsgBox "Введите исходный текст": GoTo
1
If TextBox3.Text = "" Then MsgBox "Введите ключ": GoTo 1
'проверка ключа
If k1 = 1 Then MsgBox ("Введите другой ключ, на этом ключе вы не
получите шифротекст"): GoTo 1
'определение размера прямоугольника, в который вписываем текст
If (k Mod k1) = 0 Then
k2 = k / k1
Else
k2 = k \ k1 + 1
End If
'проверка ключа
If k2 = 1 Then MsgBox ("Введите другой ключ, на этом ключе вы не
получите шифротекст"): GoTo 1
For j = 1 To k1
```

```
For i = 1 To k2
Cells(i, j) = Mid(M, j + (i - 1) * k1, 1)
Next i
Next j
c = ""
For j = 1 To k1
For i = 1 To k2
c = c & Cells(i, j)
Next i
Next j
TextBox2.Value = c
1:
End Sub
```

3. Процедуру обработки событий нажатия кнопки «Отмена», введем в окно редактирования кода

```
Private Sub CommandButton2_Click()
'закрыть форму
UserForm1.Hide
TextBox1.Text = ""
TextBox2.Text = ""
TextBox3.Text = ""
End Sub
```

4. В результате введения исходного текста и ключа в поле формы после нажатия кнопки «Шифровать» диалоговое окно примет вид, показанный на рис.27.

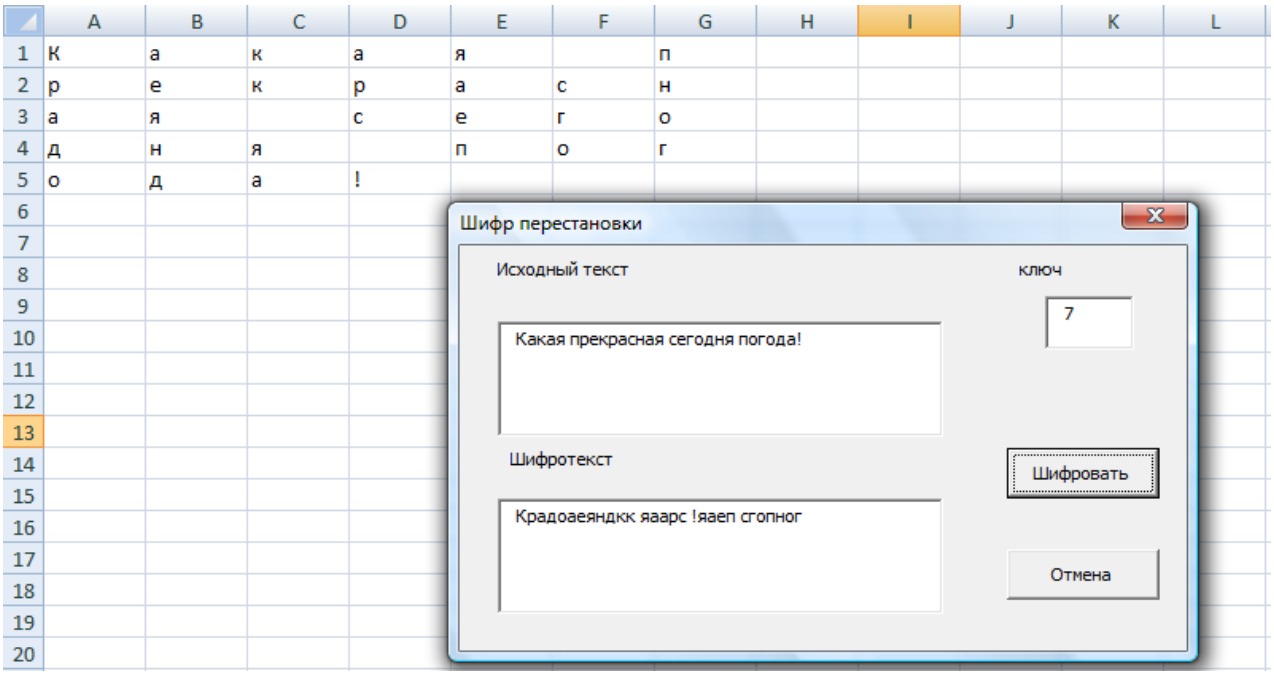

Рис.27

5. Нажатие кнопки «Отмена» приведет к закрытию окна формы.

Индивидуальные задания по лабораторной работе №5.

Задание 1. Поэкспериментируйте, вводя различные значения ключа. При каких значениях ключа не удается зашифровать текст и почему?

Задание 2. Создайте средство расшифровки.

Задание 3. Зашифровать выражения. Варианты заданий приведены в табл. 15.

4.6 Лабораторная работа № 6

Тема: Создание пользовательской формы – Шифратор файлов.

Задача: Задано:

а) из диалогового окна Открытие документа выбирается исходный текстовый файл(*.txt), который требуется зашифровать с помощью шифра простой перестановки;

б) зашифрованный файл необходимо расшифровать, зная ключ – шифр простой перестановки.

Формализация задачи. Определим исходные и выходные данные. Исходные данные – произвольный текстовый файл. (Воспользуйтесь имеющимся файлом «Текст» или в редакторе Блокнот создайте свой текстовый файл)
Выходные данные – а) зашифрованный файл;
б) расшифрованный (исходный) файл.

Разработка алгоритма. Для решения поставленной задачи создадим программу, позволяющую выбрать необходимый текстовый файл, считать содержимое выбранного файла и с помощью подпрограммы осуществить шифрование (расшифровывания). Шифрование (Расшифрование) осуществим согласно правилу, по которому буквы в тексте переставляются в обратном порядке.

Реализация алгоритма на ЭВМ. Спроектируем форму пользователя.

1. Откройте документ Microsoft Excel.
2. Выполните команду Сервис/Макрос/Редактор Visual Basic.
3. Выберите команду Insert/UserForm. В редакторе Visual Basic появятся: окно пользовательской формы и панель инструментов Панель элементов.
4. Используя диалоговое окно Свойства (для вызова этого окна, если оно отсутствует, выполните команду View/Properties Windows) и Панель элементов, простым перетаскиванием элементов управления на форму, создайте пользовательскую форму в виде, представленном на рис.28.

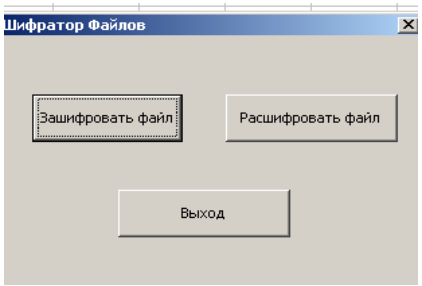

Рис.28

5. В окно редактирования кода необходимо ввести следующие процедуры:

```
Private Sub Перестановка(strTest, strS)
'процедура выполняет перестановку символов в строке
Dim i As Long, n As Long
n = Len(strTest)
strS = Space(n)
For i = 1 To n
tmp = Mid(strTest, n - i + 1, 1)
Mid(strTest, n - i + 1, 1) = Mid(strTest, i, 1)
Debug.Print strTest
Mid(strS, i, 1) = tmp
Next i
Debug.Print strS
End Sub

Private Sub CommandButton1_Click()
'процедура выбора файла и его шифрования
Dim FSys As New FileSystemObject
Dim sFname As Variant
Dim Tfile As TextStream
Dim TextOfFile As String, CryptoText As String
    Set FSys = CreateObject("Scripting.FileSystemObject")
    sFname = Application.GetOpenFilename("Txt file (*.txt),
*.txt")
    If sFname = False Then
    MsgBox "Файл не выбран"
    Exit Sub
    End If
    Set Tfile = FSys.OpenTextFile(sFname, ForReading, False,
TristateFalse)
   TextOfFile = Tfile.ReadAll
    Tfile.Close
TextOfFile = LCase(TextOfFile)
Перестановка TextOfFile, CryptoText
Set Tfile =
FSys.CreateTextFile(Application.GetSaveAsFilename("Зашифрованный
текст", fileFilter:="Текстовые файлы (*.txt), *.txt"))
        Tfile.Write CryptoText
    Tfile.Close
Set Tfile = Nothing
Set FSys = Nothing
End Sub

Private Sub CommandButton2_Click()
'процедура выбора файла и его расшифрования
Dim FSys As New FileSystemObject
Dim Tfile As TextStream
Dim TextOfFile As String, CryptoText As String
Dim sFname As Variant
     Set FSys = CreateObject("Scripting.FileSystemObject")
   sFname = Application.GetOpenFilename("Txt file (*.txt),
*.txt")
    If sFname = False Then
```

```
    MsgBox "Файл не выбран"
    Exit Sub
    End If
    Set Tfile = FSys.OpenTextFile(sFname, ForReading, False,
TristateFalse)
   TextOfFile = Tfile.ReadAll
    Tfile.Close
TextOfFile = LCase(TextOfFile)
Перестановка TextOfFile, CryptoText
    Set Tfile =
FSys.CreateTextFile(Application.GetSaveAsFilename("Расшифрованны
й текст", fileFilter:="Текстовые файлы (*.txt), *.txt"))
        Tfile.Write CryptoText
    Tfile.Close
Set Tfile = Nothing
Set FSys = Nothing
End Sub

Private Sub CommandButton3_Click()
'закрыть форму
UserForm1.Hide
End Sub
```

При нажатии кнопки «Зашифровать файл» («Расшифровать файл») появится окно «Открытие документа». При помощи этого окна пользователь может выбрать требуемый файл. Нажатие кнопки «Открыть» приведет к тому, что выбранный текстовый файл будет загружен в буфер обмена. В коде также осуществляется проверка на пустоту выбранного файла. Если файл не выбран, то на экран выводится диалоговое окно с сообщением. Для корректной работы программы необходимо установить ссылку на Microsoft Scripting Runtime в диалоговом окне References – VBA Project , которое отображается на экране выбором команды Tools/ References.

Правильность работы шифраторов проверить:

1) поместить зашифрованный файл на рабочий стол и сравнить его содержание с исходным файлом.

2) с помощью шифратора расшифровать зашифрованный файл, поместить его на рабочий стол и сравнить его содержание с содержанием исходного файла.

Для промежуточной отладки может быть использован отладчик Debug.

4.7 Лабораторная работа № 7

Тема: Создание пользовательской формы – Вычисление хеш-функции.

Задача: создать пользовательскую форму, вычисляющую хеш-функцию произвольного текста.

Формализация задачи. Определим исходные и выходные данные.

a) Исходные данные – Входной текст, состоящий из слов русского языка.
b) Выходные данные – вычисленная хеш-функция. Длина хеш - кода должна составлять 256 бит.

Разработка алгоритма. Для решения поставленной задачи создается пользовательская форма с программным кодом, позволяющим для исходного текста составить хеш-функцию. Расчет хеш-функции выполняется на основе создания случайных значений начального хэша и хэш модуля.

Реализация алгоритма на ЭВМ.

1. Откройте документ Microsoft Excel.
2. Выполните команду Сервис/Макрос/Редактор Visual Basic.
3. Выберите команду Insert/UserForm. В редакторе Visual Basic появятся: окно пользовательской формы и панель инструментов Панель элементов.
4. Используя диалоговое окно Свойства (для вызова этого окна, если оно отсутствует, выполните команду View/Properties Windows) и Панель элементов, простым перетаскиванием элементов управления на форму, создайте пользовательскую форму в виде, представленном на рис.29.

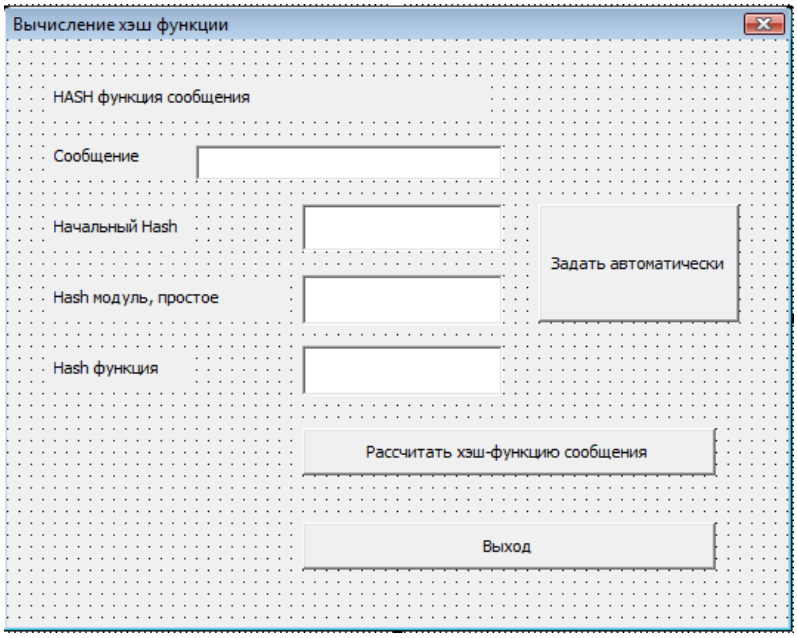

Рис.29

5. Процедуру обработки событий нажатия кнопки «Задать автоматически», позволяющую рассчитать начальные значения начального хэша и хэш модуля, введем в окно редактирования кода

```
Private Sub CommandButton2_Click()
K = 0
Randomize
Z = Round(1000 * Rnd())
I = 1
D = 0
While K <> 1
For I = 1 To Z
If (Z \ I) = (Z / I) Then D = D + 1
Next I
If D = 2 Then K = 1: GoTo 1 Else Z = Z - 1: K = 0: D = 0
Wend
1: H0 = Z
TextBox2.Text = H0
```

```
K = 0
Randomize
Z = Round(1000 * Rnd())
I = 1
D = 0
While K <> 1
For I = 1 To Z
If (Z \ I) = (Z / I) Then D = D + 1
Next I
If D = 2 Then K = 1: GoTo 2 Else Z = Z - 1: K = 0: D = 0
Wend
2: P = Z
TextBox3.Text = P
TextBox4.Text = ""
End Sub
```

6. Процедуру обработки событий нажатия кнопки «Рассчитать хеш-функцию сообщения», введем в окно редактирования кода

```
Dim S As String
Dim m() As Integer
Dim H0, H, P, Z, K, D As Integer
Private Sub CommandButton1_Click()
S = TextBox1.Text
H0 = Val(TextBox2.Text)
P = Val(TextBox3.Text)
If S = "" Then
       MsgBox ("Задана пустая строка сообщения")
       End If
If H0 = 0 Then
       MsgBox ("Не задан начальный хэш")
       End If
If P = 0 Then
       MsgBox ("Не задан хэш модуль")
       End If

For I = 1 To Len(S)
ReDim m(I)
m(I) = Val(Mid(S, I, 1))
Next

For I = 1 To Len(S)
H = ((m(I) + H0) ^ 2) Mod P
H0 = H
Next
TextBox4.Text = H
End Sub
```

7. Процедуру обработки событий нажатия кнопки «Выход», запишем в окно редактирования кода

```
Private Sub CommandButton3_Click()
'закрыть форму
```

```
UserForm1.Hide
TextBox1.Text = ""
TextBox2.Text = ""
TextBox3.Text = ""
TextBox4.Text = ""
End Sub
```

8. В результате введения исходного текста сообщения и выполнения операций автоматического задания начальных значений начального хэша и хэш модуля после нажатия кнопки «Шифровать» диалоговое окно примет вид, показанный на рис.30.

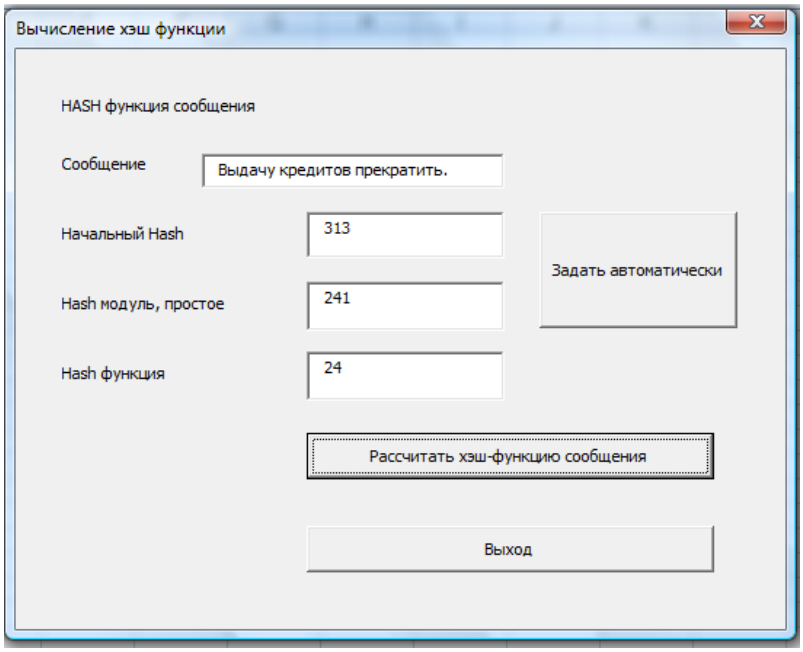

Рис.30

9. Нажатие кнопки «Выход» приведет к закрытию формы.

Индивидуальные задания по лабораторной работе №7.

Задание 1. Поэкспериментируйте с созданной пользовательской формой, задавая различные начальные значения начального хэша и хэш-модуля для одного и того же текста сообщения. Объясните, почему так происходит? Отвечает ли созданная в данной лабораторной работе хеш-функция всем необходимым требованиям, предъявляемым к хеш-функции?

Задание 2. Поэкспериментируйте с созданной пользовательской формой, задавая различные исходные сообщения: сообщения содержащие числа, сообщения на английском или немецком языках. Проанализируйте результат.

Задание 3. Вычислите по своему варианту задания хеш-функцию для выражения, приведенного в табл. 15.

4.8 Лабораторная работа № 8

Тема: Создание пользовательской формы, реализующей алгоритм шифра RSA.

Задача: По двум простым числам *p,q* вычислить число *n*, равное произведению *p* и *q* (*n*=*pq*), а также сгенерировать случайным образом целое число *E*, взаимно простое с произведением (*p*-1)(*q*-1) и секретный ключ *D*. Используя секретный ключ *D* зашифровать произвольное числовое сообщение (таким сообщением может быть хеш-функция некоторого текстового сообщения).

С целью проверки правильности выполнить расшифровку сообщения.

Формализация задачи. Определим исходные и выходные данные.

Исходные данные – число m, удовлетворяющее требованию m≤ *n*-1, два простых числа *p,q*.

Выходные данные – секретный ключ шифрования *D* , пара целых чисел - открытый ключ: *n* и *E*, а также зашифрованное и расшифрованное исходное число m.

Разработка алгоритма. Для решения поставленной задачи создадим программу, позволяющую вычислить открытый ключ: *n* и *E* и соответствующий ему секретный ключ *D*, считать содержимое исходного числового сообщения и с помощью программы осуществить шифрование и расшифровывание с использованием полученных ключей. Для удобства пользователя создадим процедуру, которая выводит в окно формы таблицу простых чисел.

Реализация алгоритма на ЭВМ. Спроектируем форму пользователя.

1. Откройте документ Microsoft Excel.
2. Выполните команду Сервис/Макрос/Редактор Visual Basic.
3. Выберите команду Insert/UserForm. В редакторе Visual Basic появятся: окно пользовательской формы и панель инструментов Панель элементов.
4. Используя диалоговое окно Свойства (для вызова этого окна, если оно отсутствует, выполните команду View/Properties Windows) и Панель элементов, простым перетаскиванием элементов управления на форму, создайте пользовательскую форму в виде, представленном на рис.31.

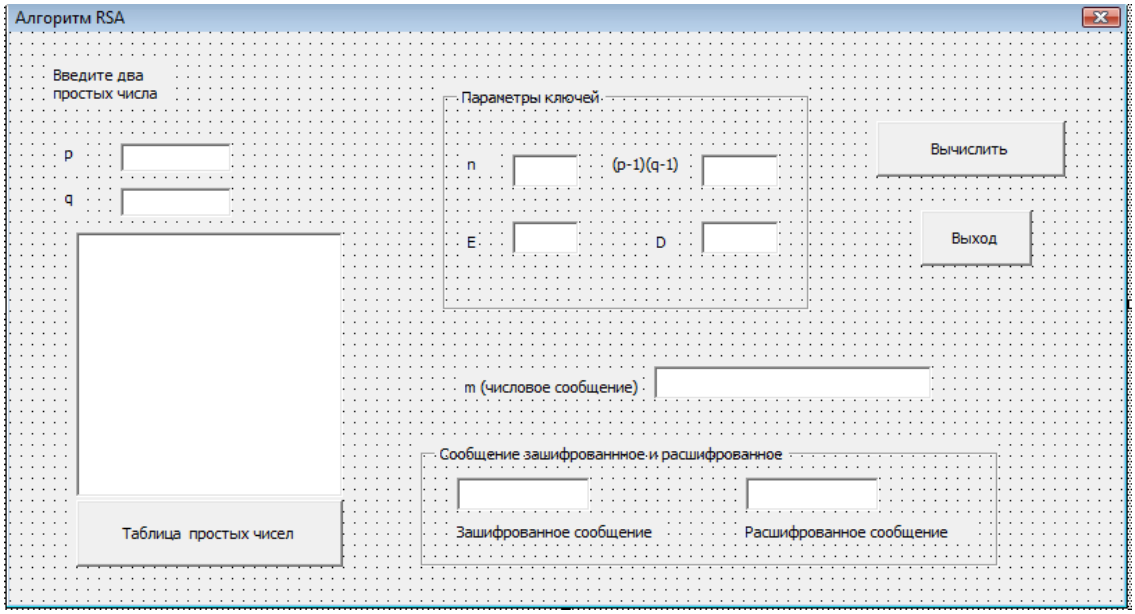

Рис.31

5. С созданной формой свяжите следующий программный код, обеспечивающий выполнение операций, реализуемых при нажатии на кнопках формы.

```
Option Explicit
Private Sub CommandButton1_Click()
If Not IsNumeric(Text1.Text) Then
MsgBox ("введите число p")
Return
End If
If Not IsNumeric(Text2.Text) Then
MsgBox ("введите число q")
Return
End If
If Not IsNumeric(Text7.Text) Then
MsgBox ("введите число m")
Return
End If
Dim p As Long, q As Long, n As Long, e As Long, PHI As Long, d
As Long, m As Long, c As Long
p = Text1.Text
q = Text2.Text
If (check_prime(p) = False) Then
    MsgBox ("p слишком велико или не является про-
стым,обратитесь к таблице простых чисел")
Else
    If (check_prime(q) = False) Then
        MsgBox ("q слишком велико или не является про-
стым,обратитесь к таблице простых чисел")
    Else
        n = p * q
        Text3.Text = n
        PHI = (p - 1) * (q - 1)
        e = getE((PHI))
        d = getD((e), (PHI))
        Text4.Text = PHI
        Text5.Text = d
        Text6.Text = e
        m = Text7.Text
        If m > n - 1 Then MsgBox ("число m не может быть за-
шифровано"): GoTo 1
        If m ^ e > 2147483647 Then MsgBox ("число m не может
быть зашифровано, в данной программе"): GoTo 1
        c = (m ^ e) Mod n
        Text8.Text = c
        m = decrypt(c, n, d)
        Text9.Text = m
        Label12.Caption = "Ключ дешифрования =<" + Str(d) +
"," + Str(n) + ">"
        Label13.Caption = "Ключ шифрования   =<" + Str(e) +
"," + Str(n) + ">"
    End If
```

```
End If
1:
End Sub


Private Function check_prime(ByVal val As Long) As Boolean
Dim primes, i As Integer, prime As Boolean
primes = Array(1, 2, 3, 5, 7, 11, 13, 17, 19, 23, 29, 31, 37,
41, 43, 47, 53, _
    59, 61, 67, 71, 73, 79, 83, 89, 97, 101, 103, 107, 109,
113, 127, 131, 137, _
    139, 149, 151, 157, 163, 167, 173, 179, 181, 191, 193,
197, 199, 211, 223, 227, _
    229, 233, 239, 241, 251, 257, 263, 269, 271, 277, 281,
283, 293, 307, 311, 313, _
    317, 331, 337, 347, 349, 353, 359, 367, 373, 379, 383,
389, 397)
check_prime = False
For i = 0 To 78
    If (val = primes(i)) Then
        prime = True
    End If
Next i
check_prime = prime
End Function


Private Function decrypt(ByVal c As Long, ByVal n As Long,
ByVal d As Long) As Long
Dim i As Long
Dim g As Long
Dim f As Long
On Error GoTo errorhandler
If (d Mod 2 = 0) Then
    g = 1
Else
    g = c
End If
For i = 1 To Int(d / 2)
    f = c * c Mod n
    g = f * g Mod n
Next i
decrypt = g
Exit Function

errorhandler:
Select Case Err.Number
    Case 6
        Status.Text = "Переполнение, задайте меньшие значения"
    Case Else
        Status.Text = "Ошибка вычисления"
End Select
```

```
End Function


Private Function getD(ByVal e As Long, ByVal PHI As Long) As
Long
Dim u(3) As Long
Dim v(3) As Long
Dim q As Long
Dim temp1 As Long
Dim temp2 As Long
Dim temp3 As Long
u(0) = 1: u(1) = 0: u(2) = PHI: v(0) = 0: v(1) = 1: v(2) = e
While (v(2) <> 0)
    q = Int(u(2) / v(2))
    temp1 = u(0) - q * v(0)
    temp2 = u(1) - q * v(1)
    temp3 = u(2) - q * v(2)
    u(0) = v(0)
    u(1) = v(1)
    u(2) = v(2)
    v(0) = temp1
    v(1) = temp2
    v(2) = temp3
Wend
If (u(1) < 0) Then
    getD = (u(1) + PHI)
Else
    getD = u(1)
End If
End Function


Private Function getE(ByVal PHI As Long) As Long
Dim great As Long
Dim e As Long
great = 0
e = 2

While (great <> 1)
    e = e + 1
    great = get_common_denom(e, PHI)
Wend
getE = e
End Function


Private Function get_common_denom(ByVal e As Long, ByVal PHI
As Long) As Long

Dim great As Long, temp As Long, a As Long
If (e > PHI) Then
    While (e Mod PHI <> 0)
```

```
        temp = e Mod PHI
        e = PHI
        PHI = temp
    Wend
    great = PHI
Else
    While (PHI Mod e <> 0)
        a = PHI Mod e
        PHI = e
        e = a
    Wend
    great = e
End If
get_common_denom = great
End Function


Private Sub show_primes()
Dim no_primes As Long, i As Long, prime As Boolean, j As Long
Status.Text = "1"
no_primes = 1
For i = 2 To 400
    prime = True
    For j = 2 To (i / 2)
        If ((i Mod j) = 0) Then
            prime = False
        End If
    Next j
    If (prime = True) Then
        no_primes = no_primes + 1
        Status.Text = Status.Text + ", " + Str(i)
    End If
Next i
Status.Text = Status.Text + vbCrLf + "Количество первых про-
стых чисел:" + Str(no_primes)
End Sub


Private Sub CommandButton2_Click()
Unload Me
'при закрытии формы очищаем текстовые поля
Text1.Text = ""
Text2.Text = ""
Text3.Text = ""
Text4.Text = ""
Text5.Text = ""
Text6.Text = ""
Text7.Text = ""
Text8.Text = ""
Text9.Text = ""
End Sub
```

```
Private Sub CommandButton4_Click()
'обращение к процедуре вывода простых чисел в поле формы
Call show_primes
End Sub
```

6. В результате нажатия кнопки «Таблица простых чисел» диалоговое окно примет вид, показанный на рис.32.

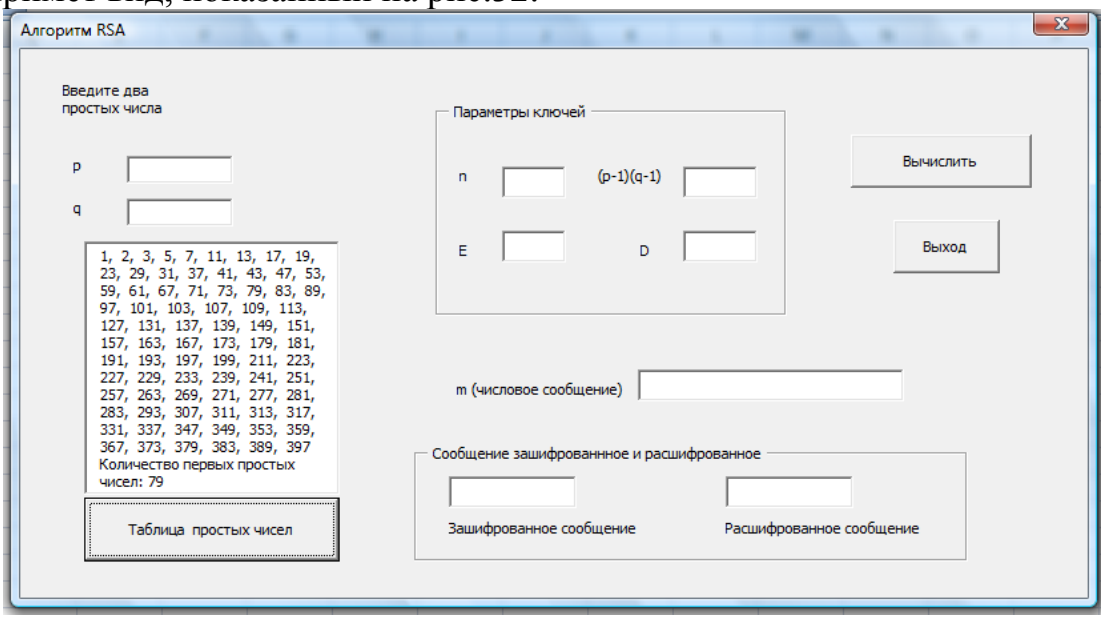

Рис.32

7. В итоге введения исходного текста сообщения и двух простых чисел *p,q* после нажатия кнопки «Вычислить» диалоговое окно примет вид, показанный на рис.33.

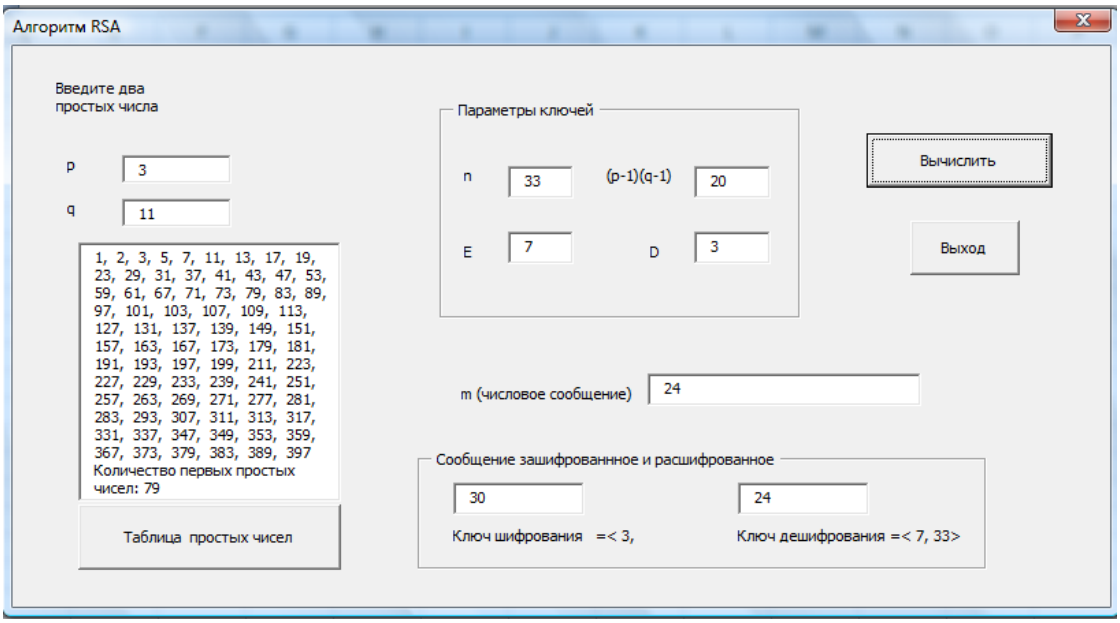

Рис.33

8. Нажатие кнопки «Выход» приведет к закрытию формы.

Индивидуальные задания по лабораторной работе №8.

Задание 1. Поэкспериментируйте с созданной пользовательской формой, задавая различные начальные *p,q* для одного и того же текста сообщения. Проанализируйте результаты.

Задание 2. Поэкспериментируйте с созданной пользовательской формой, задавая различные исходные сообщения. Проанализируйте результаты.

Задание 3. Для вычисленной по своему варианту в индивидуальном задании к лабораторной работе №7 хеш-функции выражения, приведенного в табл. 15, рассчитайте с использованием, созданной в лабораторной работе № 8 формы, значения открытого ключа: *n* и *E* и соответствующего ему секретного ключа *D* для пары $p=3$, $q=11$. Проанализируйте результат.

4.9 Лабораторная работа № 9.

Тема: симметричные криптосистемы.

Цель работы: Разработать криптографическую защиту информации, содержащейся в файле данных, с помощью алгоритма шифрования, указанного в варианте. Для этого:

1. Разработать алгоритмы шифрования и дешифрования блока (потока) открытого текста заданной длины из алфавита Zn на заданном ключе с помощью метода, указанного в варианте (Если это позволяет алгоритм, длину блока взять кратной 8 бит).
2. Определить алфавит криптосистемы (открытого текста и шифротекста). Если алфавит не задан в варианте, выбрать его самостоятельно, так, чтобы он включал в себя символы используемого в примере открытого текста. Например, русский, английский, ASCII. Поставить символам исходного алфавита в соответствие символы из алфавита Zn (n – основание алфавита).
3. Написать программу генерации случайных ключей шифра, оценить размерность ключевого пространства.
4. Написать программу, реализующую шифрование на заданном ключе открытого текста, состоящего из символов заданного алфавита. Открытый текст, ключ и шифротекст должны быть представлены отдельными файлами.
5. Написать программу для реализации алгоритма дешифрования полученного файла шифротекста при известном ключе.
6. Провести тестирование программ
   a) на коротких тестовых примерах.
   b) на текстах в несколько страниц.

4.10 Лабораторная работа № 10.

Тема: криптоанализ симметричных криптосистем.

Задача: Провести эксперимент по определению практической стойкости, алгоритма, разработанного в лабораторной работе №9.

Считать, что противнику известен алгоритм шифрования. Выбрать наилучший с его точки зрения алгоритм подбора ключа и обосновать свой выбор.

Использовать методы:

- анализа статистических свойств шифротекста (частот появления букв).
- силовую атаку (полный перебор ключей).
- другие (если есть более эффективные)

С помощью программы, реализующей выбранный алгоритм криптоанализа провести эксперимент по вскрытию шифротекстов различного размера. При использовании статистического криптоанализа использовать табл. 5 и табл. 6 или подсчитать частоты появления букв используемого алфавита в тексте, частью которого является текст примера. Для проверки на «осмысленность» полученного текста создать мини-словарь из части слов, встречающихся в тексте примера.

Построить графики зависимости времени криптоанализа от параметров алгоритма шифрования (длины или других параметров ключа, размера шифротекста или др., в зависимости от алгоритмов шифрования и криптоанализа).

Проведите эксперимент по определению параметров, необходимых для практической криптостойкости алгоритма шифрования, разработанного в лабораторной работе №9. А именно: размер передаваемого текста, размер и характеристики ключа, объем ключевого пространства и другие параметры алгоритма шифрования.

Практической криптостойкостью в данной работе будем считать невозможность взлома шифра противником, имеющим в распоряжении один ПК мощности, равной мощности компьютера, на котором делалась работа и один час времени.

Индивидуальные задания по лабораторным работам №9,10

Таблица 16

№	Задание	№	Задание
1	Шифрующие таблицы с числовым ключом	13	Аффинная система подстановок Цезаря
2	Шифр Гронсфельда с ключевым словом	14	Шифр Вижинера с числовым ключом
3	Алгоритм, реализующий идею «диска Альберти» для русского алфавита.	15	Алгоритм, реализующий идею «диска Альберти» для английского алфавита
4	Шифр Цезаря с ключевым словом	16	Шифрующие таблицы Трисемуса
5	Шифрующие таблицы с перестановкой по ключу – размеру таблицы.	17	Шифр гаммирования с генератором ключей на основе датчика случайных чисел
6	Полибианский квадрат для русского алфавита.	18	Полибианский квадрат для английского алфавита.
7	Шифр Гронсфельда с числовым ключом	19	Шифр Вижинера с ключевым словом
8	Шифр Кардано без поворотов.	20	Шифр Вернама
9	Шифр Плейфера	21	Шифр Хилла для 3-грамм
10	Шифрующие таблицы с ключевым	22	Шифрующие таблицы с двойной

	словом		перестановкой по ключевому слову.
11	Шифр Цезаря многоалфавитный	23	Шифр Уинстона
12	Шифр гаммирования с линейным конгруэнтным генератором ключей	24	Шифрующие таблицы с двойной перестановкой по числовому ключу.
	Дополнительные варианты (повышенной сложности):		
25	Магические квадраты		
26	Шифр Кардано с поворотами.		

4.11 Лабораторная работа № 11.

Тема: Криптографические протоколы на основе асимметричных криптосистем.

Разработать алгоритмы, реализующие криптографические протоколы (см. вариант задания) взаимодействия удаленных абонентов на основе асимметричных криптосистем.

Написать программы, реализующие эти протоколы для всех участников. Значения модуля криптосистемы выбирать не менее 50 бит. Для вычислений с большими числами можно использовать специальные программы. Для проверки чисел на простоту использовать комбинированный алгоритм на основе тестов Леманна или Рабина-Миллера Хеширование выполнять на основе любого блочного симметричного алгоритма (например, с использованием сети Фейстеля или алгоритма из предыдущих лаб. работ) по одной из схем, данных в лекциях.

Проверить правильность выполнения протокола для малых значений параметров криптосистемы (контрольный пример).

Продемонстрировать выполнение протокола для нормальных значений параметров криптосистемы.

Индивидуальные задания по лабораторной работе №11

Таблица 17

№	Задания	№	Задания
1	Протокол обмена секретным документом комбинированным методом шифрования на основе криптосистемы RSA.	14	Протокол двустороннего подписания контракта на основе алгоритма цифровой подписи Эль Гамаля.
2	Протокол двустороннего подписания контракта на основе алгоритма цифровой подписи ГОСТ Р 34.10-94.	15	Протокол обмена несекретным документом с цифровой подписью на основе алгоритма ГОСТ Р 34.10-94.
3	Протокол обмена несекретным документом с цифровой подписью на основе алгоритма RSA.	16	Протокол двустороннего подписания контракта на основе алгоритма цифровой подписи RSA.
4	Протокол обмена секретным до-	17	Протокол обмена несекретным до-

	кументом, зашифрованным с помощью алгоритма RSA.		кументом с цифровой подписью DSA.
5	Протокол идентификации абонента с помощью алгоритма цифровой подписи DSA.	18	Протокол обмена секретным документом с цифровой подписью на основе алгоритма RSA.
6	Протокол обмена несекретным документом с невидимой цифровой подписью на основе алгоритма RSA.	19	Протокол византийского соглашения для трех участников на основе схемы Шамира проверяемого разделения секрета.
7	Протокол идентификации абонента с помощью алгоритма цифровой подписи ГОСТ Р 34.10-94.	20	Протокол обмена несекретным документом с цифровой подписью на основе алгоритма Эль Гамаля.
8	Протокол генерации сеансового секретного ключа на основе криптосистемы RSA.	21	Протокол экспоненциального ключевого обмена по методу Диффи-Хеллмана.
9	Протокол двустороннего подписания контракта на основе алгоритма цифровой подписи DSA.	22	Протокол вычисления дискретного логарифма со скрытием информации от оракула.
10	Протокол обмена несекретным документом со слепой цифровой подписью на основе алгоритма RSA.	23	Протокол обмена секретным документом, зашифрованным с помощью алгоритма Эль Гамаля
11	Протокол аутентификации Шнорра.	24	Протокол «подбрасывания монеты по телефону».
12	Протокол идентификации абонента с помощью алгоритма цифровой подписи RSA.	25	Протокол идентификации абонента с помощью алгоритма цифровой подписи Эль Гамаля.
13	Протокол вычисления ключа доступа при разделении секрета между тремя участниками по схеме Шамира проверяемого разделения секрета.	26	Протокол обмена секретным документом комбинированным методом шифрования на основе экспоненциального ключевого обмена по методу Диффи-Хеллмана.

ЛИТЕРАТУРА:

1. Алферов А.П., Зубов А.Ю., Кузьмин А.С., Черемушкин А.В. Основы криптографии: Учебное пособие. – М.: Гелиос АРВ, 2001.
2. Введение в криптографию. Под общ. Ред. В.В.Ященко. – М.: МЦНМО, "ЧеРо", 1998.
3. ГОСТ 28147-89 Системы обработки информации. Защита криптографическая. Алгоритм криптографического преобразования
4. ГОСТ Р 34.10-2001 Информационная технология. Криптографическая защита информации. Процессы формирования и проверки электронной цифровой подписи
5. ГОСТ Р 34.11-94 Информационная технология. Криптографическая защита информации. Функция хэширования
6. ГОСТ Р 50739-95 Средства вычислительной техники. Защита от несанкционированного доступа к информации. Общие технические требования
7. ГОСТ Р 50922-2006 Защита информации. Основные термины и определения
8. ГОСТ Р 51188-98 Защита информации. Испытания программных средств на наличие компьютерных вирусов. Типовое руководство
9. ГОСТ Р 51275-99 Защита информации. Объект информатизации. Факторы, воздействующие на информацию. Общие положения
10. ГОСТ Р 53898-2010 Системы электронного документооборота. Взаимодействие систем управления документами. Требования к электронному сообщению
11. ГОСТ Р ИСО 7498-2-99 Информационная технология. Взаимосвязь открытых систем. Базовая эталонная модель. Часть 2. Архитектура защиты информации
12. ГОСТ Р ИСО/МЭК 15408-1-2002 Информационная технология. Методы и средства обеспечения безопасности. Критерии оценки безопасности информационных технологий. Часть 1. Введение и общая модель.
13. ГОСТ Р ИСО/МЭК 15408-2-2002 Информационная технология. Методы и средства обеспечения безопасности. Критерии оценки безопасности информационных технологий. Часть 2. Функциональные требования безопасности
14. ГОСТ Р ИСО/МЭК 15408-3-2002 Информационная технология. Методы и средства обеспечения безопасности. Критерии оценки безопасности информационных технологий. Часть 3. Требования доверия к безопасности
15. ГОСТ Р ИСО/МЭК 7498-1-99 Информационная технология. Взаимосвязь открытых систем. Базовая эталонная модель. Часть 1. Базовая модель
16. Ерош И.Л. Дискретная математика. Математические вопросы криптографии. – Учебное пособие / СПбГУАП. СПб., 2001.
17. Пазизин С.В. Основы защиты информации в компьютерных системах. – М.: ТВП/ОПиПМ, 2003. 178 с.
18. Пазизин С.В. Основы защиты информации в компьютерных системах: Учебное пособие. – М.: ТВП, 2001.
19. Проскурин Г.В. Принципы и методы защиты информации. – М.: МИЭМ, 1997.

20. Романец Ю.В., Тимофеев П.А., Шангин В.Ф. Защита информации в компьютерных системах и сетях. – М.: Радио и связь, 1999.
21. Рябко Б.Я., Фионов А.Н. Криптографические методы защиты информации – М.: Горячая линия – Телеком, 2005.
22. Саломаа А. Криптография с открытым ключом. М: Мир.,1996.
23. Сычев Ю.Н. Основы информационной безопасности. – М.: 2006.
24. Шеннон К. Предсказание и энтропия печатного английского текста. В кн. Работы по теории информации и кибернетике. – М.: Иностранная литература, 1963.
25. Шеннон К. Теория связи в секретных системах. В кн. Работы по теории информации и кибернетике. – М.: Иностранная литература, 1963.

Рекомендуемые сайты

Стандарты и рекомендации в области информационной безопасности - http://unix1.jinr.ru/faq_guide/sec/jet/infosec/starec.html

Приложение

Таблица 1

Функции обработки строковых выражений

Название	Описание	Синтаксис
Asc	Возвращает ASCII- код начальной буквы строки.	Asc(string)
Chr	Преобразует ASCII- код в строку.	Chr(charcode)
LCase UCase	Преобразует строку к нижнему и верхнему регистру.	LCase(string) UCase(string)
Len	Возвращает количество символов в строке.	Len (string)
Left	Возвращает подстроку, состоящую из заданного числа первых символов исходной строки.	Left (string, length) string – исходная строка; length – число символов.
Right	Возвращает строку, состоящую из заданного числа последних символов исходной строки.	Right (string, length) string – исходная строка; length – число символов.
Mid	Возвращает подстроку строки, содержащую указанное число символов.	Mid (string, start [,length]) string –строковое выражение, из которого извлекается подстрока; start –позиция символов в строке, с которой начинается нужная подстрока; length – число возвращаемых символов подстроки.
LTrim	Возвращает копию строки без пробелов в ее начале.	LTrim (string)
RTrim	Возвращает копию строки без пробелов в ее конце.	RTrim (string)
Trim	Возвращает копию строки без пробелов в ее начале и конце.	Trim (string)
Space	Возвращает строку, состоящую из указанного числа пробелов.	Space(number)

Split	Преобразует строку в одномерный массив, нумеруемый с нуля.	Split(Expression [,Delimiter] [,Limit] [,Compare]) Expression –преобразуемое строковое выражение; Delimiter – разделитель между элементами строкового выражения, из которых создается массив. По умолчанию пробел. Limit – максимальное число элементов в массиве. Если значение параметра равно -1, то ограничений на размерность массива нет; Compare – целое число, указывающее критерий отбора строк.
Join	Преобразует массив в строку.	Join(SourceArray [,Delimiter] SourceArray –преобразуемый массив; Delimiter – разделитель между элементами строкового выражения, из которых создается массив. По умолчанию пробел.
String	Возвращает строку, состоящую из указанного числа повторений одного и того же символа.	String(number, character) number – число повторений символа; character –повторяемый символ.
StrComp	Возвращает результат сравнения двух строк.	StrComp (string1, string2 [,compare]) string1 и string2 –два любых строковых выражения; compare –указывает способ сравнения строк. По умолчанию используется тип сравнения, заданный инструкцией Option Compare. Допустимые значения: -1– сравнение согласно инструкции Option Compare; 0– двоичное сравнение; 1– посимвольное сравнение без учета регистра; 2– сравнения на основе информации из базы данных. Возвращаемые значения: -1, если string1 меньше чем string2; 0, если string1 равняется string2; 1, если string1 больше чем string2.
StrReverse	Возвращает строку в обратном порядке.	StrReverse (string)
InStr, InStrRev	Возвращает позиции первого и последнего вхождений одной строки внутри другой строки.	InStr ([Start,] StringChek, StringMatch[,Compare]) InStrRev(StringChek, StringMatch, [Start], [Compare]) Start – числовое выражение, задающее по-

		зицию, с которой начинается поиск. Если этот параметр опущен, то поиск начинается с первого символа строки; StringChek –строковое выражение в котором выполняется поиск; StringMatch -искомое строковое выражение; Compare – указывает способ сравнения строк. 0 – двоичное сравнение, 1 – посимвольное сравнение без учета регистра.
Replace	Находит и заменяет в строке одну подстроку другой подстрокой.	Replace(Expression, Find, Replacewith [,Start[,Count[,Compare]]]) Expression – строка, в которой заменяется подстрока; Find –заменяемая подстрока; Replacewith –подстрока, на которую заменяется подстрока, указанная в качестве значения параметра Find; Start – позиция в строке, с которой ищется подстрока, указанная в качестве значения параметра Find. Если этот параметр опущен, то поиск начинается с первой позиции; Count –указывает сколько найденных строк нужно заменить. Если этот параметр опущен, то будут произведены все замены; Compare - критерий сравнения при поиске подстроки. 0 – двоичное сравнение, 1 – посимвольное сравнение без учета регистра.
Val	Возвращает числа, содержащиеся в строке в качестве числовых значений соответствующего типа.	Val(string) String – строка, любое допустимое строковое выражение.

Таблица 2

Функции для работы с файлами

Название	Описание	Синтаксис
ChDir	Изменяет текущую папку.	ChDir Path
ChDrive	Изменяет текущий диск.	ChDrive Drive
CurDir	Возвращает имя текущей папки.	

Dir	Возвращает файл или папку, соответствующую образцу, указанному в параметре PathName. Если несколько файлов соответствуют образцу, то возвращается первый из них. Используется для проверки существования файла на диске.	Dir [[(PathName [,Attributes])] Параметр Attributes принимает значения согласно табл. 14.
FileAttr	Возвращает значение типа Long, представляющее режим файла, открытого с помощью инструкции Open. Возвращаемые значения: 1 (для режима Input), 2 (Output), 4 (Random), 8 (Append) и 32 (Binary)	FileAttr (Filenumber, Returntype) Filenumber- допустимый номер файла; Returntype –число, указывающее характер возвращаемых данных. При 1, функция FileAttr возвращает значение, указывающее режим работы файла.
GetAttr	Возвращает значение типа Integer, определяющее атрибуты файла, каталога или папки. Значение, возвращаемое функцией является суммой констант, приведенных в табл. 14.	GetAttr (Path)
SetAttr	Устанавливает атрибуты файла	SetAttr PathName , Attributes
FileCopy	Копирует файл	FileCopy Source, Destination Source – строковое выражение, указывающее имя компилируемого файла; Destination - строковое выражение, указывающее имя результирующего файла. Может содержать имя каталога, папки или диска.
FileDateTime	Функция возвращает дату и время последнего изменения файла	FileDateTime Path
Kill	Удаляет существующий файл	KillDir Path В параметре допустимо использование символов * и ? для удаления нескольких файлов по маске.
MkDir	Создает новую папку	MkDir Path
RmDir	Удаляет существующую папку	RmDir Path

Таблица 3

Константы атрибутов файла

Константа	Значение	Описание
vbNormal	0	Обычный
vbReadOnly	1	Только для чтения
vbHidden	2	Скрытый
vbSystem	4	Системный
vbDirectory	16	Каталог или папка
vbArchive	32	Файл был изменен после последнего резервирования.